

CISM DOMAIN 4

Incident Management and Incident Response Overview

At its core, incident management exists to address a wide range of events that threaten the operation of any enterprise by responding to and containing security incidents, then restoring normal operations as quickly as possible. First, let's take a broad view of these concepts and how they relate to the enterprise as a whole

Incidents

Incidents are unexpected events that can originate from a wide spectrum of potential sources.

This emphasizes the breadth of potential sources that can lead to **security-related incidents**, underscoring the importance of a comprehensive **incident response strategy**.

Incidents are **unexpected, disruptive events** that may arise from a wide variety of sources—technical, environmental, operational, or human-related. What unifies them in the context of information security is their **potential impact on the confidentiality, integrity, or availability (CIA) of information assets**.

Categories of Incident Sources:

- **Cyberattacks** – Malicious activities such as ransomware, phishing, DDoS, and malware infections that directly threaten IT systems and data.
Natural Disasters – Events like floods, earthquakes, or fires that can damage infrastructure and disrupt critical operations.
- **Loss of Key Personnel** – Departure or sudden unavailability of individuals essential to maintaining information security functions or business continuity.
- **Workplace Accidents** – Physical incidents that could indirectly compromise security controls, such as disabling surveillance or physical access systems.

The ability to detect, identify and assess the situation, determine the causes and quickly arrive at solutions can mean the difference between an inconvenience and a disaster.

- Incident management and response efforts need to be inclusive of managing and responding to incidents as they relate to information security, regardless of their origin (logical, physical, human).

Core Message:

The organization must respond to **all types of incidents through the lens of information security**. Regardless of the incident's origin, the **primary concern is how it impacts IS assets** and what response is needed to mitigate that impact.

Takeaway:

As a Certified Information Security Manager, your role is to ensure:

- The incident response plan is **holistic**, covering both IT-specific and broader enterprise risks.
 - **Risk assessments** account for non-traditional sources of disruption.
 - **Stakeholders across business units** understand their roles in reporting, containing, and recovering from incidents.
-

Defining an Incident

One of the critical responsibilities of the **Information Security Manager (ISM)** is to **clearly define what constitutes a security-related incident**. This foundational step enables consistent detection, classification, and response across the enterprise. One important role of the information security manager is to define what constitutes a security-related incident.

This categorizes various **types of security incidents** to ensure a shared understanding across all stakeholders and to support a formalized and actionable **incident response plan (IRP)**.

One important role of the information security manager is to define what constitutes a security-related incident.

- Many incidents that initially appear to be malicious instead turn out to be the result of human error.
- Typically, enterprises experience nearly double the number of incidents due to human error than are caused by externally initiated security breaches.

Incident Types:

- **Malicious Code Attacks:** Includes viruses, worms, trojans, and spyware introduced intentionally or inadvertently.
- **Unauthorized Access to Resources:** Any access attempt or success by unapproved users, including privilege escalation or credential misuse.
- **Unauthorized Use of Services:** Legitimate services being exploited for non-business or malicious purposes.
- **Unauthorized Changes:** Configuration or system changes performed without proper authorization or change control.
- **Denial of Service (DoS):** Disruption of service availability through flooding, crashing, or resource exhaustion.
- **Misuse or Abuse of Resources:** Internal misuse of systems (e.g., using corporate email for phishing).
- **Surveillance and Espionage:** Activities such as keylogging, wiretapping, or unauthorized data extraction.
- **Hoaxes / Social Engineering:** Psychological manipulation to trick users into compromising information or systems.
- **Ransomware:** Malicious encryption of data or systems, typically followed by extortion demands.

Insight:

By establishing a comprehensive incident definition, the ISM ensures:

- Consistent and timely incident detection
- Accurate classification and prioritization
- Appropriate stakeholder escalation and containment measures

Tip for implementation: Integrate this definition directly into your organization's **incident response policy**, and ensure alignment with your **security operations center (SOC)** or **managed security service provider (MSSP)**.

Incident Management Program Overview

This presents a high-level overview of an **Incident Management Program (IMP)**, a cornerstone capability within a mature Information Security Management System (ISMS).

Key Description for Presentation:

An **Incident Management Program** is designed to detect, respond to, and recover from security events that deviate from normal business operations. Its purpose is to **reduce enterprise impact and ensure continuity of operations**.

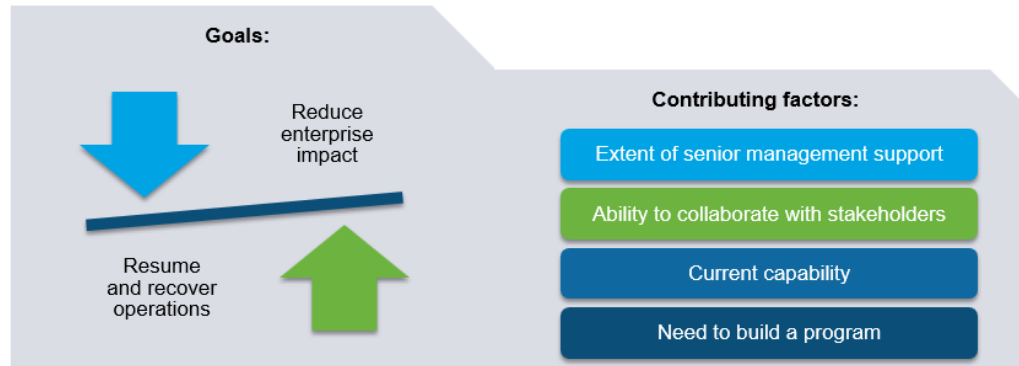
An incident management program is a subset of risk management, with a focus on planning, preparation and identification of those events which deviate from normal, planned operations.

The desired goal is to:

- 1) reduce the impact felt by an enterprise,
- 2) resume and recover operations to acceptable levels.

Incident Management Program Overview

Incident management programs typically fall under risk management and focus on planning, preparation and identification of events that deviate from normal operations.



Program Goals:

- **Reduce Enterprise Impact:** Minimize damage to systems, data, operations, and reputation.
- **Resume and Recover Operations:** Rapidly restore normalcy through predefined response and recovery procedures.

These objectives align with **risk management principles**, especially those supporting business continuity and resilience. To develop a successful incident management program, the information security manager should consider contributing factors, including:

Contributing Factors to IMP Success:

1. **Extent of Senior Management Support**
 - Executive sponsorship legitimizes the program and ensures allocation of adequate resources and authority.
2. **Ability to Collaborate with Stakeholders**
 - Cross-functional collaboration (IT, legal, HR, PR, etc.) ensures effective and coordinated response efforts.
3. **Current Capability**
 - Assesses the maturity of existing response procedures, technical tools, and staff preparedness.
4. **Need to Build a Program**
 - Recognizes gaps in incident response capabilities and informs the development of a roadmap for implementation or improvement.

Where an incident management program already exists, the information security manager will need to review the existing capabilities, skills and instrumentation to address any potential gaps while enhancing, augmenting and maturing an existing program to meet the needs of an enterprise based on changes to its operating environment.

Insight:

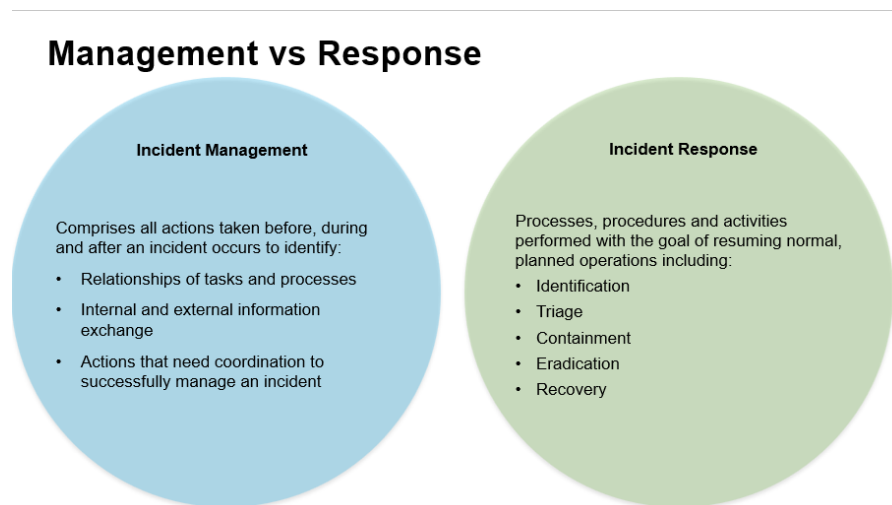
A successful IMP requires a **well-structured incident response lifecycle**: preparation, detection, containment, eradication, recovery, and lessons learned. Key elements include:

- Defined roles and responsibilities
- Playbooks for different incident types
- Communication and escalation paths
- Integration with business continuity and disaster recovery

Tip: Regular testing (e.g., tabletop exercises) and post-incident reviews help build organizational muscle memory and strengthen the program over time.

Management vs Response

This clarifies the **difference between Incident Management and Incident Response**, two critical but often misunderstood components of an effective information security program.



Subtle differences and nuances exist between incident management and incident response functions

Incident Management – *The Strategic Layer*

- **Definition:** Encompasses all strategic and organizational actions taken *before, during, and after* an incident.
- **Key Focus:**
 - **Task & Process Relationships** – Understanding interdependencies within the organization.
 - **Information Exchange** – Coordinating communication flows (internally and externally).
 - **Overall Coordination** – Ensuring all response activities are properly supported and managed.

Think of Incident Management as the governance and coordination framework that ensures incidents are handled consistently, in alignment with enterprise risk appetite and business continuity objectives.

Incident Response – *The Tactical Layer*

- **Definition:** Focuses on the *immediate execution* of technical and operational actions once an incident occurs.
- Incident response: Incident response is the planning, coordination and execution of appropriate containment, eradication and recovery activities This includes the activities, processes and procedures performed when responding to an incident focusing on:
- **Phases:**
 1. **Identification** – Detecting and recognizing an incident.
 2. **Triage** – Prioritizing based on severity and potential impact.
 3. **Containment** – Preventing further spread or damage.
 4. **Eradication** – Removing the root cause.
 5. **Recovery** – Restoring systems to normal and validating integrity.

Incident Response is the hands-on aspect—the playbook in motion when a breach or disruption occurs.

Insight:

- Both domains must be clearly defined in policy and well-integrated into your **Information Security Governance** and **Business Continuity Frameworks**.
 - **Incident Management is broader**, encompassing communication, escalation, compliance, and oversight.
 - **Incident Response is operational**, often led by IT/security response teams following predefined procedures.
-

Management vs Response (Continued)

This emphasizes the **shared foundation and strategic alignment** between **Incident Management** and **Incident Response** in enterprise risk governance.

Integrated Capabilities for Resilience

Although **Incident Management** and **Incident Response** serve different functions (strategic coordination vs. tactical execution), they are **mutually reinforcing disciplines** that together:

- **Enable emergency operations** during adverse events (e.g., cyberattacks, system outages, or physical disruptions).
- Are **integral components of enterprise risk management and resiliency frameworks**.
- **Support business continuity and risk mitigation goals** by ensuring incidents are addressed systematically and effectively.
- Require **top-level sponsorship** — leadership **knowledge, engagement, and commitment** are vital for building credibility, allocating resources, and ensuring effectiveness.

Together incident management and incident response capabilities are the operationalization of emergency operations during an adverse event impacting an enterprise.

- Both are a component of overall enterprise resiliency and risk management.
- Help to ensure risk to the enterprise is properly managed and addressed.
- Require acknowledgement along with reasonable and appropriate commitments by senior management to ensure that risk is sufficiently addressed and efficiently and effectively managed to the acceptable risk tolerance level.

Key Message:

- **You can't respond effectively if you haven't managed the process well.**
- Incident response without proper incident management leads to **fragmented actions, delayed recovery, and missed learning opportunities.**
- Both functions must be **aligned with enterprise risk appetite** and **embedded in governance structures.**

This alignment forms the **foundation of a mature information security program**, ensuring **repeatability, accountability, and business value** in adverse conditions.

Incident Management and Response Goals

This outlines the **strategic and operational objectives** of an effective incident management program. These goals are essential for reducing the impact of disruptions and ensuring a timely and coordinated recovery.

Strategic Objectives

These objectives ensure that the incident management framework is **aligned with enterprise priorities**:

1. **Supporting overall enterprise strategy**
Aligns incident management with organizational goals, risk tolerance, and business

continuity priorities.

2. **Providing a means to address the situation and minimize impact**
Establishes structured procedures to reduce business disruption during security events.
3. **Providing management with sufficient information to decide courses of action**
Ensures decision-makers receive timely, accurate, and contextual insights.
4. **Maintaining or restoring continuity of services**
Focuses on resuming essential functions with minimal downtime.
5. **Providing initial defense against attacks**
Integrates early detection and containment mechanisms into incident response playbooks.
6. **Providing additional deterrence measures**
Enhances post-incident prevention through lessons learned, threat intelligence, and control improvements.

Design incident management practices to mitigate the impact of and ensure the efficient and effective recovery from an incident are:

- Supporting the overall enterprise strategy.
- Providing an effective means of addressing the situation so it minimizes the impact to the enterprise.
- Providing management with sufficient information to decide appropriate courses of action.
- Maintaining or restoring continuity of enterprise services in line with business continuity and disaster recovery plans.
- Provide an initial defense against subsequent attacks.
- Provide additional deterrence measures (using technology, investigation and prosecution). This program is likely not to be known to threat actors and may not be notably deterrent externally.

The goals of incident management and response activities can be summarized as the following:

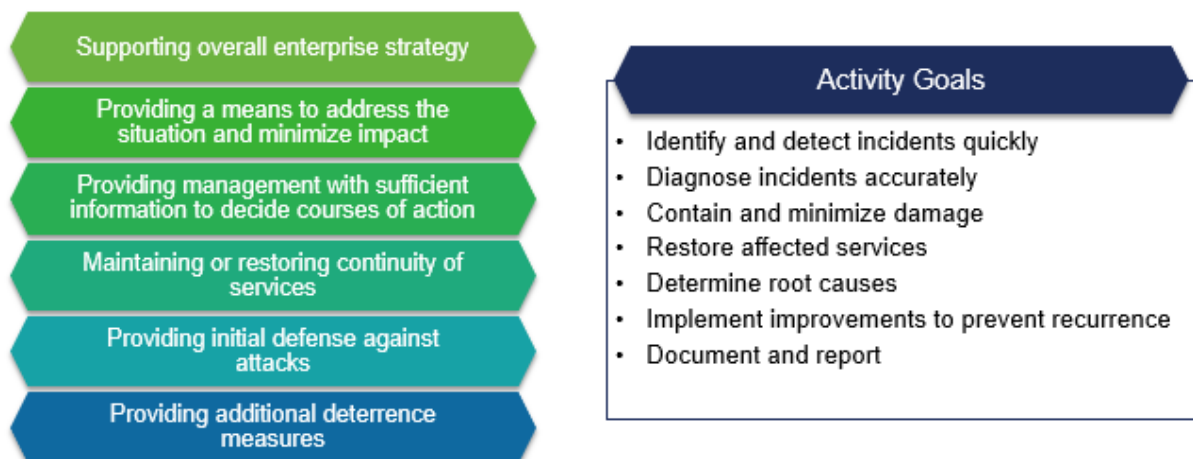
- Identify and detect incidents quickly.
 - Diagnose incidents accurately.
 - Contain and minimize damage.
 - Restore affected services.
 - Determine root causes.
- Implement improvements to prevent recurrence.
- Document and report.

Activity Goals (Execution-Focused)

These are the **tactical goals** of day-to-day incident response operations:

- **Identify and detect incidents quickly** – Fast detection is critical to minimize spread and impact.
- **Diagnose incidents accurately** – Accurate classification ensures correct escalation and handling.
- **Contain and minimize damage** – Immediate containment actions protect critical systems.
- **Restore affected services** – Timely restoration supports business continuity.
- **Determine root causes** – Root cause analysis drives continuous improvement.
- **Implement improvements to prevent recurrence** – Reinforces organizational learning and resilience.
- **Document and report** – Maintains accountability, supports compliance, and enhances incident databases.

Design incident management practices to mitigate impact and ensure recovery:



Insight:

Importance of Incident Management

This underscores **why** incident management is a critical capability within an enterprise information security program.

Core Principles of Importance

1. **"Enterprises increasingly rely on information processes and systems."**
 - Digital transformation has made organizations more dependent on IT infrastructure, meaning **any interruption** can have widespread consequences.
 - This dependency elevates the **business impact of IT incidents**.
2. **"Significant disruption can result in severe impacts."**
 - These impacts may include **financial loss**, **regulatory penalties**, **reputational damage**, or **operational downtime**.
 - An incident can easily **cascade across systems and stakeholders** if not contained.
3. **"How quickly an enterprise can identify, analyze, respond to, and recover from an incident affects impacts and costs."**
 - The **speed and efficiency** of incident response significantly **influence the total cost of an incident**.
 - Delays in detection or action can **escalate technical issues into organizational crises**.

Risk Indicators Driving the Need for Incident Management

These indicators justify why robust incident management programs are more crucial than ever:

- **Increasing occurrences and escalating losses**
The **volume and cost** of incidents are on the rise globally.
- **Increase of software or system vulnerabilities**
More systems and code mean a larger **attack surface**.
- **Security control failure**
Gaps in layered security controls lead to **incident exposure**.
- **Legal and regulatory mandates**
Compliance requires **incident detection, reporting, and response capabilities** (e.g., GDPR, HIPAA, SOX).

- **Sophisticated and capable threat actors**
Adversaries use **advanced techniques**—requiring proactive incident response capabilities.
- **Exploitation of IT processes and practices**
Misconfigured systems, **shadow IT**, and **process gaps** are often exploited.
- **Zero-day attacks**
These **unknown vulnerabilities** are exploited before a patch exists—requiring immediate, adaptable response.

So, why is this important? As we have noted throughout this course, enterprises increasingly rely on information processes and systems.

- Significant disruption to those processes, systems and activities can result in unacceptably severe impacts.
- The speed that enterprise can identify, analyze, respond to and recover from an incident reduces the impact felt by the enterprise and ultimately the costs associated with the incident. This normally results in senior management understanding that the enterprise needs an effective and efficient means of responding to an incident.

Some indicators that can help make the case for incident management to senior leaders include:

- The trend of both increased occurrences and escalating losses resulting from information security incidents (e.g., ransomware)
- The increase of vulnerabilities in software or systems affecting large parts of an organization's infrastructure and impact operations
- Failure of security controls to prevent incidents
- Legal and regulatory mandates requiring the development of an incident management capability
- The growing sophistication and capabilities of threat actors including advanced persistent threats (APTs)
- Exploitation of poorly managed IT processes and practices
- Increasing zero-day attacks

Insight:

Incident management is not a reactive-only function—it is a **strategic enabler** of resilience, business continuity, and trust. IS managers must:

- **Design and test incident response plans**

- **Embed detection mechanisms**
 - **Collaborate with legal, HR, and operations**
 - **Continuously monitor evolving threats and compliance requirements**
-

Incident Management Program Preparation

This provides the **foundational elements** necessary to **build and prepare** a well-functioning incident management program. Preparing an effective program ensures that the organization can swiftly and effectively respond to disruptions.

Successful Outcomes

“Requires an approach aligned with the enterprise to minimize impact and cost if an incident occurs.”

- Successful incident management begins with **business alignment**.
- This means the incident program must support business objectives, continuity requirements, and risk tolerance.
- The **goal** is to ensure **measurable, repeatable outcomes** that minimize cost, disruption, and risk.

Structure and Operation

Enterprises must decide structure and operation appropriate to their needs.”

- There is **no one-size-fits-all**. Enterprises must consider:
 - Size and complexity of the organization
 - Regulatory environment
 - Industry-specific risks
- The structure may include dedicated response teams (CSIRTs), escalation paths, and reporting hierarchies.

Activities and Resources

“Individual program activities and resources vary based on enterprise qualities.”

- Activities include detection, containment, communication, investigation, and recovery.
- Resources involve personnel, technology (SIEMs, IDS/IPS), and budget.
- Tailor these to your **enterprise capabilities and maturity level**.

Development and Management

“Requires identification of key processes, definition of practices and training of staff.”

- Development includes:
 - **Defining procedures** (incident types, escalation paths)
 - **Training** IT and business units on detection and response protocols
 - **Continuous improvement** through lessons learned and testing (e.g., tabletop exercises)
- Management requires **ongoing governance**, policy enforcement, and performance measurement.

How an enterprise prepares to manage and respond to incidents will greatly influence its ability to recover and resume normal business operations.

- A successful outcome requires a consistent, coordinated approach that is aligned with the enterprise to ensure minimal impacts and costs to the enterprise when an incident does occur.
- Each enterprise must decide the structure and operation that is reasonable and appropriate for their needs. Individual program activities and resources vary based on an enterprise’s qualities, requirements and needs (maturity, industry, strategic goals, compliance requirements, geographic operations, staffing levels and expressed desire or need for addressing incidents).
- Individual program activities and resources vary based on enterprise qualities. Program management (planning, training, testing), operational activities (processes, procedures, protocols), tactical activities (evidence collection, triage, initial analysis) practices and individual activities.

Ensuring successful development and management of an enterprise’s incident management program requires the:

- Identification of key processes, definition of practices and activities along with management and training of staff to ensure the proper support and alignment with the enterprise's strategic goals and objectives.

Summary

To **prepare an effective incident management program**, an IS manager must:

- Align the strategy to business goals and risk appetite
 - Define the structure, resource needs, and key procedures
 - Continuously train, test, and improve the program
 - Maintain flexibility to adapt to evolving threats and organizational changes
-

Resource Coordination

Purpose:

To ensure an **effective and resilient incident management capability**, resource coordination integrates various functional areas, aligns with business continuity, and enables a proactive incident response posture.

An effective incident management capability increases overall organizational resiliency efforts in time of need. Coordinating incident management resources includes aspects such as:

1. Incident Management Team (IMT)

“Coordinates business and technical resources”

“Includes internal and external resources (HR, PR, legal, finance, vendors and providers)”

- The IMT serves as the **central coordinating body** activated during incidents.
- Its role is to unify diverse stakeholders to:
 - **Ensure timely decision-making**
 - **Manage communication across teams**
 - **Leverage internal resources (e.g., HR, PR) and external providers (e.g., legal counsel, cloud vendors)**

- A well-structured IMT avoids delays and confusion during crises.

Incident Management Team (IMT)

- Coordinates business and technical resources assigned as part of the enterprise's incident management team.
- In addition to security and IT, members may include representatives from legal, finance/accounting, human resources (HR), public relations (PR), corporate communications, the impacted lines of business, and resources who are actively responding to the incident, such as hardware vendors or service providers

2. Incident Management and Response Capabilities

- Balance capabilities with baseline requirements
 - Carefully balance the extent of incident management and response capabilities with baseline requirements (security, business continuity [BC] and disaster recovery [DR]) as defined by the appropriate stakeholders
- Determine cost-effectiveness of high capability level
 - At some point it may be more cost effective to use alternative processing options than to maintain a high level of incident management and response capability.
- Consider in context of BC and DR planning
 - The level of incident management capability must also be considered in the context of BC planning and DR planning.
 - These capabilities must be **right-sized** to organizational needs.

4. System Deployment and Implementation

- Enables active collaboration between the business, technical counterparts and incident management staff
- Provides insight in developing approaches (security baselines, better defensive practices, and more streamlined response processes.)

Tailoring Incident Management and Response



Purpose:

To ensure that the **incident management and response strategy is not one-size-fits-all**, but is **customized** to fit the **organization's mission, structure, and stakeholder expectations**. Each enterprise needs to tailor the strategy and solution to ensure that efforts are properly aligned with the enterprise and stakeholder needs

Key Tailoring Considerations:

1. Constituency to be Served

- Understand **who the stakeholders are** (employees, customers, regulators).
- Define **service levels** and **communication expectations** during incidents.

2. Enterprise Mission, Goals, and Objectives

- Align the incident program with the **strategic direction of the enterprise**.
- For example, a financial services firm will prioritize **confidentiality and uptime**, whereas a public health agency may focus on **availability and compliance**.

3. Services to be Provided

- Clarify what **incident response capabilities** are being offered:
 - Detection?
 - Analysis?

- Recovery?
- Customize response plans based on service-level requirements.

4. Organizational Model and Stakeholder Relationships

- Structure the program to reflect **lines of business**, **geographic reach**, and **governance models**.
- Integrate with existing **risk, compliance, and legal functions**.

5. Funding

- Ensure adequate **budget allocation** for:
 - Tools (SIEM, endpoint detection)
 - Staffing (analysts, responders)
 - Training and tabletop exercises
- **Cost justifications** should be aligned to risk appetite and business impact.

6. Resources Needed

- Assess **personnel, technology, and third-party services** required for an effective response.
- Ensure readiness through **resource allocation planning**, including surge capacity for major incidents.

More Details

- Each enterprise needs to tailor the strategy and solution to ensure that efforts are properly aligned with the enterprise and stakeholder needs
- The approach adopted by the enterprise depends on a variety of factors, including:
 - Constituency to be served—Who are the consumers of this capability?
 - Enterprise mission, goals and objectives—Are we properly aligned with the enterprise?
 - Services to be provided—What services are we committing to provide our constituents?
 - Organizational model and the relationship with the various stakeholders—Who are we accountable and responsible to?
 - Funding for start-up costs and ongoing operations—How are we going to pay for this capability?

- Resources needed by the computer security incident response team (CSIRT) —What do we need to deliver the desired capabilities to the constituents we serve?

Numerous organizations—such as the Carnegie Mellon University Software Engineering Institute (CMU SEI), the US National Institute of Standards and Technology (NIST), the International Consortium for Organizational Resilience (ICOR), the SANS Institute and ISACA — provide varying degrees of information, approaches and methodologies to develop incident management and response capabilities.

Guidance:

“A tailored program is a **resilient program**. It’s not about overengineering but about making sure the right people, tools, and processes are in place to respond quickly and effectively when incidents occur.”

Incident Handling Functions and Life Cycle

two critical perspectives in managing incidents:

1. **Incident Handling Functions** – the core operational activities performed during an incident.
2. **Incident Life Cycle** – the structured phases through which an incident passes, from anticipation to closure and improvement.

Incident Handling Functions

These are the **operational capabilities** required by an incident response team to effectively manage security events:

1. **Detection and Reporting**

- Identify anomalies or indicators of compromise.
- The ability to receive and review event information, incident reports and alerts
- Ensure all stakeholders know how to report suspected incidents.

2. Triage

- **Prioritize incidents** based on impact, scope, and urgency.
- The actions taken to categorize, prioritize and assign events and incidents to maximize the effectiveness of limited resources
- Separate false positives from real threats.

3. Analysis

- Investigate root cause, affected systems, and potential damage.
- The attempt to determine what happened, the impact and threat, the damage that resulted, and the recovery or mitigation steps that should be followed
- Leverage threat intelligence and forensic tools.

4. Incident Response

- **Execute containment, eradication, and recovery** procedures.
- The actions taken to resolve or mitigate an incident, coordinate and disseminate information, and implement follow-up strategies to prevent recurring incidents
- Implement countermeasures and communication protocols.

Incident Management Life Cycle

This outlines the **strategic and procedural flow** of an incident from start to finish:

1. Planning and Preparation

- Creating policies, acquiring management support, developing user awareness, building a response capability
- Conducting research and development
- Building checklists and acquiring necessary tools
- Developing a communication plan and awareness training
- Ensuring stakeholder buy-in and commitment to an incident response program

2. Detection, Triage, and Investigation

- Defining events vs. incidents, and notification process
- Detecting and validating incidents
- Prioritizing and rating incidents
- Implementing intrusion detection systems, intrusion prevention systems and security information event monitoring

3. Containment, Analysis, Tracking, and Recovery

- Executing containment strategy for various incidents
- Performing forensic analysis according to evidence-handling processes
- Executing recovery procedures in line with enterprise business continuity plans and disaster recovery plans
- Determining the source of the incident

4. Post-Incident Assessment

- Conducting post-mortem (Exactly what happened and at what time? How well did staff and management perform in dealing with the incident? Were the documented procedures followed? Were they adequate? What corrective actions can prevent similar incidents in the future?)
- Reporting on incident management-related metrics (e.g., mean-time-to-incident-discovery, cost of recovery)
- Providing feedback on lessons learned

5. Incident Closure

- Conducting incident response postmortem analysis
- Submitting reports to management and stakeholders

Tip:

“An effective IS program doesn’t just react—it prepares. Incident handling is **tactical**, but the life cycle adds the **strategic lens** needed for long-term resilience and improvement.”

Incident Management Metrics and Indicators

structured overview of the **quantitative and qualitative indicators** used to evaluate the **effectiveness and efficiency** of an enterprise's incident management capability. These metrics help security managers make informed decisions, assess response readiness, and demonstrate value to stakeholders.

Key Performance and Outcome Metrics

1. Key Performance Indicators (KPIs)

- Measure how well the incident management team performs against predefined **operational targets**.
- A performance indicator or key performance indicator is a type of performance measurement
- Example: *Mean Time to Detect (MTTD)*, *Mean Time to Respond (MTTR)*.

2. Key Goal Indicators (KGIs)

- A measure that tells management, after the fact, whether an IT process has achieved its business requirements; usually expressed in terms of information criteria
- Reflect whether **strategic goals** (e.g., maintaining uptime or limiting data loss) are being achieved.
- More outcome-focused and aligned with **business objectives**.

Recovery Objectives

3. Recovery Point Objective (RPO)

- Determines and quantifies acceptable data loss during operation disruption
- The **maximum acceptable data loss** measured in time (e.g., last backup point).
- Guides **data backup frequency** and continuity planning.

4. Recovery Time Objective (RTO)

- The **maximum allowable time** to restore business operations after an incident.
- Drives resource allocation and service restoration priorities.

Continuity and Availability Benchmarks

5. Service Delivery Objectives (SDO)

- Minimal level of service that must be restored after an event to meet business requirements until normal operations are restored
- Used in SLA development and continuity validation.

6. Maximum Tolerable Outage (MTO)

- Represents the **absolute threshold** of downtime the business can endure without irreversible damage.
maximum time an enterprise can operate in alternate (or recovery) mode
- Critical for **business impact analysis (BIA)**.

7. Allowable Interruption Window (AIW)

- amount of time that normal operations can be down before the enterprise faces major financial difficulties that threaten its existence.
- Helps fine-tune recovery procedures.

Threat Indicators

8. Indicators of Attack (IoA)

- **Real-time behavioral indicators** suggesting an attack is in progress (e.g., lateral movement, command-and-control traffic).
- Enable **proactive detection and containment**.

9. Indicators of Compromise (IoC)

- **Forensic artifacts** such as IPs, hashes, and domain names that indicate a system has already been compromised.
- Support **incident investigation and threat hunting**.

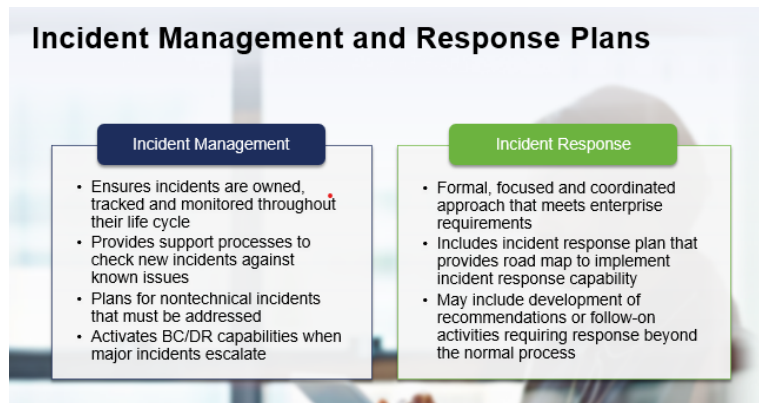
Insight:

“Metrics aren’t just numbers—they tell the story of your program’s maturity, resilience, and alignment with business goals. You can’t manage what you don’t measure.”

Incident Management and Response Plans

Incident management and response plans are where the enterprise will outline what needs to happen. When done in advance of an incident occurring, the enterprise is not just prepared to handle those incidents, but they can reduce the impact and loss from incident occurrence.

Incident Management and Incident Response, both of which are foundational to an enterprise's resilience strategy.



Incident Management

This is the overarching process that ensures **all incidents—regardless of origin—are tracked, owned, and effectively managed throughout their lifecycle.**

Effective incident management ensures that incidents are identified, detected, recorded and managed to limit impacts.

Key elements:

- **Lifecycle Ownership:** Ensures incidents are monitored end-to-end for accountability and resolution.
- **Known Issues Repository:** New incidents are checked against existing patterns or previous problems to improve diagnostic efficiency.
- **Nontechnical Preparedness:** Plans are in place for incidents beyond IT—such as legal, HR, or operational disruptions.
- **Escalation to BC/DR:** When severe incidents occur, Incident Management may activate **Business Continuity** or **Disaster Recovery** plans.

Think of Incident Management as the **governance and coordination** function for all incidents—technical or non-technical.

More Insight Incident Management

Effective incident management ensures that incidents are identified, detected, recorded and managed to limit impacts. This includes:

- Ensuring that the incidents are owned, tracked and monitored throughout their life cycle.
- Initial support processes that allow new incidents to be checked against known issues, errors and problems so that any previously identified workarounds can be quickly identified.
- Planning for nontechnical incidents that must be addressed (social engineering, lost or stolen backup tapes or devices, physical theft of sensitive materials and natural disasters).
- Activation of business continuity (BC) or disaster recovery (DR) operations when major incidents occur requiring response beyond that provided by the normal incident process.

Incident Response

This refers to the **tactical execution** phase focused on immediate action to mitigate damage and restore services.

Incident response is the last step in an incident-handling process that encompasses the planning, coordination and execution of appropriate containment, eradication and recovery activities

Key components:

- **Coordinated Action Plan:** A documented, formal process tailored to the organization's needs.
- **Implementation Road Map:** The response plan guides the execution, from detection to recovery.
- **Post-Incident Activities:** May include recommendations, lessons learned, and actions that go beyond routine operations.

Incident Response is a **subset** of Incident Management, focusing on **execution and recovery** when an actual event occurs.

More Insights

Incident response

Incident response is the last step in an incident-handling process that encompasses the planning, coordination and execution of appropriate containment, eradication and recovery activities.

- Enterprises should have a formal, focused and coordinated approach to responding to incidents, including an incident response plan (IRP) that provides the road map for implementing the incident response capability. Each enterprise needs a plan that meets its unique requirements, which relate to the enterprise's mission, size, structure and functions.
- This may also include the development of recommendations or lead to follow-on mitigation activities identified during the lessons learned.

Integration Perspective:

Both functions are essential:

- Incident Management offers the **strategic view and control framework**.
- Incident Response offers the **operational agility** to deal with emerging threats.

A well-designed security program aligns both to strengthen enterprise resilience, reduce downtime, and safeguard reputation.

Incident Management Objectives

Primary Objectives of Incident Management

These objectives ensure that incidents are handled with **minimal business disruption and maximum organizational resilience**:

1. **Rapid Containment and Recovery**
 - Handle incidents swiftly to **limit exposure** and recover within predefined **Recovery Time Objectives (RTOs)** and **Recovery Point Objectives (RPOs)**.
 - Time is critical—delays translate to greater risk and cost.
2. **Restoration of Normal Operations**
 - Aim to **resume business processes quickly and safely**, minimizing productivity and service losses.
3. **Prevent Recurrence**

- Implement processes to **analyze, document, and learn** from past incidents.
- Institutionalize **lessons learned** into future strategies and playbooks.
- 4. **Proactive Risk Reduction**
 - Use **predictive intelligence and security analytics** to deploy **countermeasures** before incidents occur.
 - Reduce incident probability through **continuous improvement** and **threat modeling**.
- 5. **Safeguard Critical Assets**
 - Design protective strategies (e.g., segmentation, least privilege) to **mitigate asset-level impacts** during incidents.

More Insights

The objectives of incident management are to:

- Handle incidents quickly to contain exposure or eradicate to enable recovery within recovery time objectives (RTOs) and recovery point objectives (RPOs).
- Restore systems and business processes to normal operation.
- Prevent incidents from recurring by documenting and learning from past incidents.
- Deploy proactive countermeasures to prevent/minimize the probability of incidents occurring in the future.
- Deploy safeguards to protect and reduce impact to assets should an incident occur.

Key Capabilities to Ensure Incident Readiness

To fulfill the objectives, organizations must ensure:

- **Early Detection and Accessibility**
 - Monitoring systems must be **well-integrated and accessible** to trained personnel for rapid response.
- **Skilled, Trained Personnel**
 - Regular training ensures responders are **confident, efficient, and adaptive**, improving continuity and minimizing escalation.
- **Information Capture and Lessons Integration**
 - Incident managers must lead efforts to **analyze root causes**, capture data, and **apply corrective and preventive actions**.
- **Structured Disaster Declaration Process**
 - Disaster declaration must follow **clear criteria**, guided by **experience, knowledge, and authority**, ensuring decisions are justified and controlled.

For effective incident management and response capabilities, enterprises need to ensure:

- Key control monitoring capabilities provide early detection of potential problems,
- Monitoring and detection capabilities are accessible by appropriate incident management personnel.
- Personnel are trained in assessing the situation, conducting triage and managing effective responses enhance operational continuity and controlling impacts.
- Incident managers provide processes to capture all relevant information and apply previously learned lessons.
- Disasters are declared through well-defined criteria, experience, knowledge and authority to invoke the disaster recovery processes necessary to maintain or recover operational status. We will discuss more about this criteria later in this module

Insight:

Effective incident management is not reactive—it's **strategically prepared, routinely exercised, and continuously improved**. The best programs focus equally on:

- **Minimizing risk**
 - **Speeding recovery**
 - **Institutionalizing resilience**
-

Incident Recording represents a key component of a mature **Incident Management process**, aligning directly with Domain 4: *Incident Management*.

What is Incident Recording?

Incident recording is the structured documentation and logging of incident-related information throughout the response lifecycle. Its primary objective is to **capture, track, analyze, and inform** decisions in both real-time and post-incident review.

Purpose and Importance

Effective incident recording ensures that incidents are:

- **Identified** and categorized accurately
- **Tracked** through resolution
- **Documented** for forensics and learning

- **Analyzed** to inform continuous improvement
- **Routed** appropriately for triage and escalation

Effective incident management ensures that incidents are identified, detected, documented and managed to limit impacts. Recording incidents allows the enterprise to:

Key Functions

1. **Track Incident Response Activities**
 - Maintain a **real-time activity log** of containment, eradication, and recovery actions.
 - Enhances accountability and provides an audit trail.
 - Track incident response activities,
2. **Provide Information to Aid Planning Activities**
 - Recorded incidents feed into **strategic planning**, informing threat modeling, tabletop exercises, and budget allocation.
 - Provide information to aid planning activities
3. **Review All Aspects of an Incident**
 - Ensure **360-degree analysis**: root cause, attack vectors, response delays, impact, and resolution effectiveness.
4. **Properly Document Information (Including Forensics)**
 - Accurate and timely recording ensures compliance, supports **legal defensibility**, and enables digital forensics investigations.
5. **Prioritize and Route Incidents to the Correct Resources**
 - Helps automate or guide **incident triage and escalation** based on criticality, type, and required expertise.

Insight:

Many organizations fail not in detection, but in **poor documentation and unclear escalation paths**. A mature IS program includes:

- An **incident recording framework** tied to severity classifications
 - Logging tools integrated with **SIEM** and ticketing systems
 - **Post-incident reviews** using captured data to drive continuous improvement
-

Enterprise Benefits of an Effective Incident Management Program

Tangible business and operational advantages that an enterprise gains when it implements a robust and integrated **incident detection, response, and escalation framework**. These benefits align with ISACA's CISM Domain 4 (*Incident Management*) and are critical to building an enterprise-resilient IS strategy.

Key Benefits:

1. Ensure Timely Incident Detection

- Early detection is critical to reducing mean time to respond (MTTR) and minimizing damage.
- Enables containment before the incident escalates to a disaster-level event.

2. Effectively Manage Unanticipated Events That May Disrupt Business

- Enhances the organization's ability to respond to **zero-day threats**, natural disasters, or internal system failures.
- Supports **continuity of operations**.

3. Establish Severity and Declaration Criteria

- Promotes clarity and consistency in **incident classification**.
- Ensures incidents are **escalated appropriately** based on risk and business impact.

4. Train Personnel to Recognize and Escalate Incidents

- Builds a security-aware culture where **employees are the first line of defense**.
- Reduces reliance solely on automated tools.

5. Build Response Capabilities That Support Business Strategy

- Aligns incident response with the **enterprise's risk appetite and strategic priorities**.
- Demonstrates value to the board and executive leadership.

Operational Enhancements:

6. **Proactively Manage Incident Risk in a Cost-Effective Manner**
 - Enables **prioritization of risks** and targeted investment in controls and recovery strategies.
7. **Provide Integration Across Security Functions**
 - Reduces silos between IT, compliance, and business units.
 - Supports a **holistic risk view** across the enterprise.
8. **Provide Monitoring and Metrics**
 - Enables **performance-based management** through KPIs and KRIs.
 - Data-driven insights support **continuous improvement**.
9. **Ensure Information and Plans Are Current and Accessible**
 - Maintains up-to-date playbooks, contacts, and escalation procedures.
 - Reduces downtime in incident triage and response efforts.

Outcomes of good incident management and response include the following benefits for the enterprise:

- Ensure timely incident detection.
- Effectively manage unanticipated events that might threaten to disrupt the business.
- Establish well-defined severity and declaration criteria along with escalation and notification processes.
- Train personnel to recognize incidents, apply severity criteria, and properly report and escalate.
- Build response capabilities that demonstrably support the business strategy by being responsive to the criticality and sensitivity of the resources protected.
- Proactively manage the risk of incidents appropriately in a cost-effective manner
- Provide integration of security-related organizational functions to maximize effectiveness.
- Provide monitoring and metrics to gauge performance of incident management and response capabilities,
- Ensure that information and plans are current and accessible when needed by periodic testing and updates

Insight:

Many security programs fail to communicate **value to business stakeholders**. The benefits shown here are the exact outcomes a **CISO or IS Manager must showcase** to gain continued investment and board-level support. Always tie incident management back to:

- **Operational resilience**
- **Regulatory compliance**

- Strategic risk management
-

Enterprise Outcomes

The Value of Incident Management and Response

An effective **ff program** is not a siloed activity—its success directly influences the performance and integration of broader enterprise functions such as **risk management** and **assurance processes**.

This illustrates two primary enterprise-wide outcomes that are enabled when incident management is effectively embedded into business operations.

1. Risk Management

- **Definition:** Any realized threat or vulnerability that bypasses the organization's internal controls is considered an incident.
- **Key Objective:** Ensure the **incident is contained and managed** before it escalates into a **disaster** or causes strategic-level impact.
- **Best Practice:**
 - This aligns with the need to **contain residual risk** and meet RTOs/RPOs (Recovery Time and Point Objectives).
 - Organizations must treat incident handling as a **risk response strategy**—specifically, **mitigation and contingency planning**.

- Any risk that materializes that is not prevented by the enterprise's internal controls constitutes an incident.
- The incident must be managed and responded to with the intent that it does not escalate into a disaster.

2. Assurance Process Integration

- **Integrated Planning:**
 - Enterprise incidents often require cross-functional responses (e.g., HR, legal, compliance, operations).
 - Plans must therefore be **interconnected** and tested **across departments**.
- **Realistic Testing:**
 - Drills and simulations should mirror real-world conditions to validate assumptions and identify gaps in interdepartmental dependencies.

Assurance Process Integration

- Integrate and incorporate plans with other organizational functions (physical security, HR, legal) as incidents may require involvement of these functions.
- Develop plans that define departments involved in various incident management and response activities and specifies that those linkages have been tested under realistic conditions
- **Insight:**
 - This reflects **maturity in organizational preparedness**—where response plans are not just written, but **actionable and tested**.
 - It supports assurance to **executive leadership and stakeholders** that the enterprise can withstand adverse events. **Perspective:**

Enterprise outcomes like these move the conversation from **technical response** to **strategic enablement**. As a professional, your role is to demonstrate how incident management contributes to:

- Business continuity
 - Governance maturity
 - Operational resilience
 - Regulatory compliance
-

Value Delivery

Through Incident Management

Objective: The goal of value delivery in the context of information security and incident management is to ensure **business enablement** through **effective risk mitigation**, **assurance**, and **continuity**. This slide reinforces how incident management integrates into the broader business ecosystem to deliver **measurable value**.

Incident management capabilities must be closely integrated with business functions and provide the last line of defense to support cost-effective risk management. Incident management involves more than the technology controls to prevent or respond to incidents; it includes a set of processes that can provide an optimal balance between prevention, containment and restoration.

1. Integrate with Business Processes and Structures

- Incident management should be tightly coupled with **existing operational workflows**, not operate in isolation.
- Seamless integration ensures incidents are **detected, escalated, and resolved** within the business context.

Insight: This aligns with Domain 1 — *Information Security Governance*, ensuring security processes support and enable business objectives.

2. Improve Risk Management and Stakeholder Assurance

- A robust incident response capability increases **confidence in organizational resilience**.
- This builds trust among stakeholders, regulators, and partners.

Perspective: This supports **risk optimization** and enables the enterprise to meet **compliance mandates** while reducing uncertainty.

3. Integrate with Business Continuity Planning (BCP)

- Incident management must be **aligned with BCP/DRP** to ensure seamless recovery and minimal downtime.
- Early detection and containment reduce recovery time and data loss.

Best Practice: Ensure incident playbooks are tested alongside BCP scenarios to validate integration.

4. Protect Critical Functions and Assets

- Incident management acts as the **last line of defense**, protecting essential services, customer data, and intellectual property.
- Embedding it in strategy reinforces **defense-in-depth** and holistic protection.

Link: Closely tied to *Information Risk Management and Security Program Development and Management*.

5. Optimize Risk Management Efforts

- Incident management complements traditional risk processes by offering **real-time, reactive, and adaptive capabilities**.
- It supports **continuous improvement** through root cause analysis and lessons learned.

Closely integrate incident management capabilities with business functions and provide the last line of defense to support cost-effective risk management

To deliver value, incident management should:

- Integrate with business processes and structures as seamlessly as possible.
- Improve the capability to manage risk and provide assurance to stakeholders.
- Integrate with the business continuity plan (BCP).
- Become part of an enterprise's overall strategy and effort to protect and secure critical business functions and assets.
- Provide the backstop and optimize risk management efforts

Result: Greater agility in managing emerging threats and aligning with business risk appetite.

Summary:

Value delivery is not just about response—it's about **strategic alignment**. The role is to ensure incident management:

- Protects enterprise value.
- Enhances resilience and reputation.
- Supports business agility and trust.

IS Manager Role



Understanding the IS Manager Role

The role of the information security manager has within BC, DR planning and incident response is influenced by enterprise size, the industry, applicable regulatory requirements and maturity of BC, DR and incident response capabilities.

To be successful, it is important for the information security manager understand:

- Requirements to adequately address their responsibilities regardless of the environment they operate in.
- How the incident management and response plans and activities integrate with the overall BCP and DRP if an incident escalates to a disaster.

Smaller Enterprises: The information security manager may be involved in all BC, DR and incident response functions

- This includes assisting the business units completing their business impact analyses (BIAs), working with the IT department to identify suitable backup and recovery solutions, coordinating incident response efforts as events are escalated and delivering normal information security services needed by the enterprise.

Larger enterprises

- BC, DR and incident response business functions may be separate departments with dedicated staff and budgets needed to support operations.
- The role of the information security manager may be an internal consultant, advising as a subject matter expert in any of the related functions.
- The information security manager may be a general contributor—supporting and augmenting existing operations and delivering services in support of business need

Or they may function purely as a business peer, with security incidents being reported for the purposes of monitoring, prioritization and remediation, with response efforts performed by the incident response department.

Strategic Alignment

In Incident Management

Purpose:

Strategic alignment ensures that **incident management initiatives directly support the enterprise's strategic objectives**. Without alignment, incident management may become a siloed activity, failing to deliver enterprise value.

incident management must be aligned with an enterprise's strategic plan

Key Components to Align:

1. **Constituency**
Identify and engage all stakeholders impacted by incident response. This includes internal users, third parties, and customers.
2. **Mission**
The incident management approach must reinforce the enterprise's **core purpose**—for example, preserving service continuity in a healthcare system or protecting sensitive data in finance.
3. **Services**
Incident response services must be aligned with **business-critical operations**. This ensures that high-value services receive prioritized protection and recovery.
4. **Organizational Structure**
The incident response function must be designed to fit within the **existing governance model**. Clarify reporting lines, authority, and escalation pathways.
5. **Resources**
Ensure that staffing, tools, and capabilities meet the **expected incident response scope**. This includes cross-functional resources (legal, HR, communications).
6. **Funding**
Budgets should reflect **realistic threat exposure and business risk appetite**. Underfunded incident management undermines resilience.
7. **Management Support**
Executive buy-in is essential to **institutionalize incident response** as a formal business function. This support enables quicker decision-making, policy enforcement, and resource allocation.

More Insights

- **Constituency**—To whom does the IMT provide services? It is important to know who the stakeholders are for this function and identify their expectations and information needs. For example, senior management in financial institutions may be bound by Basel III or another regulation. Thus, the IMT should meet applicable performance and reporting requirements.
- **Mission**—The mission defines the purpose of the team and the primary objectives and goals that are provided by IMT. An example of a possible

IMT mission statement follows: The mission of the incident management team is to develop, maintain and deliver incident management capabilities and services to safeguard the organization's information assets against computer incidents. We strive to provide assurance to our stakeholders that risk and cyber- or IT-related incidents are dealt with in an efficient and effective manner and that we will prevent/minimize losses resulting from such incidents.

- **Services**—Services provided by IMT should be clearly defined to manage stakeholder expectations. Services offered in enterprises may differ significantly, and normally have a positive correlation with the size of the enterprise and the extent of senior management support. At a high-level, these services range and include functions such as incident management, vulnerability management, situational awareness, knowledge transfer and event management.
- **Organizational structure**—The structure of the IMT should effectively support the enterprise's structure. For multinational companies, a geography-based structure may be the best. For enterprises with multiple subsidiaries, one IMT may be developed for each major subsidiary. The best structure would provide the business with the maximum availability of IMT services on the most cost-effective basis.
- **Resources**—Sufficient, qualified staffing is needed to be both effective and efficient. Because incident management can include a wide range of services, most of the time it is not possible to have all the resources available within one IMT. One way to solve this issue is to establish virtual team members and/or complement the team with external resources.
- **Funding**—The IMT usually consists of highly specialized members. The training, equipment and systems they use when providing services tends to be very specialized, requiring greater capital expenditures. In view of this, sufficient funding is required to ensure the continuity of critical incident response services.
- **Management support**—Senior management buy-in is essential for establishing a successful incident management capability within an

enterprise. A lack of support can result in any number of issues. For example, the inability to respond to an incident due to an existing silos within the enterprise, untrained team members resulting from being underfunded, insufficient budget allocation to allow for effective and efficient response, or the ability to attract or retain qualified personnel. Without the commitment of senior management, the incident management and response capabilities will rely on personal heroics at best or introduce a variety of legal risk (e.g., the spoliation evidence or mishandling of evidence).

Insight:

Strategic alignment is not a one-time activity—it must be **continually reassessed** to ensure relevance as the enterprise evolves.

Ask yourself:

- Does the current incident management capability reflect the **enterprise's current risk posture**?
- Is the response strategy **proportional to business priorities and threats**?
- Are incident response activities **measurable, reportable, and improvable**?

Tip:

Distinguish between **alignment vs. compliance vs. integration**. Always tie back **incident response capabilities** to:

- Business goals
 - Stakeholder expectation
 - Enterprise risk tolerance
-

Gaining Senior Management Commitment

Effective incident management and response programs require more than just operational efficiency—they need the backing of senior leadership. Gaining this commitment is essential for allocating sufficient resources, aligning with business objectives, and reinforcing organizational resilience.

The three key pillars to secure senior management support:

1. Business Case

- **What it means:** Demonstrates that investing in incident management is a **cost-effective strategy** compared to implementing controls for every potential condition.
- **Relevance:** This aligns with the CISM principle of **risk-based justification**, where security investments must be defensible in terms of business value.

2. Opportunities

- **What it means:** Highlights that mature incident handling capabilities **enhance business reputation**, opening up new opportunities by demonstrating resilience and readiness.
- **Relevance:** Supports **strategic alignment**, as it shows how security supports broader business goals.

3. Resource Management

- **What it means:** Emphasizes the importance of **optimizing resources** by combining effective incident response with prudent information security investment.
- **Relevance:** Connects to the **governance and resource management** domain, where allocation of staff, tools, and budget is driven by impact and value.

More Insights

As is the case with other aspects of information security, senior management's commitment is critical to the success of incident management and response activities.

This can be gained through:

- A business case demonstrating that, under many circumstances, effective incident management and response may be a less costly option than attempting to implement controls for all possible conditions.
- Providing the enterprise more business opportunities by allowing higher levels of acceptable risk based on a demonstrated capacity and capability to handle security incidents.

- Combining sufficient incident response with effective information security is likely to offer the most cost-effective risk management approach and may be the most prudent resource management decision.

Insight:

As a security leader, your ability to present a strong business case, identify value-creating opportunities, and show efficient use of resources is vital to:

- Elevate IS functions from technical operations to **strategic enablers**
 - Gain **executive sponsorship** for ongoing investments
 - Ensure that incident handling is **proactively supported**, not reactively funded
-

Incident Management Resources

outlines the critical steps and stakeholder groups necessary to build and support an effective incident management program.

Incident Management Resources

Objective:

To ensure successful incident response, the enterprise must identify, organize, and align necessary resources—both internal and external—based on a clearly defined implementation strategy.

Three-Phase Approach to Resource Planning:

1. **Develop a Clear Scope, Objectives, and Implementation Strategy**
 - Define **what success looks like** for incident management.
 - Establish alignment with **business priorities and risk posture**.
 - Helps clarify the **roles and responsibilities** for all contributors.
2. **Consider Elements Needed to Move from Current to Desired State**

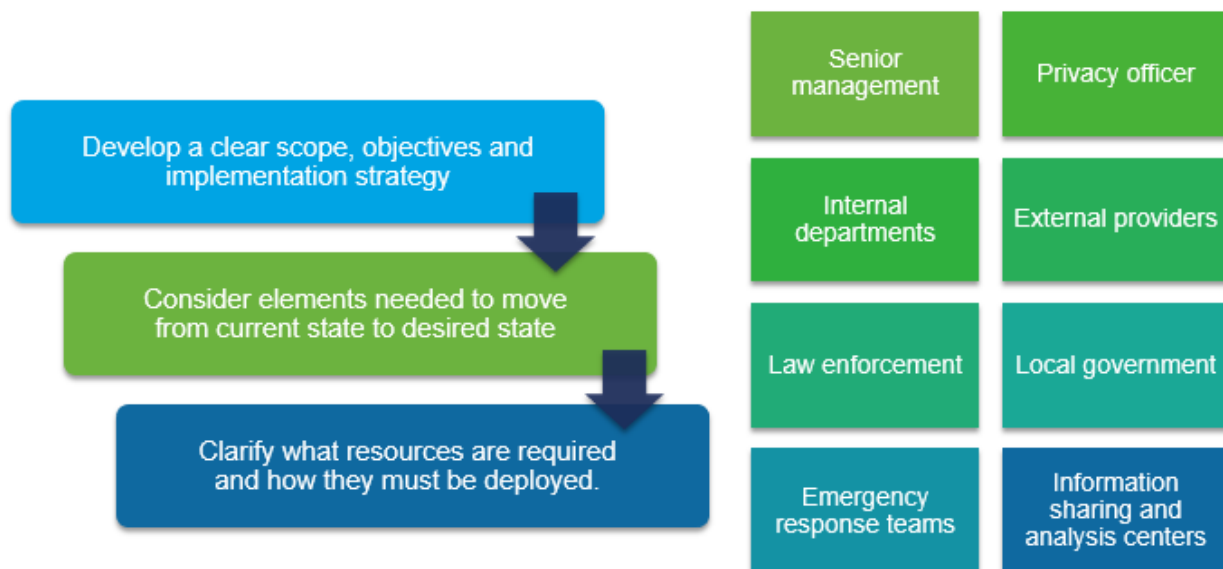
- Conduct a **gap analysis**.
- Assess maturity of **existing capabilities**, tools, and response procedures.
- Identify improvements necessary to meet strategic goals.

3. Clarify What Resources Are Required and How to Deploy Them

- Determine required **personnel, processes, technology, and third-party support**.
- Specify **deployment timing, coordination models**, and response protocols.

More Insights

- Many internal and external resources may be used in the development of an incident management and response plan. It is essential to:
 - Develop a clear scope, objectives and implementation strategy.
 - Consider the elements needed to move from the current state of incident management to the desired state, as defined by the enterprise.
 - Clarify what resources are required and how they must be deployed.



Stakeholder Categories Involved:

Internal Resources	External Resources
Senior management – governance, decision-making	Privacy officer – regulatory compliance
Internal departments – IT, legal, HR, operations	External providers – MSSPs, forensic consultants
Emergency response teams – incident containment and remediation	Local government – public safety, critical infrastructure
Law enforcement – when escalation is required for legal intervention	Information Sharing and Analysis Centers (ISACs) – threat intel and collaboration

Insights:

- This supports the **Governance and Risk Management** domain of CISM.
- It reinforces that incident response is **not a purely technical function**—it is an enterprise-wide capability.
- Proper resource coordination depends on:
 - **Strategic alignment** with BCP/DRP
 - **Defined escalation paths**
 - **Communication protocols across internal and external parties**

Plan Development Challenges

Developing an effective incident management or response plan is not only a technical task but also a leadership, communication, and organizational alignment effort. This slide identifies **five common challenges** that derail planning efforts and reduce incident preparedness.

Key Challenges:

1. Lack of Management Buy-In and Consensus

- One of the most critical blockers.
- Without executive endorsement, plans often lack funding, authority, and cross-departmental support.
- **Align plans with business risk tolerance and secure stakeholder sponsorship** early.

2. Mismatch to Enterprise Goals and Structure

- Plans not tailored to the organization's **specific size, structure, or mission** are ineffective.
- A one-size-fits-all approach creates gaps and redundancies.
- Plans must be based on **risk assessments** and business impact analysis (BIA).

3. IMT Member Turnover

- Incident Management Teams (IMTs) require continuity and domain knowledge.
- High turnover reduces institutional memory and effectiveness during crises.
- Solutions include **cross-training, formal documentation, and succession planning**.

4. Ineffective Communication

- Breakdown in communication leads to poor coordination during both plan development and incident execution.
- Challenges may include **siloed teams, unclear responsibilities, and lack of escalation paths**.
- Plans should define **clear communication protocols**, including **who communicates what, to whom, and when**.

5. Complex, Broad Plan

- Overly detailed or generalized plans can paralyze action during critical moments.
- Plans must be **concise, role-based, and scenario-driven**, enabling easy execution.
- Use **tabletop exercises** to validate clarity and usability.

More Insights

- When developing and maintaining an incident management plan, there may be unanticipated challenges as the result of:
 - Lack of management buy-in and organizational consensus—Most challenges result from a lack of management buy-in and consensus among the business units.

- When an incident occurs, management response may not be provided as expected, thus hindering incident management efforts. This may happen when senior management and other stakeholders or constituents are not involved in incident management planning and implementation.
- Challenges can also be caused by the lack of regular meetings between the IMT and constituents. A sense of ownership among constituents in incident management helps to ensure that sufficient resources and support are available for the IMT.
- Mismatch to enterprise goals and structure—
 - Business operates at an accelerated rate and may change significantly over a short period of time. Incident management may not be able to cope with the speed or nature of changes happening within the enterprise.
 - Consider a situation where the business expands to emerging countries. The presence in new countries may grow at a significant rate; however, it may be difficult to expand incident management capabilities. A round of discussions may be needed to identify critical business functions and local stakeholders and understand local regulations. Senior management is usually occupied with business matters at this stage and may not be able to invest time in incident management. It is the responsibility of the IMT to identify any critical issues and make these known to executive management.

IMT member turnover—

- The champion of incident management, who is normally either a member of senior management or the information security manager, may leave the organization unexpectedly
- This can cause any planning or development efforts to come to a halt. The lack of a champion is likely to reduce the focus and resources devoted to implementing the plan.

Ineffective communication—This may result either in under-communication or over-communication.

- In the case of under-communication, relevant stakeholders may not receive the information they need. This may result in different understandings about the need for incident management planning; the benefits that can be obtained; or their role in developing, implementing and maintaining an incident management capability.
- Over-communication may turn stakeholders against incident management because they may feel that the plan is too much to handle or it competes with priorities they have established.

Complex and broad plan—

- The proposed plan may be good and cover many issues, but it is too complex and too broad.

- Constituents may not be prepared to participate and commit to plans that appear overreaching.

Perspective:

Organizations have to approach plan development with a **governance mindset**:

- **Engage stakeholders early**
- **Tie every section of the plan back to business objectives**
- **Treat the plan as a living document**, tested, updated, and embedded in the organization's culture

Incident Management and Response Teams

emphasizes the importance of identifying and organizing specific functional teams ahead of a potential incident.:

Summary:

An effective incident response capability is **team-based** and **pre-structured**. This slide highlights the **critical roles and responsibilities** of various teams involved in incident response, ensuring that efforts are coordinated, assets are protected, and operations are restored quickly.

Key Teams and Their Roles:

1. Emergency Action Team

- First responders to immediate threats.
- Initiate emergency procedures (e.g., evacuation, lockdown).
- Bridge the gap between incident detection and formal team activation.

2. Damage Assessment Team

- Evaluates the **impact on assets** (e.g., data, facilities, personnel).
- Determines the **severity level** and guides escalation.
- Critical for accurate and timely situational awareness.

3. **Emergency Management Team**

- Oversees the **entire incident response effort**.
- Coordinates between all teams, senior leadership, and external stakeholders.
- Makes strategic decisions, including invoking DRP/BCP.

4. **Relocation Team**

- Activated when primary facilities are unusable.
- Facilitates **relocation of personnel, systems, and services** to alternate sites.
- Coordinates logistical requirements (transport, IT access, workspace).
-

5. **Security Team**

- Handles physical and logical security risks.
- Investigates causes, isolates affected systems, and **protects critical infrastructure**.
- Works closely with legal, compliance, and law enforcement if necessary.

The plan must identify teams and define their assigned responsibilities ahead of an incident occurring. This includes:

- Designating and training end-user personnel to lead teams Depending on the size of the business operation, the team may consist of a single person.
- Considering the level of service and the types of assets lost, compromised, damaged or endangered.
- Developing a matrix to indicate the function correlations among different teams.

Examples of the kinds of teams usually needed include:

- Emergency action team—Designated first responders whose function is to deal with fires or other emergency response scenarios
- Damage assessment team—Qualified individuals who assess the extent of damage to assets and make an initial determination regarding what is a complete loss versus what is restorable or salvageable
- Emergency management team—Responsible for coordinating the activities of all other recovery teams and handling key decision making

•Relocation team—Responsible for coordinating the process of moving from the affected location to an alternate site or to the restored original location

Security team—When no designated/formal capability is defined by the enterprise, the “security team” will often become the de facto CSIRT. It is responsible for monitoring the security of systems and communication links, containing any ongoing security threats, resolving any security issues that impede the expeditious recovery of the system(s) and assuring the proper installation and functioning of every security software package

Insights:

- **Proactive Designation and Training:** Teams must be established *before* an incident occurs. This includes training, simulation exercises, and availability planning.
- **Service-Level Awareness:** Not all assets or services are equal in value. Teams must understand which systems are critical based on **business impact analysis (BIA)**.
- **Functional Correlation Matrix:** CISM leaders should help build **team responsibility maps** to ensure there are no gaps or overlaps in roles. This improves speed and accountability.

Takeaway for IS Managers:

Success in incident response is determined **long before** an incident occurs. Building competent, clearly defined, and well-integrated response teams is a **cornerstone of information security governance**.

Resource Management

In Incident Response

Incident response rarely happens with unlimited time, personnel, or funding. Therefore, **resource triage and prioritization** are essential to restoring business operations quickly and effectively.

Insights:

Key Objectives of Resource Management

1. Efficient Use of Resources

- Time, people, and money are constrained during crises.
- Success depends on how well these resources are deployed under pressure.

2. Oversight & Reporting

- Senior management and the incident response team must monitor resource usage in real-time.
- Regular updates ensure visibility and accountability.

3. Priority-Driven Approach

- Focus first on the **most critical systems** to limit business disruption.
- Resources are assigned based on **business impact analysis (BIA)** and **recovery objectives** (RTO/RPO).

4. Triage Methodology

- Assets are categorized based on current status and restoration feasibility:
 - **Compromised assets:** Cannot be quickly addressed—monitor, isolate, and defer.
 - **Unaffected assets:** Can wait—do not consume resources unnecessarily.
 - **Restorable assets:** Prioritize and act immediately.

Incident management and response activities consume resources that must be managed to achieve optimal effectiveness.

Resource management:

- Encompasses time, people, budget along with other factors to achieve objectives efficiently under constraints.
- Is accomplished by ensuring appropriate oversight, monitoring of resources and regular reporting.
- When it is not possible to achieve all objectives, effective resource management ensures that the most important priorities are addressed first.
- In terms of incident response, effective triage capabilities ensure that limited resources are applied most effectively to contain and limit damage.

During triage promptly identify:

- Compromised assets that cannot be quickly addressed,
- Unaffected assets that can wait
- And assets that can most efficiently be restored with the available resources.

Prioritization = Resilience

This supports a critical principle: **information security resource management must align with business priorities**. Incident response isn't just about speed—it's about restoring **what matters most first**, based on risk and business continuity priorities.

Incident Management Action Plan Phases

Each phase in this cycle represents a **critical function** in a mature incident management program. Together, they form a **continuous improvement loop**.

Prepare

- Develop and document incident response plans.
- Train and assign roles to team members.
- Perform simulations and tabletop exercises.
- Establish escalation paths and communication protocols.

Focus: Ensure preparation aligns with organizational risk appetite and business continuity strategies.

Protect

- Implement **preventive controls** (e.g., firewalls, endpoint security).
- Apply security policies and user awareness training.
- Harden systems and reduce the attack surface.

Focus: Protection must be cost-effective and proportionate to business risk.

Detect

- Deploy detection mechanisms such as **IDS/IPS**, SIEM, and behavioral analytics.
- Monitor for anomalies, breaches, or early signs of compromise.
- Establish baselines for normal activity.

Focus: Emphasize timeliness and accuracy of detection—early detection reduces response cost and impact.

Triage

- Assess severity, scope, and potential impact of the incident.

- Prioritize response efforts based on **criticality and asset classification**.
- Engage key stakeholders early based on incident type and escalation matrix.

Focus: Effective triage enables resource prioritization and strategic decision-making.

Respond

- Contain, mitigate, and eradicate the threat.
- Communicate with affected parties and regulators as required.
- Document actions, lessons learned, and update playbooks.

Focus: Ensure response processes are repeatable, testable, and continually improved.

Defining Incident Management Processes describes:

- 1.Prepare: This phase defines the work to be completed prior to any incident response capability.
- 2.Protect: This can mean not just protecting and securing information assets but also the enterprise brand and reputation
- 3.Detect: The detect process identifies unusual, suspicious or malicious activity that might impact critical business functions or infrastructure.
- 4.Triage: Triage is a process of sorting, categorizing, correlating, prioritizing and assigning incoming reports/events into categories of problems that cannot be addressed, those that can wait, and those that can be addressed efficiently with current resources.
- 5.Respond: The response process includes steps taken to address, resolve or mitigate an incident.

Final Thought:

An effective **incident management lifecycle** ensures business resilience, minimizes downtime, and reinforces stakeholder confidence. It must be **aligned**

with governance, risk management, and compliance (GRC) strategies—hallmarks of the framework.

Evaluating Incident Response Capability

Why It Matters:

An organization's ability to respond to incidents is only as strong as its **preparation, practice, and periodic evaluation**. These assessments ensure that the **Incident Management Team (IMT)** remains capable, agile, and aligned with evolving business needs and threats.

The information security manager must identify what is already in place to understand the current state. Means of evaluating capabilities already in place include :

Surveys

- **Purpose:** Capture subjective feedback from stakeholders (e.g., IT, security, business units).
- **Focus Areas:** Confidence in response process, communication effectiveness, perceived gaps.
- **Note:** Useful for gauging cross-functional engagement and perception of the IMT's value.

Self-Assessment

- **Purpose:** Internal review by the IMT based on defined maturity models or benchmarks (e.g., NIST CSF, COBIT).
- **Use:** Identify process gaps, skills deficiencies, or readiness issues.

- **Note:** Promotes ownership and helps align capabilities with policy and enterprise risk appetite.

External Assessment or Audit

- **Purpose:** Independent validation through **interviews, technical reviews, simulations** (e.g., tabletop exercises).
- **Value:** Brings objectivity and often reveals blind spots missed internally.
- **Note:** Should be part of a formal audit/compliance schedule—especially for regulated industries (e.g., finance, healthcare).

Incident History Review

- **Purpose:** Learn from actual events to improve response capabilities.
- **Scope:** Trends, response times, containment success, recovery effectiveness, and business impact.
- **Note:** This is a key activity in **lessons learned** and continuous improvement cycles.

The information security manager must identify what is already in place to understand the current state. Means of evaluating capabilities already in place include:

Survey of senior management, business managers and IT representatives— Gather information using a collection of senior management, business line managers and technology representatives, employee surveys and focus groups to help determine the past performance and perception of the IMT and its process capabilities.

Self-assessment—Conducted by the IMT against a set of criteria to develop an understanding of current capabilities. This is the easiest method because it does not require participation from many stakeholders. The disadvantage of this method is that it may provide only a limited view on current capability and aspects that stakeholders may consider important.

External assessment or audit— This is the most comprehensive option, and it combines interviews, surveys, simulation and other assessment techniques in the assessment. This option is normally used for an enterprise that already has an adequate incident management

capability but is further improving it or reengineering the processes. These techniques will help to determine if the current state is effective and, if not, will help with determining the desired state of the incident response capability.

Incident history review-- Recent incidents (both internal and external) can provide valuable information on trends, types of events and business impacts. This information is used as an input for the assessment of types of incidents that must be planned for and considered

Guidance:

- Integrate these evaluation methods into the **IS governance framework**.
 - Align reviews with the **business impact analysis (BIA)** and enterprise risk management (ERM).
 - Use findings to drive **KPI/KRI adjustments**, resource allocation, and staff training.
-

Response and Recovery Plan highlights the essential components for designing and implementing an effective Incident Response Plan (IRP) that supports enterprise resilience and aligns with strategic objectives.

Purpose of the Response and Recovery Plan (IRP)

- The IRP serves as a **roadmap** to develop and operationalize incident response capability.
- The IRP to the **enterprise's mission, goals, and strategy**, stressing alignment with broader business objectives.

The incident response plan (IRP) provides the road map to implement the incident response capability.

•The enterprise mission, strategies and goals for incident response should help in determining the structure and necessary resources and management support. Once an enterprise develops a plan and gains management approval, the enterprise should

implement the plan and review it regularly or when there is any significant change introducing unplanned risks to the enterprise. This ensures that the organization is following the road map for maturing the capability and fulfilling the goals for incident response.

Core Components

1. Mission

- Define the IRP's alignment with the enterprise's purpose and security objectives.

2. Strategies and Goals

- Articulate the long-term direction of the IRP, including response and recovery benchmarks.

3. Senior Management Approval

- Ensures sponsorship, resource allocation, and governance backing for IRP effectiveness.

4. Enterprise Incident Response Approach

- Define the enterprise-wide methodology (centralized/decentralized), integration with business functions, and risk posture.

5. Key Personnel and Responsibilities

- Assign roles (e.g., incident handler, communicator) with clear responsibilities for execution.

6. Internal and External Communication

- Establish protocols for timely and secure communication with stakeholders, vendors, regulators, and the public.

7. Metrics

- Use performance indicators (MTTR, number of incidents resolved, etc.) to measure and improve effectiveness.

8. Road Map

- Define phases and timelines for implementation, training, testing, and improvement cycles.

9. Program Fit

- Ensure the IRP integrates with business continuity, disaster recovery, and other governance programs.

10. Program Structure

- Establish governance, escalation procedures, documentation standards, and continuous improvement processes.

The IRP should include the following elements:

- Mission
- Strategies and goals
- Senior management approval
- Enterprise approach to incident response
- Key decision-making personnel and responsibilities
- Internal and external communications
- Metrics for measuring the incident response capability and its effectiveness
- Road map for maturing the incident response capability
- How the program fits into the overall enterprise
- The incident response program structure should also be discussed within the plan.

Insight:

The strength of an IRP is not just in design but in how **well it integrates across the enterprise**, aligns with strategic business priorities, and receives **ongoing executive support**. A well-structured plan reduces response time, limits impact, and builds stakeholder confidence.

Policies and Standards illustrates the critical role that documented policies, standards, and procedures play in strengthening an organization's Incident Management Team (IMT) operations.

Purpose of Documented Policies and Standards:

Establishing formal, written policies and standards ensures that incident management is **predictable, accountable, repeatable, and aligned with enterprise strategy**. These documents serve as the foundation for governance, control, and performance consistency.

The incident response plan (IRP) must be supported by well-defined policies, standards and procedures. A documented set of policies, standards and procedures is important.

Key Benefits:

1. Ensure Activities Align with IMT Mission

- Policies ensure that all response activities are consistent with the goals and purpose of the Incident Management Team (IMT), reinforcing strategic alignment.

2. Establish Correct Expectations

- Standards help stakeholders understand what to expect during an incident, reducing confusion and improving trust and coordination.

3. Provide Guidance for Operational Needs

- Operational procedures detail the step-by-step actions required to handle incidents, ensuring consistency and efficiency across the organization.

4. Maintain Consistency and Reliability of Services

- Defined standards promote reliable outcomes by enforcing repeatable processes, which is essential during high-stress incident conditions.

5. Understand Roles and Responsibilities Clearly

- Policies and procedures assign specific duties, reducing delays and miscommunication during incident response.

6. Set Requirements for Identified Alternate Personnel for all important functions

- Ensures continuity of operations by predefining qualifications, authority, and responsibilities of backup personnel during an incident.

Insight:

In effective incident management, **policies and standards serve as the institutional memory**. They reduce dependency on individual knowledge, support training, facilitate audits, and **demonstrate due diligence**—a critical aspect in both compliance and post-incident investigations.

Organizations should treat these documents as **living resources**, updated regularly to reflect lessons learned, regulatory changes, and evolving business needs.

Developing an Incident Response Plan (IRP) presents a high-level overview of the **incident response lifecycle**, a foundational concept for effective information security governance.

Purpose of the Incident Response Plan (IRP):

An IRP is a **tactical and operational framework** designed to guide how an organization **prepares for, detects, responds to, and recovers from information security incidents**. It is critical in reducing the **impact, cost, and recovery time** of cyber and operational threats.

The IRP is the operational component of incident management.

- The plan details the personnel, actions and activities that take place in case adverse events result in the loss of data, information systems or processes.
- The plan should include the formation, management and maintenance of the incident response team.

IRP Lifecycle Phases:

1. Preparation

- The foundation for effective response.

- Includes team formation, training, incident classification, and tool readiness.
- Policies, communication plans, and escalation paths are defined.

2. Identification

- Detect and confirm the occurrence of an incident.
- Determine scope, severity, and impact based on predefined criteria.

3. Containment

- Short-term actions to isolate and limit damage.
- May involve disconnecting systems, changing credentials, or activating backup communication channels.

4. Eradication

- Remove the root cause (e.g., malware, unauthorized users).
- Clean systems and ensure vulnerabilities are patched.

5. Recovery

- Restore services and systems to normal operation.
- Monitor for reinfection or related issues.

6. Lessons Learned

- Conduct post-incident analysis.
- Identify process gaps and update procedures, training, and controls.

A common approach to developing an IRP is to base it on a six-phase model of incident response that covers preparation, identification, containment, eradication, restoration and follow-up.

1. Preparation: Prepares an enterprise to develop an IRP prior to an incident. This includes establishing approaches, processes and plans to handle incidents along with communicating details.

2. Identification: This phase aims to verify if an incident has happened and investigate the details. Reports on possible incidents may come from information systems, end users or other enterprises. Not all reports are valid incidents; they may be false alarms or may not qualify as an incident. Activities in this phase include assigning ownership and establishing chain-of-custody for evidence.

3. Containment: After an incident has been identified and confirmed, the IMT activates and shares information from the incident handler, conducts a detailed assessment and coordinates further action with the system owner or business manager of the affected information systems/assets. During this phase it is important to gain agreement on actions taken while documenting and maintaining evidence.

4. Eradication: When containment measures have been deployed, it is time to determine the root cause of the incident and eradicate it. Eradication can be done in several ways such as restoring backups to achieve a clean state of the system, removing the root cause, improving defenses, and performing vulnerability analysis to identify any additionally impacted systems with the same root cause.

5. Recovery: This phase ensures that affected systems or services are restored to a condition specified in the service delivery objectives (SDO) or BCP. The time constraint up to this phase is documented in the RTO. It is important to validate the system(s) were recovered successfully and facilitating that system owners can declare return to normal operations.

6. Lessons Learned: Develop a report at the end of the incident response process to share what happened, actions that were taken, results after executing the plan and lessons learned. These lessons should be developed into a plan to enhance the incident management capability and the documentation of the IRP.

Perspective:

This highlights **the maturity of your incident response capability**—a key domain focus. Mature IR programs:

- Have **roles and responsibilities clearly assigned**.
- Are **tested regularly** (via tabletop exercises, red team drills).
- Feed results back into risk management, governance, and policy reviews.

- Are aligned with **BCP/DRP and security architecture**.

Key Reminders for IS Managers:

- The IRP must be **integrated with the enterprise risk strategy**.
 - Every incident must generate **actionable insights**.
 - **Regulatory expectations** (e.g., GDPR, HIPAA, PCI DSS) often require formal IRPs and reporting protocols.
-

Gap Analysis and the IRP represents a crucial phase in **developing or improving an Incident Response Plan (IRP)**. Here is a breakdown of its strategic relevance:

What Is Gap Analysis in the Context of IRP?

A **gap analysis** identifies the difference between the current state of your incident response capabilities and the **desired future state** aligned with business goals, compliance requirements, and threat landscapes.

In a mature IS program, this analysis drives **continuous improvement** and aligns IRP efforts with **organizational resilience objectives**.

Gap analysis provides information on the gap between current incident response capabilities and the desired level determined by senior management.

Breakdown:

1. Capabilities, Skills, and Technology Improvement

- Assess existing tools (e.g., SIEM, SOAR) and team skillsets.
- Identify deficiencies in threat detection, forensics, or real-time analysis.
- Drives investment decisions in training and tooling.

2. Processes That Need to Be More Efficient and Effective

- Examine procedures for containment, escalation, communications, and recovery.
- Are they clearly documented, tested, and repeatable?
- Streamline for reduced response times and error rates.

3. Resources Needed to Achieve Capability Objectives

- Identify people, time, systems, and financial support needed.
- Helps ensure **IR capability aligns with organizational risk appetite**.

•Resources needed to achieve the objectives for the incident response capability

4. Steps Needed to Close the Gap

- Develop an actionable improvement plan (e.g., train staff, update playbooks, test IR scenarios).
- Prioritize initiatives based on risk impact and business value.

•Steps needed to close the gaps between the current state and the desired state.

5. Most Effective Strategy to Achieve Objectives and Prioritize Efforts

- Aligns improvements with enterprise objectives.
- Ensures that investment and attention are **focused on the most critical areas first** (e.g., protecting crown jewels, meeting compliance timelines).

• Most effective strategy to achieve the objectives and prioritize efforts to areas of greatest potential impact and the best cost benefit.

Insights:

- This gap analysis is essential to **demonstrate due diligence** and **maturity growth** during audits or regulatory reviews.
- It ensures that IRPs are not static documents but **living frameworks**.
- The analysis should be periodically reviewed — especially **post-incident or post-audit**.

What Should an IS Manager Do With This?

- Document all gaps and proposed actions.
 - Secure senior management **buy-in** for prioritized improvements.
 - Integrate gap closure efforts with **budget planning, staffing models, and roadmap updates**.
 - Link findings to KPIs and KRIs (e.g., MTTD/MTTR).
-

Logistics outlines a vital but often overlooked component of the **Incident Response Plan (IRP)** — ensuring **operational continuity through logistical preparedness**.

What Does Logistics Mean in IRP?

Logistics in the IRP context refers to the **support systems and materials** needed to **enable recovery operations**, especially when regular business functions are disrupted. This includes ensuring access to people, tools, processes, and documentation.

The IRP should include provisions for logistical support necessary to continue normal business activities during recovery.

Breakdown:

1. Ensure plan can be implemented when regular staff are unavailable

- **Importance:** Incidents can occur during holidays, off-hours, or when key personnel are unreachable.
- **Best Practice:** Cross-train alternate staff, and ensure role redundancy in the IR team.

2. Provide detailed, hardcopy set of procedures

- **Importance:** Digital systems may be compromised or inaccessible during certain incidents (e.g., ransomware).
- **Best Practice:** Maintain **offline IRP binders** or protected USBs at designated secure sites.

Providing detailed, up-to-date hard-copy procedures used by staff and contract personnel who may be unfamiliar with the standard and recovery operations and should be easy to follow

3. Secure necessary forms at an offsite location

- **Importance:** Incident response forms (e.g., breach logs, chain of custody, incident declaration) may be needed urgently.
- **Best Practice:** Store critical operational documents at alternate sites or in **cloud systems with offline sync**.

Securing necessary supplies of forms (check stock, invoice forms and order forms) at an offsite location

4. Provide necessary equipment at the recovery site

- **Importance:** Business Continuity and IR plans often fail if recovery teams don't have access to:
 - Workstations
 - Communication gear
 - Backup drives
 - Documentation tools

Providing necessary equipment at the recovery site. For example, if the data entry function is dependent on certain hardware devices and/or software programs, these programs and equipment, including specialized electronic data interchange (EDI) equipment and programs, must also be provided at the recovery site.

- **Best Practice:** Conduct regular inventories of **go-kits**, stock recovery sites, and perform recovery drills.

Strategic Value to the Organization:

- Reinforces **resilience** by ensuring recovery operations are not dependent on fragile systems or single points of failure.
- Supports **compliance** with ISO 22301 and ISACA-aligned continuity frameworks.
- Enhances **incident readiness**, especially for geographically distributed or hybrid workforce models.

Recommendations:

- During tabletop exercises, test for **logistical readiness**.
 - Assign a **logistics coordinator** within the Incident Response Team.
 - Maintain a **logistics checklist** updated alongside the IRP.
 - Ensure logistics planning is aligned with **BCP and DR plans**.
-

Organizing, Training and Equipping Staff highlights one of the most critical success factors in incident management programs: **preparedness through people**. Ensure the **Incident Management Team (IMT)** is ready, capable, and confident to respond to incidents effectively — through training, testing, and proper resourcing.

Information Security Manager Responsibilities

1. Develop scenarios to test plans ensuring familiarity with tasks and responsibilities

- **Why this matters:** Tabletop exercises, simulations, and red team/blue team drills help build muscle memory and reinforce response roles.
- **Practice:** Regularly validate incident response readiness via **simulated exercises** and update the plan based on results.

2. Help teams identify and equip required resources

- **Key point:** Response teams must know what they need (tools, access, checklists) before a crisis occurs.
- **Focus:** Conduct **resource gap analyses** and ensure pre-positioning of essential IR tools (e.g., forensic kits, communication channels).

3. Assess and modify ambiguous procedures

- **Why this is critical:** Vague procedures lead to delays, confusion, and mistakes during high-stress incidents.
- **Role:** Use **post-incident reviews (PIRs)** and feedback loops to refine procedures and roles continuously.

4. Determine inadequate or ineffective resources

- **Relevance:** Inadequate resources can include:
 - Untrained personnel
 - Outdated IR tools
 - Poor documentation or incomplete escalation paths

To train the response team, the information security manager should:

- Develop reasonable, real-world event scenarios and test the response and recovery plans to ensure that team participants are familiar with their tasks and responsibilities.
- Help teams identify the resources they require for response and recovery, providing the basis for equipping the teams with what they need.
- Assess and modify ambiguous procedures to achieve clarity
- And determine inadequate or ineffective recovery resources.

IMT Member Training Program Phases

Induction

- Initial orientation to the IRP, policies, and organizational goals.

Mentoring

- Shadowing experienced responders, often overlooked but highly effective in skill transfer.

On-the-job

- Practical, live or simulated incident participation to reinforce training.

Formal

- Structured learning: workshops, certifications (e.g., ISACA, SANS), SOP walkthroughs.

IMT members should undergo the following training program:

- Induction to the IMT—The induction should provide the essential information required to be an effective IMT member.
- Mentoring team members regarding roles, responsibilities and procedures—Existing IMT members can provide valuable knowledge to aid new members after induction. To facilitate effective mentoring, the buddy system can be used, pairing new members with experienced members.
- On-the-job training—This may serve to provide an understanding of company policies, standards, procedures, available tools and applications, acceptable code of conduct, etc.
- Formal training—Team members may require formal training to attain an adequate level of competence necessary to support the overall incident management capability.

Recommendations

- **Embed training** as part of your enterprise-wide awareness and resilience program.
 - Use **performance metrics** (e.g., mean time to detect/respond) to evaluate training effectiveness.
 - Align staff preparedness with **governance objectives**, such as:
 - Risk appetite
 - RTO/RPO targets
 - Regulatory requirements (e.g., GDPR, HIPAA)
-

Incident Notification Process is a vital piece of the broader Incident Response Plan (IRP) and aligns directly with **Domain 4: Incident Management**.

Purpose of Incident Notification

Incident notification is not just a communication task—it's a **strategic control function** that enables the organization to:

- **Respond quickly and accurately** to security events.
- **Contain damage** and **mitigate impact** before the incident escalates.
- Ensure **compliance** with legal, regulatory, and contractual obligations (e.g., GDPR breach notifications, regulatory timelines).
- **Coordinate** internal and external stakeholders effectively.

Key Characteristics of an Effective Incident Notification Process

Timely

- Notifications must occur **as soon as thresholds or triggers are met** (e.g., indicators of compromise, abnormal behavior).
- **Speed** is essential to engage containment and recovery actions early.

Relevant

- Only the **right people with the right level of information** should be notified.
- Avoid noise or irrelevant alerts that may dilute urgency.

Targeted Mechanisms

- Use tools such as SIEMs, automated ticketing, incident dashboards, and pre-defined escalation paths.

Stakeholders Involved

Functional Area	Role in Notification/Response
Cybersecurity / Threat Intel / Privacy / Physical IS	Analyze and classify incident severity and technical scope
IT / Network / Application Dev	Provide technical triage and support containment/remediation
Business Process Owners / HR / Legal / Risk	Evaluate legal, HR, regulatory, and process impacts
Senior Management / Communications	Coordinate messaging, reporting, and public response

This highlights the **multi-disciplinary nature** of incident management..

An effective and timely security incident notification process is a critical component of any security program that:

- Enables the enterprise to respond quickly and efficiently through obtaining timely and relevant information
- And will ultimately limit the potential loss and damage that may occur as the result of an incident.
- Notification mechanisms from an automated detection system or monitoring to send email or phone messages regarding incident notifications

The following functions are most likely to need information concerning incidents when they occur:

- Application development
- Business process owners
- Cybersecurity
- HR (when an incident appears to involve insiders)
- IT department

- Legal/general counsel
- Network operations
- Physical and information security
- Privacy department (when an incident appears to impact privacy)
- PR/corporate communications
- Risk management
- Senior management
- Threat intelligence team

Best Practices

- Define **incident thresholds** and **classification levels** that trigger specific notifications.
- Ensure **incident communication plans** are tested during tabletop and live exercises.
- Maintain **pre-approved contact lists** and escalation protocols for business-critical functions.
- Enable **role-based visibility** in incident tracking tools.

Tip:

Train your incident responders to ask:

“Who needs to know, when, and in how much detail?”

This mindset ensures alignment with **business risk impact** and prevents overexposure of sensitive information.

Support and Consensus outlines three essential pillars for gaining organizational backing in implementing or improving incident management programs.

Support and Consensus:

Key Components for Effective Incident Management

To gain sustained support for an incident management strategy, the following dimensions must be addressed:

Impacts

- **"Unacceptable impacts of prior incidents"**
 - Demonstrating the **consequences of insufficient security responses** in the past (e.g., data breaches, operational downtime, reputational damage) helps underscore the necessity for structured incident management.
 - Stakeholders respond better when they **see tangible risks and consequences**.

Business Case

- **"Developing a persuasive business case"**
 - A robust business case articulates the **return on investment (ROI)**, cost-avoidance benefits, and **regulatory alignment** of incident management.
 - Aligns proposed initiatives with **business goals**, showing that incident response isn't just an IT function but a **business enabler**.

Developing a persuasive business case detailing examples of similar events in other enterprises that show the consequences of inadequate incident management

Baselines

- **"Reducing overall security costs using security baselines"**
 - Using **baselines** helps organizations understand their current capabilities and identify **gaps**.
 - When well-defined, these benchmarks can be used to **rationalize investments**, optimize controls, and reduce redundancy—leading to **cost-effective risk**

management.

Reducing overall security costs by setting baselines to address common events and providing protection with an adequate response, containment and recovery capability.

As with other aspects of security, it is critical to achieve stakeholder consensus and senior management support for an effective incident management capability.

Takeaway

For a professional, **building consensus among stakeholders** means:

- Speaking in the language of **business impact**.
 - Framing security not as a cost center, but as **value protection**.
 - Using **metrics, historical data**, and **cost-benefit analysis** to support the narrative.
-

Incident Classification and Categorization

Not all incidents are equal. The enterprise realistically cannot leverage limited resources simultaneously. Classifying and categorizing incidents can help manage those limited resources effectively.

Classification and Categorization Overview introduces a structured approach to managing incidents effectively, aligned with best practices in **incident prioritization and response planning**

Classification and Categorization Overview

Effective incident management begins with clear classification and categorization. These activities **enable prioritization, reduce response time, and improve resource allocation**. The framework here emphasizes four key elements:

Prioritize

- **Purpose:** Enables quick identification and classification of incidents.
- **Perspective:** Prioritization ensures that **resources are allocated to the most critical threats first**, minimizing business impact.
- **Key Practice:** Leverage impact/urgency matrices to determine severity levels.

Respond

- **Purpose:** Ensures triage efforts address the **most impactful incidents with limited resources**.
- **Perspective:** Incident response must be **resource-aware** and aligned with enterprise risk appetite.
- **Key Practice:** Apply incident triage protocols to minimize delay in response efforts.

Define

- **Purpose:** Clarifies response actions before incidents occur.
- **Perspective:** Predefining response paths supports **consistency, compliance, and audit readiness**.

- **Key Practice:** Document standard operating procedures (SOPs) and integrate with the IRP (Incident Response Plan).

Tailor

- **Purpose:** Aligns response strategies to the enterprise's unique environment and commitments.
- **Perspective:** One-size-fits-all doesn't work—**customization enhances effectiveness and stakeholder confidence.**
- **Key Practice:** Adapt categorization frameworks to reflect specific business processes, regulatory expectations, and SLA agreements.

Prioritize	Respond	Define	Tailor
The ability to identify, classify and categorize responding to an incident is a crucial part of prioritizing efforts.	Effective and proper triage enables the enterprise to respond to incidents of greatest impact using the limited resources available.	Define how the enterprise responds in advance of an incident occurring.	The approach used needs to be tailored to the environment and commitments established by the enterprise.

Insight

This model reflects a **mature incident management discipline** where classification supports:

- Faster decision-making
- Improved communication with stakeholders
- Regulatory compliance (e.g., GDPR, HIPAA, PCI DSS)

It also ensures the **Incident Response Team (IRT)** doesn't waste time on low-impact events during a crisis.

Defining Levels and Escalation Procedures

In a mature **Information Security Incident Management System**, determining escalation levels is **critical for efficient and timely resolution**. This model aligns with ITIL and ISACA best practices for **incident prioritization and SLA-driven response**.

Key Escalation Criteria

1. Severity of the Event

- How critical the impact is to business operations (e.g., data breach, DDoS, ransomware).

2. Number of Organizations Affected

- Whether it impacts a single unit or enterprise-wide systems/services.

3. Notification Requirements - specific need to be notified

- Regulatory bodies, executive management, customers, or third-party vendors.

Level of events and the escalation procedures can be defined by the:

- Severity of the event
- Number of organizations affected
- Specific need to be notified

					Priority	Resolution
					1	2 hours
Urgency	High	3	2	1	2	8 hours
	Medium	4	3	2	3	24 hours
	Low	5	4	3	4	36 hours
	Enterprise Impact				5	160 hours
		Low	Medium	High		

Priority Matrix (Urgency vs. Enterprise Impact)

Urgency \ Impact	Low	Medium	High
High	3	2	1
Medium	4	3	2
Low	5	4	3

Interpretation:

- **Priority 1 (P1):** High urgency + high impact – requires immediate action.
- **Priority 5 (P5):** Low urgency + low impact – minimal disruption; can be scheduled.

Response Time by Priority Level

Priority	Resolution Time
1	2 hours
2	8 hours
3	24 hours
4	36 hours
5	160 hours

- This **SLA-based approach** ensures that higher-priority incidents are resolved with the highest urgency.
- Supports **auditable compliance and business continuity alignment**.

Level of events and the escalation procedures can be defined by:

- the severity of the event
- the number of organizations that may be affected by the event
- and their specific need to be notified.

Guidance

- Ensure these matrices are reviewed **periodically and adapted** based on real-world incident trends.

- Train incident responders and service desk teams to **classify incidents quickly and accurately** using this model.
 - Integrate this matrix with your **incident response playbooks, ticketing tools, and communication protocols**
-

Escalation Process presents a structured and methodical approach to incident escalation—an essential part of any incident response strategy.

Escalation Process

A **well-defined escalation process** ensures that incidents are handled **promptly, effectively, and with the right authority**. This is especially critical for **minimizing impact**, enabling **timely decision-making**, and ensuring **stakeholder accountability**.

To establish the events to be managed, the information security manager should work with management to define and implement an escalation process (i.e., in the event of a telecommunications shutdown).

Key Phases in the Escalation Workflow

1. Prioritize Event Information

- Categorize the incident based on severity, impact, and urgency (aligned with the previously discussed priority matrix).
- Enables early triage and SLA-bound response.

2. Determine When to Alert Groups and Stakeholders

- Identify which **internal and external stakeholders** (e.g., IT, legal, HR, vendors) must be notified and **at what incident level**.
- Escalate early to **avoid delayed containment**.

3. Develop Escalation Processes and Decision Authority

- Define **who has the authority** to make decisions at each stage of escalation.
- Empower **Incident Response Team (IRT)** and **senior leadership** for rapid action.

4. Document Detailed Descriptions of the Escalation Process

- Create **clear SOPs and flow diagrams** covering:
 - Escalation triggers
 - Notification protocols
 - Time-bound hand-offs
 - Backup approvers

5. Authorization of Recovery Actions or Disaster Declaration

- Determine thresholds where incident escalation transitions to **disaster declaration** or invokes **BCP/DRP plans**.
- Must include executive approval logic.

Work with management to define and implement an escalation process:



Provide:

- Actions to perform in the escalation process
- Responsible person and alternates

Note:

- If actions cannot be completed or time limit runs out, continue to the next action
- Missing time requirements may change status to an alert condition

What Should Be Provided

- **Actions to perform:** Specific steps and responsibilities at each escalation level.
- **Responsible persons and alternates:** Named roles to prevent bottlenecks due to unavailability.

Important Notes

- **Action deadline breach:**
 - If a step is not executed within the defined SLA/time frame, the process should automatically **move to the next escalation level**.
- **Status Elevation:**
 - Missing steps or timing may **change the status to “Alert Condition”**, requiring broader attention.

For every credible and actionable event provide a list of:

- Actions described in the sequence to be performed.
- Responsible person and alternates in case of unavailability and an estimated time for execution.
- If any action cannot be executed or if the estimated time is reached, the process should continue in the next action.
- If the accumulated elapsed time reaches a predetermined limit, the emergency status may change to an alert condition (i.e., low, medium, high).

To establish the events to be managed, the information security manager should work with management to define and implement an escalation process (i.e., in the event of a telecommunications shutdown). This includes:

- Prioritizing event information
- Determining when to alert various groups and key stakeholders (senior management, the public, shareholders and stakeholders, legal counsel, HR staff, vendors and customers).
- Developing escalation processes and decision authority through consultation with key stakeholders (PR, legal counsel and appropriate senior management, vendors and utility services).

- Documenting detailed descriptions of the escalation process
- And who must authorize various recovery actions or disaster declaration

For every credible and actionable event provide a list of:

- Actions described in the sequence to be performed.
- Responsible person and alternates in case of unavailability and an estimated time for execution.

Note:

- If any action cannot be executed or if the estimated time is reached, the process should continue in the next action.
- If the accumulated elapsed time reaches a predetermined limit, the emergency status may change to an alert condition (i.e., low, medium, high).

Insight

- Link the escalation process to the **organization's risk appetite and impact criteria**.
 - Validate this process through **incident simulation exercises**.
 - Regularly **review and revise** escalation plans as part of **continuous improvement**.
-

Incident Notification emphasizes a foundational component of effective incident response: **communication**.

Incident Notification

Timely and secure **incident notification mechanisms** are crucial to prevent escalation, support decision-making, and align response activities across stakeholders.

IS Manager Responsibilities

1. Establish Reliable Notification Channels

The IS manager must deploy and maintain multiple communication options that can

function **under duress**:

- **Email (encrypted)**
- **Cell phones/SMS alerts**
- **Fax and pagers** (legacy but sometimes reliable during network failures)
- **Dedicated emergency phone lines or hotlines**
- **Web-based portals or dashboards**

2. **Encrypt Communications**

Ensure that **confidential or sensitive alerts** (e.g., breach details, customer data exposure) are encrypted and follow enterprise data protection policies.

3. **Test Notification Systems**

Periodic testing (via drills or table-top exercises) should validate:

- Reachability of contacts
- Proper escalation order
- Message accuracy and clarity

Target Notification Audience

Incident notifications should be **predefined by type of event and severity**, and may include:

Group	Purpose
Backup facilities	Prepare alternate sites for failover
Customers	Notify of potential service disruption or data exposure
Business partners	Inform partners of shared system risks
Legal/PR/HR	Prepare compliance, reputation management, and employee safety actions
Internal Audit	Evaluate control effectiveness post-incident
Response/Recovery Teams	Mobilize containment and restoration
Senior Management & Regulators	Escalate critical events with legal/compliance implications

Tip: Maintain a **dynamic stakeholder map** and integrate it with an **automated incident response platform** (e.g., SOAR or IR orchestration tools) for seamless alerting.

The information security manager should have mechanisms to enable notifications that communicate crisis or event information. These mechanisms may include using email (if computing systems and networks are operational), cellular phones, fax machines, electronic pagers, web sites or an emergency telephone number at which a message can be placed.

- Develop methods to encrypt email and other communications used in relaying crisis or event-related information to ensure that information protected against compromise

and is released only as prudent or according to plans. Note that some types of communication, such as email messages, are by default in clear text, making them subject to potential interception.

- An alert situation prompts notification of individuals and enterprises who have authoritative decision-making responsibilities, as appropriate and defined by the incident.

Entities and personnel that may receive an alert notification include, but are not limited to, the following:

- Backup facilities
- Business partners
- Customer support staff
- Customers
- General counsel/legal
- HR
- Insurance companies
- Internal audit
- Investors/shareholders
- Network operations
- Privacy department
- PR
- Regulators
- Response and recovery teams
- Risk management
- Security operations
- Senior management
- Vendors/suppliers

Recommendations

- Create **notification tiers** based on incident classification.
- Maintain **contact rosters** with primary and backup roles.

- Ensure **auditable logs** are generated for each notification for compliance and review.
-

Help Desk Processes

Objective:

Ensure that help desk personnel act as the **first line of defense** by accurately identifying, escalating, and not mishandling potential security incidents.

Key Components

1. Clear Reporting and Escalation Procedures

- The IS manager must define and communicate **incident handling workflows**.
- Help desk staff should be able to distinguish:
 - Routine requests (e.g., password resets)
 - Potential incidents (e.g., multiple failed logins, suspicious user behavior)
- Provide **checklists or decision trees** to guide action.

2. Prompt Referral = Minimized Damage

- Fast and correct identification leads to timely incident containment.
- Use **SLAs** for initial triage and escalation timelines.

3. Criteria Definition & Awareness

- IS managers should define:
 - **Incident indicators** (e.g., malware symptoms, account lockouts)

- **Escalation points** (when to involve CERT, SOC, etc.)

- Include help desk in **awareness programs** to keep them informed of current threats.

4. **Combat Social Engineering Threats**

- Help desks are often targeted for **privilege escalation or credential theft**.
- Countermeasures:
 - **Caller verification protocols**
 - **Red team testing and social engineering drills**
 - **“Do not override” training** – encourage personnel to follow process over persuasion

The information security manager must define processes for help/service desk personnel to distinguish a typical request from a possible security incident as they are likely to receive the first reports indicating a security-related problem.

- Help/service desk personnel should know the correct procedures to report and escalate a potential issue.
- Prompt recognition of an incident in progress and quick referral to appropriate parties are critical to minimizing the damage resulting from such incidents.
- By defining appropriate criteria and improving the awareness of help/service desk personnel, the information security manager develops another important method to detect a security incident.
- Proper training also helps to reduce the risk that the help/service desk could be successfully targeted in a social engineering attack designed to obtain access to accounts, such as a perpetrator pretending to be a user who has been locked out and requires immediate access to the system.

Best Practices

- Integrate **incident classification criteria** into service desk systems (e.g., via ticketing software).
- Include help desk roles in the **incident response plan (IRP)**.

- Require **ongoing security awareness training** specifically tailored to service personnel.
- Maintain **audit trails** of all escalations or overridden processes.

Summary

Responsibility

Objective

Define process Distinguish security issues from routine support

Train help desk Recognize & escalate potential threats

Reduce risk Mitigate social engineering and insider threats

Completing Escalation Process

outlines the critical final actions in the incident escalation lifecycle.

Completing Escalation Process

Purpose:

Ensure **structured resolution** of incidents through well-defined post-escalation activities within the **Recovery Time Objective (RTO)** window.

The process should continue until the emergency is resolved or the last alert has occurred.

The emergency management team will

- Evaluate the damages and mitigation alternatives
- Decide whether to declare a disaster or launch the response and recovery plan and determine the appropriate strategy.

Also, the information security manager consults with PR, legal counsel and senior management to develop a communication plan ensuring appropriate information disclosure. The total elapsed time should ideally be within the established RTO.

Key Responsibilities of the Incident Management Team:

1. Damage Assessment and Mitigation

- Rapidly evaluate the **extent of the incident's impact** (e.g., systems down, data loss).
- Recommend **mitigation strategies** that are cost-effective and minimize further exposure.

2. Disaster Declaration or IRP Activation

- Based on severity, determine whether to **declare a disaster** and **activate the Business Continuity/Disaster Recovery Plan (BCP/DRP)**.
- Escalation must be consistent with **predefined thresholds and authority levels**.

3. Strategy Determination

- Decide **who takes over operations**, what gets restored first, and how communication is managed.
- Ensure legal and reputational risk is minimized through strategic choices.

4. Communication Planning

- Work with **PR, legal counsel, and senior management** to issue accurate, timely information internally and externally.
- Maintain **confidentiality, integrity, and availability** in all communications.

Tasks Performed After Escalation (within RTO):

Step	Description
1. Notify Personnel	Alert all relevant parties (IMT, BC/DR teams, stakeholders)
2. Activate Backup Facilities	Initiate use of hot/cold sites, cloud environments
3. Contain Security Threats	Engage SOC/CERT to neutralize threats to critical systems
4. Provide Transportation Arrangements	Move teams/resources if primary location is inaccessible
5. Retrieve and Unload Data	Restore from backups, load alternate systems
6. Test	Validate data integrity, system functionality, and access controls

Best Practices:

- **Document lessons learned** for continual improvement of the escalation matrix and decision models.
- Always verify that **post-incident tasks align with RTO/RPO requirements**.
- Include all escalation tasks in the **incident runbook** to support repeatability and audit readiness

Summary:

Element	Key Focus
Strategy	Response vs. disaster declaration
Tasks	Structured, prioritized, and tracked
Governance	Involve legal, PR, executive roles
Metrics	Ensure completion within RTO

Incident Management Operations, Tools and Technologies

The information security manager needs to be fully aware and understand the environment in which enterprises operate. The increased use, dependency and pervasive nature of technology when combined with omnipresent connectivity and global accessibility not only introduce, but greatly increase both the probability and impact of an information security incident occurring.

Incident Management Operations Overview

Objective:

To effectively **reduce enterprise risk and operational impact** by ensuring a structured, responsive, and well-integrated incident management function.

Operational incident management capabilities save the enterprise from larger unplanned losses as incidents that are identified sooner are responded to and resolved faster, ultimately reducing the impact to the enterprise

Operational Pillars:

1. Define Incident Management Processes

- Establish clear policies and documented procedures for detecting, reporting, analyzing, escalating, and resolving incidents.
- Align with enterprise objectives and regulatory requirements.
- Ensure integration with **business continuity (BCP/DRP)** and **risk management frameworks**.

2. Properly Train Personnel

- Equip staff with the skills to recognize, respond to, and escalate incidents.
- Provide role-based training to both technical teams and front-line personnel (e.g., help desk, system admins).
- Conduct periodic drills, tabletop exercises, and simulations.

3. Monitor for and Alert on High-Priority Incidents

- Implement **SIEMs, IDS/IPS, threat intelligence platforms** for proactive detection.
- Define and configure **alert thresholds, escalation paths, and stakeholder notifications**.
- Ensure **24/7 coverage** for critical assets.

4. Enable Rapid Identification, Containment, and Recovery

- Empower teams with authority and tools to act immediately upon confirmation of an incident.
- Prioritize containment to **minimize lateral movement and impact**.
- Integrate IR with DR plans to support timely service restoration.

Ensure teams can quickly identify, contain, resolve and recover from incidents

5. Deliver Fast Response to Minimize Impact

- Measure and improve **MTTD (Mean Time to Detect)** and **MTTR (Mean Time to Respond/Recover)**.
- Regularly review lessons learned and optimize response playbooks.
- Align all actions with **Recovery Time Objectives (RTOs)** to ensure business continuity.

Provide fast response times to reduce overall enterprise impact from incidents.

•Return systems and services back to normal operations to achieve business goals.

Some enterprises may have a designated IMT that determines how to manage incidents and is separate from the IRT. In other enterprises, the IMT and IRT may be the same group of people. IMT will be differentiated, when necessary, but in many cases, the IRT will perform these duties.

Summary:

To **operationalize incident management effectively**, enterprises must go beyond tools and documentation. They must foster a culture of preparedness, empower response teams with clarity and authority, and continuously improve response based on real incidents.

Tools and Technologies

This presents two core categories of technologies essential for a robust **Incident Response Program**:

1. **Incident Management Systems (IMS)**
2. **Endpoint Detection and Response (EDR)**

Incident Management Systems (IMS)

IMS platforms serve as the **central nervous system** for orchestrating the incident response process. They ensure structured and auditable incident handling.

Key Functions:

- **Distributed Detection:** Integrates multiple detection tools (e.g., SIEM, IDS, log monitoring) to centralize alert management.
- **Lifecycle Tracking:** From detection to resolution, IMS ensures incidents are monitored and updated continuously.
- **Criticality-Based Prioritization:** Ensures that higher-risk events are escalated and resolved quickly.
- **Status Visibility:** Provides dashboards and communication workflows for stakeholders across IT, security, and compliance.

Link: Supports the governance principle of accountability, documentation, and communication across the incident lifecycle.

Endpoint Detection and Response (EDR)

EDR is a **proactive defense and response toolset** installed on endpoints to identify and mitigate advanced threats.

Key Functions:

- **Threat and Malware Focus:** Detects fileless attacks and advanced persistent threats (APTs) that bypass traditional antivirus.
- **Cyber Threat Intelligence + ML:** Enhances detection by correlating behavioral data and threat feeds.
- **Audit Trails:** Maintains historical logs of endpoint behavior—crucial for post-incident forensics.
- **Root Cause Analysis Support:** Helps incident handlers reconstruct the attack chain to prevent recurrence.

More Insights

The infrastructure needed to enable incident management capabilities is significant—from commercially available suites of tools to home-grown applications and everything in between. As such, the IMT will leverage an assortment of technologies.

Incident Management Systems (IMS):

- An example of a distributed incident management system is one that contains multiple specific incident detection capabilities (e.g., network intrusion detection systems [NIDSs], host-based intrusion detection systems [HIDSs] and server/appliance logs). The system is most often offered in a web-based format for easy accessibility.
- Another significant feature of incident management systems is their ability to track an incident during its life cycle
- Ensure that incidents are not overlooked but instead receive necessary attention based on criticality.
- Tracking enables users to provide more information and receive status updates along the event life cycle until it is closed.

Endpoint Detection and Response (EDR): Another solution that has gained popularity has been that of endpoint security, specifically endpoint detection and response (EDR), extended detection and response (XDR) and managed detection and response (MDR). A 2020 study conducted by Ernst & Young stated, “[a]lmost 70 percent of all breaches still originate at endpoints.”

- EDR attempts to be predictive in nature, focusing on identifying threats and malware that are designed to evade traditional security defenses.
- Most EDR solutions will leverage some type of cyber-threat intelligence with machine learning capabilities in conjunction with file analysis and threat detection.
- EDR solutions normally create a historical audit trail in which system/user behavior and security events are captured for follow-on analysis by security analysts.
- EDR solutions not only can aid in incident response efforts but also support root cause analysis.

Integration Recommendation:

A mature security program integrates **IMS and EDR**:

- IMS tracks the “**who, what, and when**” of incidents.
- EDR identifies the “**how and why**” by capturing endpoint behavior and anomalies.

Takeaway:

To build a successful incident response capability:

- Select technologies that **support automation, coordination, and continuous improvement**.
 - Align tools with incident handling policies, playbooks, and escalation procedures.
 - Ensure tools contribute to overall **governance, risk, and compliance** efforts.
-

Tools and Technologies (Continued) focusing on **Extended Detection and Response (XDR)** and **Managed Detection and Response (MDR)**.

Extended Detection and Response (XDR)

- Holistic approach to endpoint detection and response beyond individual endpoint
- Unified view of endpoints
- Analysis of servers, clouds and networks
- Builds on capabilities of EDR to provide context around security events

Managed Detection and Response (MDR):

- Hybrid combination of technology and service provider
- Valuable for environments lacking appropriate expertise, skills or resources to monitor potential attack vectors
- Service provider is responsible for providing instrumentation

Tools and Technologies

This expands on modern detection and response technologies that provide **greater visibility, scalability, and resource optimization** within an enterprise's **incident response strategy**.

Another solution that has gained popularity has been that of endpoint security, specifically endpoint detection and response (EDR), extended detection and

response (XDR) and managed detection and response (MDR). A 2020 study conducted by Ernst & Young stated, “[a]lmost 70 percent of all breaches still originate at endpoints.”

Extended Detection and Response (XDR):

- An evolved version of EDR that takes a holistic approach to endpoint detection and response. As the name implies, detection and response efforts extend beyond the individual endpoint.
- XDR provides enterprise information security teams a unified view across their endpoints
- Allows analysis of servers, cloud and networks.
- XDR builds on the capabilities of EDR, leveraging automation, machine learning and artificial intelligence capabilities to provide context around security events.

Managed Detection and Response (MDR):

- a hybrid combination of technology and service provider.
- The value is for those environments that lack both appropriate expertise and skills or have limited resources needed to adequately monitor potential attack vectors.
- Normally the service provider will be responsible for providing instrumentation.

Extended Detection and Response (XDR)

XDR evolves traditional **EDR** (Endpoint Detection and Response) by extending visibility and response capabilities across multiple security layers:

Core Capabilities:

- **Holistic Detection:** Goes beyond endpoint monitoring; includes network, cloud, and server activity.
- **Unified Visibility:** Correlates telemetry from multiple sources for contextual threat detection.
- **Automated Response:** Enables centralized orchestration of alerts and remediation.

Relevance: Supports proactive risk identification, threat hunting, and integrated incident analysis across enterprise assets (Domain 4: Incident Management).

Managed Detection and Response (MDR)

MDR is a **third-party managed security service** that provides 24/7 threat detection and response capabilities.

Key Characteristics:

- **Hybrid Service:** Combines technology tools with external expertise (e.g., SIEM, SOC analysts).
- **Ideal for Resource-Constrained Enterprises:** Especially where in-house security teams or tools are lacking.
- **Provider-Managed Instrumentation:** The service provider handles setup, monitoring, and response.

Relevance: Enables risk-based outsourcing of detection capabilities while ensuring operational continuity and SLA adherence

Key Insight:

When selecting between **XDR** and **MDR**:

- XDR is **technology-driven** and ideal for **in-house security maturity**.
 - MDR is **service-driven**, best for **SMEs or organizations with limited cybersecurity teams**.
-

Security Information and Event Management System (SIEM)

A **SIEM system** is a critical centralized solution that supports **real-time monitoring, analysis, and alerting** for enterprise-wide security events.

Key SIEM Capabilities:

1. **Centralized Event Aggregation**
 - **Combines** security events, logs, and alerts into a **single database**.

- Supports normalization and consistent analysis across multiple systems.
- 2. **Real-Time Correlation and Alerting**
 - Uses **rules and machine learning** to detect anomalies and generate alerts instantly.
 - Facilitates early **incident identification**.
- 3. **Policy Violation Detection**
 - Flags deviations from security policies for further investigation and enforcement.

More Insights

Security Information and Event Management system (SIEM):

- Is an example of a centralized incident management system that combines critical events and logs from many different systems and devices and correlates them into more meaningful incident information.
- This is accomplished by collecting data from many system and device logs that are normalized in a single database
- Where it is data-mined using correlation and inference tools to create near-real-time notifications and alerts;
- This tool can also identify policy violations. Further processing can be done from there (e.g., prioritizing incidents based on their potential severity or business impacts or performing specific notifications/escalations based on the impact ratings).

An effective SIEM will:

- •Consolidate and correlate inputs from multiple sources
- •Identify incidents or potential incidents
- •Notify staff
- •Prioritize incidents based on business impact
- •Track incidents until they are closed
- •Provide status tracking and notifications
- •Integrate with major IT management systems
- •Implement good practices (e.g., configuration, workflows, etc.)

Features of Effective SIEMs:

Capability	Purpose	
Consolidate and correlate inputs	Enables a unified security view across devices and networks.	
Identify incidents	Quickly detects malicious or abnormal activity.	
Notify staff	Triggers alerts and communicates risk to responders.	
Prioritize incidents	Aligns with business impact for risk-based response.	
Track until closure	Maintains accountability and closure discipline.	
Status tracking & notifications	Enhances visibility and auditability.	
Integrate with other systems	Improves automated response and remediation.	
Implement good practices	Enforces consistency and operational maturity.	

Benefits of Use,

There are potential efficiencies and cost savings that can be realized using automated incident management systems once they are properly configured.

Operating Costs

IS staff may be required to monitor different security devices without an automated or centralized system.

- Requires a manual approach to correlate events and process information
- Incurs possible additional training costs
- Increases probability of human error

Recovery Costs

A properly configured automated system can detect and escalate incidents significantly faster than manual processes

- Can further control and prevent damage due to faster recovery process initiation
- Reduces time to analyze and contain damage from incidents

Operating costs

IS staff may be required to monitor different security devices without an automated or centralized system.

- This requires a manual approach to correlate events and process information.
- Can also require additional training costs
- Increases probability of human error

Recovery costs

- A properly configured automated system can detect and escalate incidents significantly faster than manual processes
- This can further control and prevent damage due to faster recovery process initiation
- Reduces time to analyze and contain damage from incidents

Benefits of Use

This outlines the **cost-related impact** of adopting **automated or centralized incident detection and response systems**, such as SIEMs, EDRs, or other threat management platforms.

Operating Costs (Manual Process Burdens):

Challenge	Risk or Drawback
Manual Event Correlation	Time-consuming and inefficient.
Training Requirements	Increases operational cost due to specialized knowledge needs.
Human Error	Greater chance of oversight, misinterpretation, or slow response.

Implication:

Without automation, enterprises face inefficiencies that **increase operational risk** and **delay incident handling**.

Recovery Costs (Benefits of Automation):

Benefit	Description
Faster Escalation & Detection	Automates threat detection, reducing Mean Time to Detect (MTTD).
Accelerated Recovery	Faster containment reduces potential data loss or service interruption.
Reduced Analysis Time	Enhances forensic accuracy and response coordination.

Implication:

Investing in automation not only enhances **incident response maturity**, but also **lowers total cost of recovery (TCR)** through better detection-to-recovery efficiency.

Key Takeaways:

- Automation supports **effective response** and **cost containment**.

- Manual processes are more error-prone and expensive in the long run
 - Prioritizing cost-efficient, automated incident management tools supports **resilience and risk mitigation goals**.
-

Incident Response Team Technology Concepts

An effective Incident Response (IR) team must possess a **well-rounded understanding** of various technical domains to:

- Identify vulnerabilities,
- Analyze attack vectors,
- Contain and eradicate threats, and
- Support restoration and lessons learned.

Key Technical Competencies:

Concept	Importance for IR Team
Security Principles	• Understand confidentiality, integrity, and availability (CIA), defense-in-depth, and least privilege. Knowledge of security principles is important to understand potential problems that can arise if appropriate security measures have not been implemented correctly or if they fail, and to appreciate the potential impacts to the enterprise systems.
Internet Security Protocols	Enable secure communications (e.g., HTTPS, TLS, IPsec); IR teams must analyze anomalies here. There must be security in the underlying protocols and services used on

	the Internet. A good understanding is important to anticipate the threats that might occur in the future.
Security Vulnerabilities/Weaknesses	• Core for identifying attack surfaces and root causes. Enables timely patching and mitigation. This entails understanding how any specific attack is manifested against people, processes, software or hardware technology. • Internet security protocols: There must be security in the underlying protocols and services used on the Internet. A good understanding is important to anticipate the threats that might occur in the future.
Malicious Code	Ability to detect, analyze, and respond to malware, ransomware, and scripts. These can have different types of payloads that can result in different outcomes. The code can contain more dynamic payloads that can be configured to result in multifaceted
Operating Systems	Proficiency with Windows, Linux, macOS, etc., for log analysis, system behavior, and command-line triage. Knowledge of operating systems such as UNIX, Windows, Mac, iOS, Linux, Android and any other operating systems used by the team or constituency is important
Programming	Useful for writing scripts, analyzing code-based exploits, or understanding attack payloads. This includes the range of programming languages used by the enterprise's system and applications, concepts and techniques for secure programming, and how vulnerabilities can be introduced into code

Insights:

- **Role-Specific Training:** Domain 4 emphasizes the importance of training IR personnel based on their technical roles and responsibilities.
- **Integration with Monitoring:** These concepts support continuous monitoring, forensic analysis, and SIEM operations.

- **Risk Mitigation:** Without these competencies, IR teams may **miss early indicators of compromise (IoCs)**, prolonging Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR).

Takeaway:

An effective IR program must ensure that team members are trained in **technical concepts** that directly support the **identification, containment, and eradication of threats**, as well as **recovery operations** and **post-incident analysis**.

Team Composition

This emphasizes that the **Incident Management Team (IMT)** must be **adaptable**, strategically staffed, and aligned with organizational structure and risk exposure.

IMT Typical Roles:

Role	Responsibility
Team Leader	Oversees coordination and execution of response efforts. Often serves as the liaison with senior leadership.
Supporting Team Members	Operational personnel who conduct detection, analysis, containment, and remediation.
Virtual/Temporary Members	Brought in for expertise (e.g., forensics, legal, cloud security) when needed.
Steering Committee	Provides governance, strategic oversight, and resource alignment. Can include legal, compliance, and senior executives.

More Insights

An IMT typically includes:

- •A team leader, who may be dedicated to that role or a designated IS manager
- •Supporting team members (identified ad-hoc or dedicated) to perform primary tasks in the plan
- •Virtual/temporary team members with specialized skills recruited when necessary to fill internal gaps
- •Steering committee responsible for approving charter, acting as an escalation point or approving deviations or exceptions

Factors Influencing IMT Composition:

Factor	Relevance to Incident Management
Degree of Centralization	Centralized organizations may have a single core team; decentralized may require local response teams.
Size of the Enterprise	Larger enterprises require more formalized roles and broader capabilities.
Program Mission and Goals	Teams must align with business objectives such as compliance, uptime, or customer assurance.
Nature and Range of Services	Critical systems (e.g., healthcare, finance) require skilled and responsive team members.
Available Staff Expertise	Determines whether internal staff can manage response or if outsourcing/consultants are needed.
Constituency Size/Technology Base	More users, systems, or technologies = greater need for diverse skill sets.
Anticipated Incident Load	Higher volume requires scalable and possibly automated support.
Severity/Complexity of Reports	High complexity demands deeper investigative, legal, and communications capability.
Funding	Limits or expands the ability to build, train, and retain a capable team.

Best Practices:

- **Right-Sizing the Team:** Match team size and expertise to the organization’s risk posture and critical assets.
- **Cross-Functional Capability:** Include legal, PR, HR, and third parties where relevant.
- **Governance Integration:** Ensure the steering committee aligns incident response with enterprise risk management (ERM).

Key Takeaway:

Effective incident management requires **strategically composed teams**—not one-size-fits-all. Ensure that **composition is aligned with enterprise strategy, risk, and operational complexity**, and regularly reviewed as the threat landscape evolves.

Incident Response Team Organization

This outlines the **functional roles** of incident handlers and describes **team structural models** enterprises can adopt to build a responsive and resilient incident handling capability.

Core Activities of Incident Handlers:

Step	Description
Analyze incident data	Review logs, alerts, and system behavior to determine the nature of the event (initial triage).
Determine impact of incident	Assess affected systems, data, operations, and potential business disruption.
Recommend actions to limit damage	Propose containment strategies such as segmentation, access control changes, or service isolation.
Restore normal services	Focus on returning to business-as-usual operations through recovery plans, patching, or restoration.

Collaborate across the enterprise	Coordinate with IT, legal, HR, comms, and executives to ensure an aligned and efficient response.
--	---

Tip: Incident handlers need both technical skills and cross-functional communication capabilities.

Incident Response Team Models:

Model	Description & CISM Relevance
Central	A single, centralized team. Best for smaller or highly integrated organizations.
Distributed	Teams in different locations or departments. Ideal for large, global enterprises.
Coordinating	One team provides oversight/guidance; others execute. Supports scalability and alignment.
Outsourced	External MSSP or third-party team handles response. Useful for resource-limited enterprises.
Permanent	A dedicated team continuously monitoring and responding to incidents. Common in mature programs.
Temporary	Formed ad hoc during an incident. Common in organizations with low incident frequency or budget limits.

More Insights

IRT models that have proven to work in many enterprises include:

- **Central IRT**—A single IRT handles all incidents for the organization, typically used in a small enterprise or one that is centrally located.
- **Distributed IRT**—Each of several teams is responsible for a logical or physical segment of the infrastructure, usually of a large organization or one that is geographically dispersed.
- **Coordinating IRT**—The central team may provide guidance to distributed IRTs, develop policies and standards, provide training, conduct exercises and coordinate or support response to specific incidents. Distributed teams manage and implement incident response.

- Outsourced IRT—Successful IRTs may be comprised entirely of employees of the enterprise or may be fully or partially outsourced.
- Permanent team members may include: incident handlers, investigators and forensics experts, and IT and physical security specialists.
- Temporary team members normally consist of business representatives (e.g., middle management), legal staff, communications staff (e.g., PR), HR staff, other security groups (e.g., physical security), risk management and IT specialists.

Strategic Considerations:

- **Team model should reflect organizational complexity, risk appetite, and regulatory obligations.**
- **Incident roles and responsibilities** must be clearly defined regardless of structure (RACI models help).
- **Integration with threat intelligence**, risk management, and business continuity enhances effectiveness.

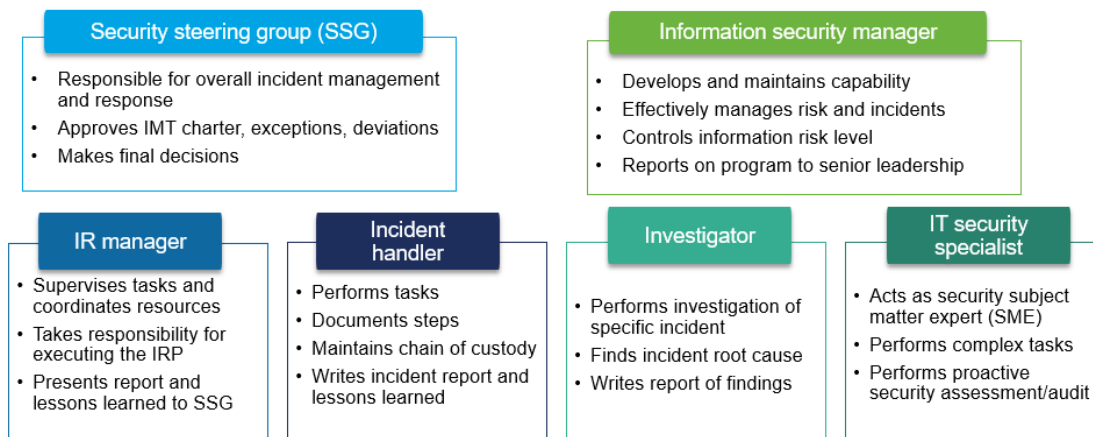
Key Takeaway:

As an information security manager, your role is to **select, support, and align** the team model and response roles with enterprise risk tolerance, size, and operational maturity. You must also ensure that these models are **tested, trained, and evaluated** regularly.

IMT/IRT Roles and Responsibilities

Well-defined roles and responsibilities are critical to the success of any **Incident Management Team (IMT)** or **Incident Response Team (IRT)**. This provides a clear breakdown of key roles within an incident response structure, aligning with **ISACA's CISM Domain 4: Incident Management**.

IMT/IRT Roles and Responsibilities



1. Security Steering Group (SSG)

Strategic Leadership Role

- The SSG provides **executive-level oversight** of the IMT/IRT and ensures that all response activities are aligned with business risk tolerance and strategic goals.
- It **approves the IMT charter**, sets exceptions or deviation protocols, and makes **final decisions** regarding incident escalations and program direction.
- This group acts as the **final authority**, especially when incidents may impact enterprise-wide operations or reputational standing.
- Highest structure of an enterprise's functions related to information security
- Takes responsibility for overall incident management and response concept
- Approves incident management team (IMT) charter
- Approves exceptions/deviations
- Makes final decisions

2. Information Security Manager

Program Capability Owner

- The IS Manager is **responsible for the program's health**—ensuring that the capability exists to manage and contain incidents.

- This role controls **information risk levels**, oversees security operations, and communicates outcomes to senior leadership.
- It is also the ISM's duty to **sustain incident management maturity** through policy, training, testing, and continuous improvement.
- IMT leader and main interface to SSG
- Develops and maintains incident management and response capability
- Effectively manages risk and incidents
- Performs proactive and reactive measures to control information risk level
- Reports on program to senior leadership

3. IR Manager (Incident Response Manager)

Operational Coordinator

- Acts as the **bridge between strategy and execution**, ensuring that the IRP (Incident Response Plan) is executed smoothly.
- Coordinates people and resources, oversees response task execution, and ensures that lessons learned are documented and reported to the SSG.
- This role is crucial during a live incident, orchestrating the **tactical response** while maintaining communication with leadership.
- Incident response manager: Incident response team (IRT) leader
 - Supervises incident response tasks
 - Coordinates resources to effectively perform incident response tasks
 - Takes responsibility for successful execution of the incident response plan (IRP)
 - Presents incident response report and lessons learned to SSG members

4. Incident Handler

Frontline Executor

- Responsible for **executing hands-on tasks**, logging activities, and **maintaining chain of custody**—an essential legal and forensic requirement.
- Often the first responder, they document the process, escalate when needed, and ensure all activities are aligned with SOPs.
- Their post-incident role includes contributing to **after-action reports** and improvement cycles.
- Incident handler: IMT/IRT team member
- Performs incident response tasks to contain exposures from an incident
- Documents steps taken when executing the IRP
- Maintains chain of custody and observes incident handling procedures for court purposes
- Writes incident response report and lessons learned

5. Investigator

Forensic Analyst and Diagnostician

- Focuses on the **root cause analysis** of specific incidents.
- Conducts detailed investigations and produces formal **findings reports**, which are used to recommend control improvements and meet compliance obligations.
- Critical in bridging the gap between technical failures and business impacts.
Investigator: IMT/IRT team member
- Performs investigative tasks for a specific incident
- Finds root cause of an incident
- Writes report of investigation findings

6. IT Security Specialist

Subject Matter Expert (SME)

- Provides **deep technical expertise** on complex systems and security controls.
 - Executes vulnerability assessments, penetration tests, and proactive audits.
 - Supports the incident handlers and investigators with **advanced tools and analysis**.
 - They often help define new **security baselines** based on incident learnings.
IT security specialist: IMT/IRT team member
 - Acts as a subject matter expert in IT security
 - Performs complex and in-depth IT security-related tasks as part of the IRP
 - Performs IT security assessment/audit as proactive measure and part of vulnerability management (i.e., performing routine vulnerability scans and associated remediation)
-

Other Roles and Responsibilities

1. Business Managers

These stakeholders ensure **alignment between incident response and business priorities**. They:

- Communicate the **business impact** of an incident
- Authorize decisions related to **acceptable risk and recovery timeframes**
- Help **prioritize resources** and restoration activities

2. Risk Management Specialists

These professionals provide a **risk-based lens** to incident management. They:

- Assess **residual and cascading risks** of incidents
- Contribute to post-incident **risk treatment planning**
- Assist in updating the **risk register** and integrating lessons into the risk management framework

3. Physical Security / Facilities Manager

Incidents are not just digital—they can be **physical or hybrid in nature**. This role:

- Ensures **physical containment** and secure access control
- Supports **site-level logistics**, such as isolation or relocation of personnel
- Helps coordinate with **law enforcement** in the case of physical breaches

4. IT Specialists / Representatives

These personnel possess system-specific knowledge and:

- Assist in **system diagnostics, patching, and restoration**
- Provide **technical input** for recovery strategies
- Act as **liaisons to affected business units** for system-level communication

5. Legal Representative

Essential in ensuring **regulatory, contractual, and legal compliance**, they:

- Assess **liability and disclosure requirements**
- Advise on evidence handling and **chain of custody**
- Prepare or review **notification content** to regulators or affected stakeholders

6. Human Resources (HR)

HR involvement becomes necessary when:

- Incidents involve **internal actors** (e.g., insider threats or policy violations)
- Staff disciplinary actions or awareness training is needed post-incident

- **Policy updates** or behavioral monitoring is required

7. Public Relations (PR)

For incidents with potential **reputational damage**, PR plays a frontline role:

- Manages **external communications and press statements**
- Helps to **control public perception** and reduce panic or misinformation
- Coordinates with legal and compliance to ensure **accurate and authorized disclosures**

More Insights

- Business managers: Business function owners; information assets/system owners
 - Make decisions on matters related to information assets/systems when an incident happens, based on IMT/IRT recommendations
 - Provide clear understanding of business impact in BIA process or in IRP
- Risk management specialist: Subject matter expert in risk management
 - Works closely with business managers and senior management to determine and manage risk
 - Provides input (e.g., business impact analysis, risk management strategy) to incident management
- Physical security/facilities manager: Knowledgeable about physical plant and emergency capabilities
 - Responsible for physical plant and facilities
 - Ensures physical security during incidents
- IT specialists/representatives: Subject matter experts in IT services
 - Provide support to IMT/IRT when resolving an incident
 - Maintain information systems in a good condition per company policy and good practices
- Legal representative: Subject matter expert in legal
 - Ensures that incident response actions and procedures comply with legal and regulatory requirements.

- Acts as the liaison to law enforcement and outside agencies.
 - Human resources (HR): Subject matter expert in HR area
 - Provides assistance in incident management/response when there is a need to investigate an employee suspected of causing an incident
 - Integrates HR policy to support incident management/response (sanctions to employees found to violate acceptable use of policy or involved in an incident)
 - Public relations (PR) representative: Subject matter expert in PR area
 - Provides controlled communication to internal and external stakeholders to minimize any adverse impact to ongoing incident response activities and protect an enterprise's brand and reputation
 - Provides assistance to IMT/IRT in communication issues, thus relieving the team to work on critical issues on resolving an incident
-

Selecting IRT Members

Interpretation:

Selecting Incident Response Team (IRT) members is not merely a staffing task—it is a **risk management decision** that directly affects enterprise resilience. The qualities highlighted in this slide reflect the **core competencies needed for a high-functioning incident response capability**.

Key Selection Criteria Explained:

1. Respond to Incidents

- Members must **act decisively** and follow pre-defined response plans during high-pressure situations.
- This includes **detecting, containing, and eradicating** threats per the IRP (Incident Response Plan).

2. Perform Analysis Tasks

- IRT members should have **strong analytical skills** to assess logs, indicators of compromise (IOCs), and security alerts.

- This skill enables them to **determine root causes and attack vectors** quickly.

3. **Communicate Effectively**

- Clear communication is essential during incident triage, escalation, and post-incident reporting.
- It includes **internal team coordination**, **stakeholder reporting**, and **cross-functional communication** with legal, HR, and PR.

4. **Solve Problems**

- Members must think critically and act under uncertainty.
- The ability to **apply controls**, isolate systems, or pivot strategies quickly is critical.

5. **Adapt to Change**

- Threats evolve, and so must the team.
- Members need to be flexible, **open to process changes**, and capable of adopting new tools or technologies during a crisis.

6. **Effective in Daily Activities**

- Even outside of incidents, members must maintain a high level of **discipline, awareness, and engagement**.
- They should support continuous improvement through **lessons learned**, simulations, and readiness drills.

7. **Ability to Handle Stress**

- Incident response is high-stakes and time-critical.
- Emotional resilience ensures **consistent performance**, **avoids burnout**, and **supports team morale**.

More Insights

- IRT members should be chosen for their ability to respond to incidents, perform analysis tasks, and communicate effectively with the constituency and external contacts.
- They must also be competent problem solvers, easily adapt to change and be effective in their daily activities.
- The set of basic skills that IRT members need can be separated into two broad groups: personal and technical skills.

- All these traits depend foremost on an IRT member being able to handle the stress of uncertain situations

Takeaway:

As an information security manager, your **role in IRT member selection** is to balance **technical proficiency, behavioral competencies**, and **strategic alignment** with the organization's incident response goals. The best IRTs are not just skilled—they are **stable, communicative, and dependable under pressure**.

Personal and Technical Skills

The effectiveness of an Incident Response Team (IRT) is not determined solely by technical expertise — it is **equally dependent on strong personal attributes** that support teamwork, communication, decision-making, and resilience.

- These are the abilities that enable them to respond to incidents, perform analysis tasks, and communicate effectively with the constituency and external contacts.
- They must also be competent problem solvers, easily adapt to change and be effective in their daily activities.
- The set of basic skills that IRT members need can be separated into two broad groups: personal and technical skills.
- All these traits depend foremost on an IRT member being able to handle the stress of uncertain situation

Personal Skills

These “soft skills” are foundational for **effective collaboration, leadership, and stress resilience** during incident handling:

Skill	CISM Mentor Insight
Communication	Vital for timely, clear updates across internal and external teams during incidents.
Leadership	Required to make confident decisions under pressure and guide others during crisis events.
Presentation	Important when reporting incident findings and status updates to executive management.
Collaboration	Cross-functional teamwork is essential — security incidents involve multiple departments (legal, HR, PR, etc.).
Integrity	Upholding ethics and trust, especially when dealing with sensitive incidents or forensic data.
Stress Management	Prevents burnout and maintains effectiveness under prolonged or high-severity conditions.
Self-Awareness	Encourages adaptability, humility, and the willingness to improve.
Problem Solving	Necessary for resolving root causes and mitigating further damage.
Time Management	Ensures prioritization and adherence to recovery time objectives (RTOs).

Technical Skills

These competencies ensure that the IRT can detect, analyze, contain, and eradicate incidents using appropriate tools and methodologies:

Skill Area	CISM Mentor Insight
Operating Systems	Deep understanding of Linux, Windows, and other platforms to detect anomalies.
Networking	Required to identify lateral movement, command & control traffic, and packet analysis.
Security Tools & Protocols	Knowledge of SIEM, IDS/IPS, firewalls, and forensic tools is essential for containment and eradication.
Scripting & Automation	Enables custom detection rules, alert tuning, and faster incident resolution.
Threat Intelligence	Helps recognize known attack patterns, IOCs, and develop proactive defenses.
Forensics & Investigation	Critical for evidence gathering, chain of custody, and supporting legal/regulatory responses.

More insights

Technical Skills: Technical skills are the basic skills required by IRT members and are of two types:

- Technical foundation skills—These require a basic understanding of the underlying technologies used by the enterprise.
- Incident-handling skills—These require an understanding of the techniques, decision points and supporting tools (software or applications) required in daily activities.

Underlying technologies

- Incident handling techniques
- Decision points
- Supporting tools

Takeaway:

To build a **mature and responsive IR capability**, the IS manager must ensure the team has a **balanced blend of personal and technical skills**. ISACA's guidance emphasizes that **competency frameworks, ongoing training, and performance evaluation** must encompass both domains.

Skills Assessment

Purpose:

A **skills assessment** is a critical step for identifying **gaps in expertise** and aligning available capabilities with **incident response needs**.

A skills assessment is useful to determine whether the required expertise is available in the organization for the IRT.

In some cases, relevant training or education may provide the necessary skills.

- If an enterprise is unable to find internal experts or hire/train staff to provide the necessary incident response specialist skills, it may be able to develop relationships with experts in the field to provide the necessary skills.
- It may be able to develop relationships with experts in the field to provide the necessary skills if they cannot be developed in-house

- When a situation arises where in-house knowledge is insufficient, these technical specialists can be called on when needed to fill the gap in expertise.
- These technical specialists can be called on when needed to fill the gap in expertise

Key Points and Insights:

Point	Commentary
"Relevant training or education may provide the necessary skills"	The IS Manager must identify baseline and advanced competencies needed for detection, analysis, and response. Then align this with existing staff capabilities and pursue certifications (e.g., SANS, GIAC, CompTIA, etc.) or specialized training to fill the gaps.
"Develop relationships with experts in the field"	Establishing partnerships with external consultants, MSSPs, or incident response retainer services (e.g., forensic experts, malware analysts) allows the organization to extend capabilities on-demand .
"Call on technical specialists to fill the gap"	A good incident response capability involves predefined escalation paths and agreements (SLAs) with experts who can support containment and investigation phases. This ensures agility and depth during major or sophisticated incidents.

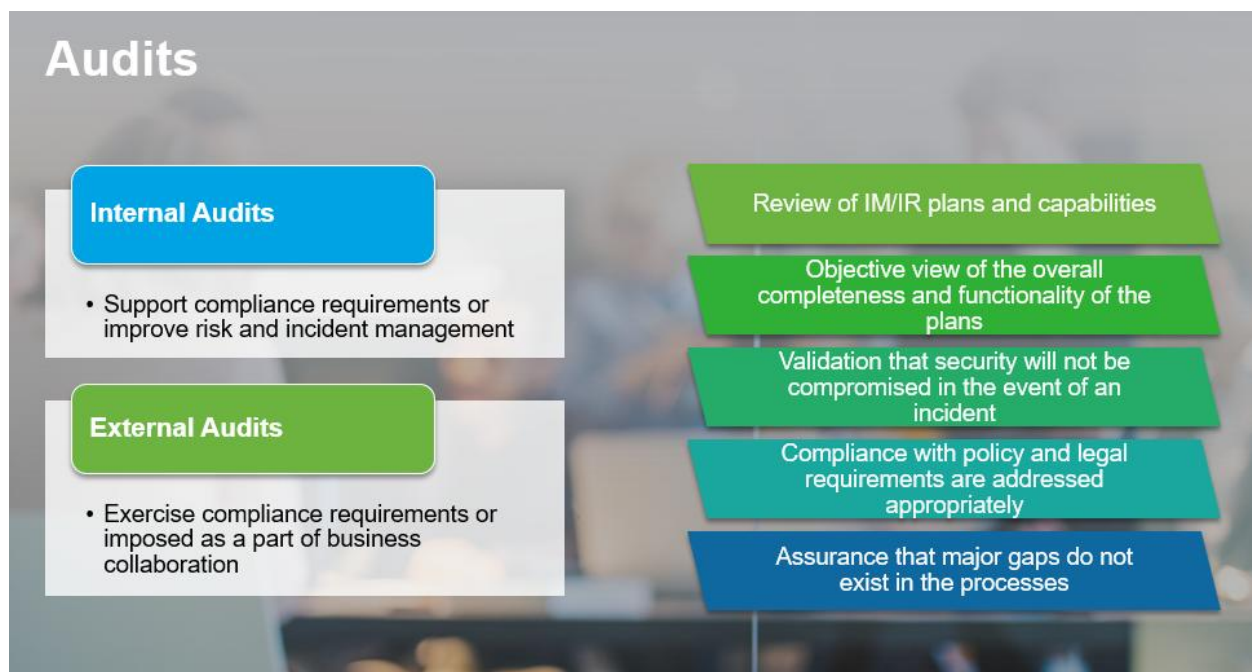
Best Practice:

- Conduct periodic **skills gap assessments** based on changing threat landscapes.
- Incorporate assessments into **tabletop exercises** and **post-incident reviews**.
- Maintain a **skills matrix** aligned with the NIST/NICE framework or internal competency models.

Strategic Outcome:

A thorough skills assessment ensures that **response quality is not compromised** due to unavailability or inadequacy of expertise — thus directly impacting **risk reduction, regulatory compliance, and response maturity**.

Audits



Internal and External

Audits are indispensable for maintaining **continuous assurance**, verifying the **resilience of Incident Management and Response (IM/IR) capabilities**, and ensuring **regulatory compliance**.

Internal and external audits are performed to verify compliance with policies, standards and procedures defined by an enterprise.

- Internal audits are conducted by specialists within the enterprise and are usually intended to support compliance requirements or improve risk and incident management.
- External audits involve a third party, who performs the tasks. While most external audits are exercised as part of mandatory requirements, they are also often imposed as part of business collaboration.

Both types of audits can provide:

- Review of incident management and response plans and capabilities.
- Objective view of the overall completeness and functionality of the IM and IR plans
- Validation that security will not be compromised in the event of an incident.
- Compliance with policy and legal requirements are addressed appropriately.
- Assurance that major gaps do not exist in the processes

Types of Audits:

Audit Type	Purpose & CISM Context
Internal Audits	Conducted by in-house resources to: - Support internal compliance and process improvement - Identify operational risks in IR plans early - Validate whether IM/IR aligns with internal risk appetite and objectives
External Audits	Performed by third parties (e.g., regulators, partners) to: - Meet contractual or regulatory compliance (e.g., PCI DSS, HIPAA) - Support due diligence in business partnerships - Offer independent validation of organizational readiness

Audit Outcomes/Focus Areas:

1. Review of IM/IR Plans and Capabilities

- Are plans documented, maintained, and aligned with enterprise risk management?

2. **Objective View of Completeness & Functionality**
 - Independent validation that plans are **realistic**, **tested**, and **scalable** under stress.
3. **Validation of Security During Incidents**
 - Ensures that **security controls remain intact** even when under duress or during recovery operations.
4. **Compliance with Policy and Legal Requirements**
 - Confirms alignment with **laws (e.g., GDPR, SOX)**, industry standards, and internal policies.
5. **Assurance of No Major Process Gaps**
 - Helps stakeholders trust that response mechanisms won't **fail during actual incidents** due to overlooked gaps.

Tips:

- **Embed audit readiness** into incident response planning — audit trails, change logs, and decision records should be maintained.
- Use audit results for **continuous improvement** — link them into **lessons learned**, **CAPAs**, and **risk treatment plans**.
- Recognize that audits are not just compliance checks — they're **strategic validation tools** for operational resilience.

Summary:

Audits are vital feedback loops. They **strengthen assurance**, **enable executive confidence**, and reinforce that your IR capability is **not theoretical** — it's tested, governed, and **ready for real-world incidents**.

Outsourced Security Providers

Outsourcing components of IT and incident management requires **robust governance**, **contractual precision**, and **strategic alignment** to ensure that **risk ownership remains with the enterprise**.

Key Considerations for Outsourcing Security Functions:

Why Outsource?

Outsourcing may bring access to:

- 24/7 threat monitoring (via MSSPs or MDR providers)
- Specialized skills unavailable in-house
- Faster mean-time-to-detect (MTTD) and mean-time-to-respond (MTTR)

Governance Requirements:

To ensure effective outsourced incident response, the organization must:

1. **Have a documented IRP** that’s still owned and controlled internally.
 - The **Incident Response Plan (IRP)** must **define roles and responsibilities** of both internal IRT and the provider.
2. **Understand Vendor Capabilities**
 - Be clear on:
 - Tools/technologies used (e.g., SIEM, EDR, XDR)
 - Escalation thresholds
 - Communication procedures during a crisis
3. **Define SLAs and Indemnity Clauses**
 - SLAs must specify:
 - **Response time commitments**
 - **Notification protocols**
 - **Data ownership**
 - **Liability limitations**
 - **Indemnity for breaches caused by provider negligence**

Aligning with Vendors — Process-Level Coordination:

This highlights **practical mechanisms** to align enterprise and vendor operations:

Mechanism	Purpose	
Matching incident reference numbers	Ensures traceability and allows incidents to be tracked across systems, improving response coordination.	
Integrating change management	Vendor-involved changes must flow through enterprise change control to avoid security	

	blind spots or undocumented misconfigurations.	
Reviewing recurring incidents	Pattern analysis across enterprise and vendor logs can uncover systemic issues (e.g., unpatched systems, alert fatigue) and improve defenses.	

Advice:

- Treat third-party providers as **extensions of your IRT**, but never **relinquish accountability**.
- Ensure **incident escalation paths** are documented, tested, and agreed upon.
- Audit vendor performance regularly using **KPI/KGI** metrics (from earlier slides).
- Ensure security events are **logged and correlated** across both environments (on-prem and vendor).

Outsourcing IT operations and incident management with the same vendor can benefit from close integration that requires:

- An IRP overseen by and IRT
- Understanding the vendor capabilities or response time
- And developing proper SLAs containing appropriate indemnity clauses.
- The information security manager should consider the following to align with vendors when security functions are fully or partially outsourced:
 - Match the enterprise's incident reference numbers with the vendors for each applicable incident:
 - This ensures a common understanding of incident details between organizations. This also helps to identify the actual organizational recovery time. For example, the vendor may report that service was restored at 4:00 p.m.; however, the outsourcing organization may note that the incident ended at 6:00 p.m. This means that it took the enterprise an additional two hours to recover internally from the incident. This can be determined by matching the enterprise's incident reference numbers with the vendors.
 - Integration of the enterprise's change management functions with the vendor's (to the extent possible):
 - Depending on the nature of the service provided, the enterprise's change management functions may be linked via leaders on the change advisory board or have a platform where the security group can view the vendor's changes and follow-up with key points of

contact from the vendor. This also contributes to awareness of system changes by both organizations.

- Requirement from the vendor for periodic review of incidents that occurs on a regular basis (e.g., monthly, annually):

Operational leadership from both the organization and the vendor attend these meetings, and all incidents/events are reviewed.

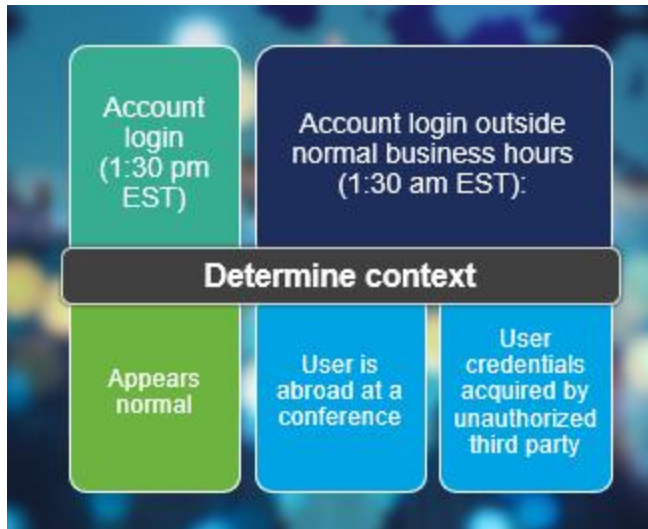
Follow-up items are generally taken from these meetings to help prevent incidents from recurring.

.

Incident Investigation, Evaluation Containment and Communication

Not every event is an incident, the information security manager must be aware of the subtle difference between the two. Performing investigation and evaluation will help determine what containment activities to perform, if any and what should be communicated to those who need to know.

Events vs Incidents



Event vs. Incident — What's the Difference?

Security Event	Security Incident
Any observable occurrence in a system or network	A security event that <i>actually</i> results in a violation or imminent threat to security policies
<i>May be benign or routine</i>	<i>Requires action and response</i>
Needs <i>contextual analysis</i>	Has <i>confirmed impact</i> or <i>potential harm</i>

Insight: Why Context is King

- **Event legitimacy is unknown** until proper analysis is performed.
 - Example: A login at 1:30 pm EST from a known location may be benign.
 - But the same login at **1:30 am EST** could raise suspicion.
- **Contextual interpretation** is required to escalate an event to an incident.
 - Is the user traveling?
 - Is there a pattern of failed logins?

- Have credentials been exposed?

This enables **prioritization and containment** of actual threats, aligning with the **principle of effective risk-based response**.

Eg. Breakdown:

- **Event:** "Account login at 1:30 am EST"
- **Contextual Evaluation:**
 - *User is at a conference abroad* – Event may be justified – *No incident*
 - *Credentials were stolen* – Confirmed violation – *Incident triggered*

This shows how **determining context** bridges the gap between raw telemetry and actionable incident response.

- An event is something that happens at a specific place or time: an account log on, a door opening, an automated process ending. These are all events, lacking any context, that occur with little to no concern.
- Contextual data adjacent or related to the event need to be investigated to determine if the event was in fact normal or abnormal.
- Until the event is investigated properly, a determination as to the events legitimacy is unknown.
 - Once sufficient, proper context around an event has been investigated and evaluated, then appropriate action can be taken.
 - This may result in implementation and execution of the enterprise response and recovery plans, in varying degrees depending upon the severity and impact of the incident to the enterprise

Example of Event Investigation

- For example, a user account logs in to their corporate expense management account during business hours. This is an event that, according to an established baseline (as we discussed in Module 2) occurs normally throughout the business day.
- Any deviation to that, such as a user attempting to login to the account after business hours, is an event that may warrant further investigation as it is outside of established norms.
- Additional contextual information may yield this as being either a legitimate event (i.e., the user is currently traveling abroad, with the login coinciding with their local business day)
- Or it could be a malicious event (i.e., credentials were acquired by an unauthorized third-party and are being used to access enterprise resources).

Best Practices:

1. **Triage capability** must be built into the **Security Operations Center (SOC)** to assess and escalate events based on threat context.
2. **SIEMs and UEBA tools** are instrumental in correlating events and identifying anomalies.
3. Define **clear incident classification criteria** in your IRP to reduce ambiguity during real-time operations.
4. Train staff to **not overreact** to every event, but to validate and investigate before declaring an incident.

Summary:

Events are the **raw signals**; incidents are **validated risks**. Mature incident response relies on strong context gathering, automated tools, and human analysis to **differentiate signal from noise**.

Executing Response and Recovery Plans

This captures the **essential responsibilities** of the **Information Security Manager (ISM)** in overseeing the **execution of incident response (IR) and recovery plans (RP)**.

Successful execution isn't just about having a plan — it's about ensuring the organization can **practice, observe, validate, and refine** it

If an investigation of the context leads to executing the response and recovery plan, there needs to be a facilitator in place who is ready to direct the tasks, oversee execution, liaise with senior management and make decisions. The information security manager should:

- Ensure a facilitator is assigned to provide reasonable assurance the enterprise can respond appropriately and recover key business functions during a disruption.
- Test plan execution to familiarize employees with the process in advance.
- Appoint independent observers to record progress and document exceptions during testing and events.
- Review independent observations to adjust the plan accordingly.

Breakdown of the Four Key Execution Elements:

1. Assign a Facilitator

- The **facilitator** plays a central role in coordinating the test or real execution of the response/recovery plan.
- Ensures the **enterprise-wide orchestration** of activities.
- Provides **reasonable assurance** that all necessary actions are executed effectively.

Insight: This aligns with the **governance aspect** of plan execution — clarity of leadership, authority, and command structure.

2. Test Execution in Advance

- Regular **simulation or tabletop exercises** help familiarize personnel with the process before a real event.
- Builds **muscle memory** in incident response teams and support functions.

Testing is a critical control — both for **response readiness** and **audit defensibility**. It helps uncover procedural gaps, resource bottlenecks, and knowledge issues.

3. Appoint Independent Observers

- Observers ensure **objective documentation** of how the test or real response unfolds.
- They record **exceptions, response time deviations, and communication breakdowns**.

Insight: This step supports **continuous improvement** and promotes **transparency**, especially when IR/DR plans are reviewed by auditors or regulators.

4. Review and Adjust Plans Based on Observations

- Post-event or post-test reviews (also known as **lessons learned sessions**) are crucial.
- Findings should drive **plan refinements, role clarifications, and possibly policy updates**.

Insight: This supports the **plan-do-check-act (PDCA)** cycle — a cornerstone of approach to managing operational resilience.

Takeaway

The ISM's role is not only to **own the IRP and RPP** but also to **ensure their viability in practice**. Effective plan execution depends on:

- Coordination (facilitator)
 - Practice (test execution)
 - Objectivity (independent observers)
 - Learning (observations – improvements)
-

Incident Containment: Methods and Activities

As each incident is unique, methods to contain the incident must be tailored. Understanding the benefits and drawbacks associated with initiating containment is vital for senior management to understand the implications

Definition and Purpose

Incident containment is a **short-term tactical action** designed to:

- **Limit the spread or impact** of a security event
- **Protect critical assets** during an incident
- **Buy time** for analysis and resolution activities

In the framework, containment is part of the **Incident Response Life Cycle**, specifically the **Containment phase**, which sits between detection and eradication.

Key Considerations

1. Tailored Response

- **No one-size-fits-all:** Every incident is unique in its scope, systems affected, threat actor sophistication, and business impact.
- Containment actions must be **context-driven** based on:
 - Threat type (e.g., ransomware vs. insider threat)
 - Criticality of assets affected
 - Recovery and business continuity objectives

Insight: This reflects the principle of **risk-based response** — the CISM should ensure actions align with enterprise risk appetite and tolerance.

2. Common Containment Activities

This widely recognized **technical and operational tasks**, including:

Activity	Purpose in Containment
Notification and escalation	Ensures the right people act swiftly
Memory captures & forensic imaging	Preserves evidence for root cause analysis
Password resets & account lockdown	Stops lateral movement by attackers
Firewall and IDS/IPS updates	Blocks known threats in real-time
Log review and analysis	Identifies breach path and scope
Malware reverse engineering	Helps in understanding malware behavior and mitigation

Device isolation	Prevents the spread of infection or data exfiltration
-------------------------	---

containment playbook. A mature IS program ensures these are well-documented, tested, and rehearsed.

3. Risk of Unplanned Outcomes

- Containment can cause **operational disruption**, especially if critical systems are taken offline.
- Poorly coordinated containment can **escalate the damage** or interfere with forensic efforts.

Insight: This underscores the need for **clear roles**, **approval hierarchies**, and **stakeholder communication** during containment.

As each incident is unique, methods to contain the incident must be tailored. Understanding the benefits and drawbacks associated with initiating containment is vital for senior management to understand the implications.

- Containment is a short-term, tactical action that is meant to purely to “stop the bleeding,” not necessarily to identify or correct the root cause that allowed the incident to occur.
- Containment includes all the activities, tasks and steps taken in the attempt of limiting or reducing the impact of an incident.
- Can have significant impact on immediate response efforts and may result in unplanned outcomes.

Common containment activities performed during a security incident may include (but are not limited to):

- Notification and escalation to relevant stakeholders
- Memory captures and analysis
- Enterprise wide password changes of ALL accounts

- Updating firewall rule sets to block/deny/drop traffic
- Updating IDS signatures
- Log collection, review and analysis
- Forensically image impacted systems
- Malware reverse engineering
- Removing the device from the network

Takeaway

Incident containment is more than just a technical response — it's a **strategic decision-making point**. The IS Manager must:

- Ensure containment actions align with **business impact tolerances**
 - Balance **speed and accuracy** in decision-making
 - Coordinate actions across **technical teams, legal, HR, PR, and leadership**
-

Initiating Containment Activities

Containment is typically directed by senior management who considers recommendations from legal counsel, information security manager and the IMT and decides at what point and how prepared the enterprise is to contain the incident.

- Methods used may affect options for legal action
- Once containment efforts are initiated, the adversary may retaliate when their presence is noticed.
- For example, if the incident involves a malware-infected system actively being controlled by an adversary, the purpose is to identify all potentially impacted systems to remove the adversary from the environment.
- The enterprise may choose to disconnect the system from the network, update firewall rules to block identified IP addresses and domains associated with the adversary

- Or scan for indicators of compromise to identify other compromised systems.

Purpose of Containment Initiation

The **initiation** of containment activities is a **strategic decision point** in the incident response lifecycle. This action is taken after detection and analysis confirm an incident is ongoing and may have **active adversary control**, particularly in malware-related events.

Senior Management Role

“Typically directed by senior management...”

According to **best practices**, senior leadership plays a pivotal role in containment decision-making due to:

- **Business impact considerations** – The containment action may disrupt operations.
- **Legal ramifications** – Premature actions (e.g., pulling a system offline) may:
 - Destroy evidence needed for legal action or law enforcement
 - Violate contractual obligations (e.g., SLA requirements)
- **Adversary awareness** – Certain containment actions may alert the attacker, prompting them to escalate or pivot tactics.

Insight: This reflects the **principle of governance and leadership oversight** in cybersecurity incident response — a key CISM domain focus.

Example Enterprise Actions (Tactical Containment)

Each example provided in the slide is a common **technical control** implemented during containment:

Action	Objective
Disconnect system from the network	Immediately isolates compromised assets to prevent lateral movement
Update firewall rules	Blocks malicious IPs/domains known to be associated with attacker infrastructure
Scan for indicators of compromise (IOCs)	Identifies spread or persistence of the attacker on other systems

Insight: These actions are based on **pre-approved playbooks** and should be implemented in coordination with legal, IR, and forensic teams.

Considerations Before Initiation

Professionals must **assess risk vs. reward** of initiating containment. Questions to ask include:

- Has the full scope of the compromise been identified?
- Will containment interfere with ongoing investigations?
- Are sufficient logs or forensic images collected?
- Have executive stakeholders and legal counsel been briefed?

Takeaway

You must:

- Understand that **timing of containment is critical** — both too early and too late carry risk
- Ensure **decision-making authority is clearly defined**
- Coordinate containment activities with the **enterprise's strategic goals and regulatory posture**

- Establish **playbooks** and **training programs** so responders understand when to escalate and execute
-

Communications :

Incident Management

Effective communication is the **cornerstone of a successful incident response** program. Without a clearly defined communications strategy, incidents can escalate in both scope and perceived severity due to **misinformation, speculation, and delay**.

Objective of Communication During an Incident

The primary goal is to:

- **Reduce confusion**
- **Preserve trust**
- **Support timely decision-making**
- **Ensure legal, operational, and reputational protection**

Best Practices:

1. Define Authorized Channels

- Pre-establish official **communication lines** (e.g., secured email, crisis hotline, comms app).
- Only **pre-approved personnel** should use these channels to distribute information.

Insight: This aligns with ensuring **role-based communication protocols** in incident response planning.

2. Document and Disseminate

- Everyone from the **Incident Response Team (IRT)** to senior management must know:
 - **Where** to send information
 - **Whom** to notify
 - **How** to escalate

Insight: Documented processes are vital for **audit readiness and accountability**.

3. Establish an Authoritative Voice

- Appoint a **single authoritative spokesperson** (e.g., CISO, comms officer).
- Prevents rumors and **unauthorized internal/external disclosure**.

Insight: This is essential for protecting the enterprise from legal, regulatory, or reputational damage.

4. Update Responsibly as Events Unfold

- As new facts emerge, ensure that updates are **accurate, timely, and cascaded** to relevant stakeholders.
- *Insight:* Communications must be **dynamic yet controlled**, aligned with incident status changes.

Because incidents impact various aspects of an enterprise is important to reduce possible misunderstanding and limits misinformation

- Establishing and defining clear channels of authorized and authoritative communication.
- Documenting and conveying these communication channels in advance of incidents to ensure each member knows the source of authoritative information
- Establishing an authoritative source in advance to prevent speculation or downplaying of facts

- As information changes and events unfold, it is important address and update incorrect information appropriately

Takeaways:

- **Integrate the communication strategy** into the incident response plan
 - **Test the communication plan** through tabletop exercises
 - **Collaborate with PR, legal, and compliance** for multi-audience messaging
 - Ensure **confidentiality and data protection** in all communications
-

Communication Channels

In Incident Management

Effective communication is not optional—it's essential. During an incident, well-defined channels are the lifeline that enables timely decision-making, coordination, and response.

1. Establish Communication Between IMT Manager and Senior Management

This is the **first and most critical channel** to activate:

- The Incident Management Team (IMT) manager **must keep executives updated** on situation severity, business impact, and risk exposure.
- Enables strategic decisions such as invoking disaster recovery or legal notifications.

Note: This ensures governance oversight and aligns with business continuity planning.

2. Decide Whether to Communicate With Additional Audiences

Not all incidents require mass notification. Use a **tiered communication approach**:

- Internal stakeholders (IT, Legal, HR)
- External parties (regulators, vendors, customers)

Tip: This aligns with **audience-specific communication** strategies—balancing transparency and control.

3. Ensure Proper Message Is Conveyed to Respective Audience

Customize messaging based on:

- Audience technical literacy
- Regulatory and legal implications
- Emotional tone and urgency

Reminder: Messages must be **pre-approved and documented** to avoid miscommunication or liability.

4. Provide Alternate Secure Communication Method

In a serious incident (e.g., ransomware, DDoS), normal channels (email, VoIP) may be compromised:

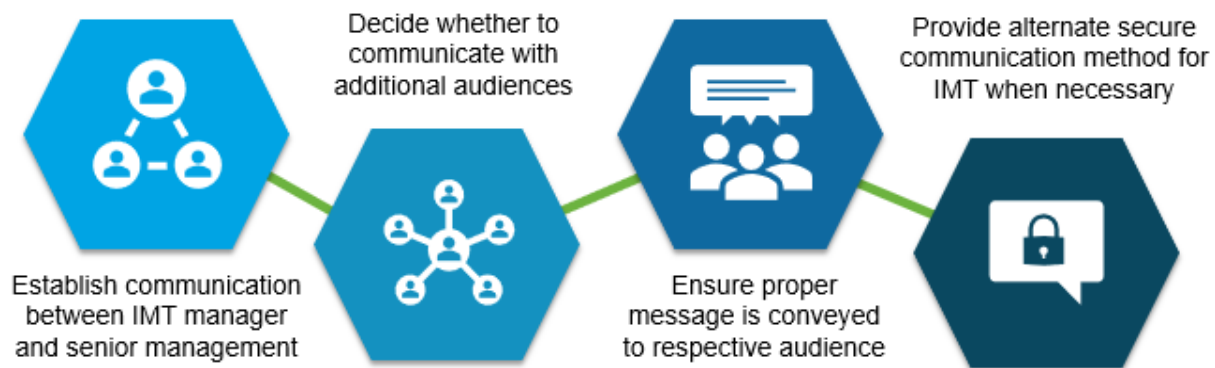
- Use encrypted messaging apps
- Activate **out-of-band communication** (e.g., satellite phones, secure SMS)

Practice: This is a critical component of your **incident response playbook and tabletop tests**.

There are a number of communication channels that should be established during an incident.

- Communications will need to occur between the IMT manager and senior management
- As well as decisions on whether or not to communicate with additional audiences including enterprise staff, external third parties, and affected business partners.

- Ensure the proper message is conveyed to the respective audiences.
- From a technical perspective, the IMT members will need a method to facilitate communications out-of-band or communicating by other than normal communication methods. For example, in responding to a suspected network intrusion, users should not communicate over suspected compromised infrastructure that may alert the intruder that they have been identified. This results in the IMT members switching to an approved browser-based email platform (e.g., Google Business) instead of the normal enterprise business email (e.g., Microsoft 365).



Guidance:

To mature your incident communications capability:

- Define primary and backup communication paths in the IR plan
 - Train personnel on **what to say, when to say it, and whom to say it to**
 - Involve **legal and public relations** early for high-profile incidents
 - Regularly test and audit your communication protocol
-

Notification Requirements

During an incident, especially a **disruptive or high-impact event**, timely and accurate **notification** is critical to trigger recovery actions, obtain external support, and fulfill regulatory obligations.

Core Components the IRP Must Include:

1. Directory of Key Personnel

- A centralized and updated **contact list** of essential internal and external personnel.
- Should include:
 - Response team leads
 - Executives
 - Technical SMEs (Subject Matter Experts)
 - Legal and regulatory liaisons

Best Practice: Keep copies offline and securely stored to ensure availability during outages.

2. Multiple Communication Methods

- Don't rely on a single channel—plan for **redundancy**:
 - Landline, mobile, SMS
 - Secure messaging apps
 - Satellite phones or radios (for high-resilience environments)

Why? Channel failure during a cyberattack (e.g., ransomware) is common. Fallback paths are **vital for continuity**.

Entities That Must Be Reachable in the IRP:

Category	Examples
Vendors	Equipment/software reps
Suppliers	Enterprises providing IT spares, media, storage
Recovery Sites	Hot/cold/warm sites, backup data centers
Media Facilities	Offsite backup retrieval agents
Insurers	Cyber insurance contacts, claims response
Regulators	Mandatory breach reporting (GDPR, HIPAA, etc.)
HR/Staffing	Contracted personnel for surge support
Law Enforcement	For criminal activity or data breach escalation

Tip: Notification plans should **align with legal, operational, and third-party risk obligations**.

Notification requirements are key parts of the IRP and incident management. Note: There are companies that handle automated emergency response communications. However, as with any other outsourced service, careful consideration should be given to the required processes that must be in place to ensure the effectiveness of this solution.

- The IRP should include a directory of key decision-making personnel, IRT members, information systems owners, end users and others required to initiate and carry out response efforts.

- A directory should also include multiple communication methods (telephone, cellular phone, texting, email, etc.) in the event of any communications channel failure.

The directory should include, at a minimum, the following individuals:

- Representatives of equipment and software vendors
- Contacts within companies that have been designated to provide supplies and equipment or services
- Contacts at recovery facilities, including hot site representatives or predefined network communications rerouting services
- Contacts at offsite media storage facilities and the contacts within the company who are authorized to retrieve media from the offsite facility
- Insurance company agents
- Contact information for regulatory bodies
- Contacts at HR and/or contract personnel services
- Law enforcement contacts. Note that the decision to bring in law enforcement during such an incident rests solely with senior management. It is generally not the role of an information security manager to inform external organizations.

Guidance:

To ensure compliance and operational readiness:

- Periodically **review and test** notification lists
 - Assign responsibility to maintain contact integrity
 - Integrate into your **tabletop exercises**
 - Document communication **SLAs and escalation paths**
-

Communication Networks

In the context of incident management, **telecommunication networks** are not just enablers of business operations—they are **lifelines** during a crisis.

Account For: Network Dependency and Criticality

These elements help ensure that your **response and recovery plans** will actually work when needed:

- **Network Inventory:** Document every WAN, LAN, telecom circuit, and provider supporting business operations.
- **Criticality Classification:** Prioritize networks based on business impact and dependency.
 - Example: Finance systems network vs. internal guest Wi-Fi.
- **Disruption Types:** Plan for:
 - **Natural disasters** (earthquakes, floods)
 - **Cable cuts** (construction or sabotage)
 - **System glitches** (misconfigurations, DNS failures)
 - **Cyberattacks** (DoS/DDoS, ransomware)
- **Resiliency Planning:**
 - Organizations must identify outage thresholds for each communication path.
 - Backup strategies may include redundant network paths, SD-WANs, or virtual circuits.

Consider: Design Elements for Continuity

To maintain communication in high-stakes scenarios:

- **Network Types:**
 - **Voice Circuits** (analog, digital)

- **WAN/LAN** connections
- **Third-Party Links** (SaaS, cloud, ISPs)
- **Communication Path Diversity:**
 - Consider **satellite**, **microwave**, or **radio links** for highly critical operations.
 - Use **out-of-band communication** paths when primary networks are under attack.
- **Power Backup:**
 - Include **Uninterruptible Power Supplies (UPS)** for all telecom and networking gear.
 - Ensure **generator support** for long-term outages.

More Insights

The plan should account for details of the enterprise's telecommunication networks needed to restore business operations.

- Because of the criticality of these networks, the procedures to ensure continuous telecommunication capabilities should be given a high priority.
- Telecommunication networks are susceptible to the same natural disasters as data centers but are also vulnerable to disruptive events unique to telecommunications. These include central switching office disasters, cable cuts, communication software glitches and errors, security breaches from hacking (phone hackers are known as "phreakers"), and a host of other human errors.
- Enterprises should backup their own telecommunication facilities and identify critical capacity requirements of outage thresholds for each capability

Telecommunications capabilities to consider include

- Telephone voice circuits, wide area networks (WANs), local area networks (LANs) and third-party providers
- Options depending on criticality and location (single-band communication, satellite or microwave uplinks)
- Sufficient backup for telecommunications and computer equipment through uninterrupted power supplies (UPSs)

Insight: Failure to design resilient network communications can **cripple recovery efforts**, especially during incidents like ransomware or insider threats that target infrastructure directly.

Advice:

- Embed **network dependency analysis** into your **Business Impact Analysis (BIA)**.
 - Align communication strategies with **disaster recovery** and **incident response playbooks**.
 - Periodically test alternate network paths and simulate **network outages** in exercises
-

Incident Eradication, Recovery and Review

While incident containment is the short-term approach to limit an incident and keep it from spreading, akin to stopping the bleeding, incident eradication takes a broader approach that leads toward recovery and review.

Eradication, Recovery, and Review

This triad represents **post-containment activities** that ensure both **technical restoration** and **strategic improvement** of the incident response capability.

1. Eradication – Root Cause Removal

Objective: Eliminate artifacts and vulnerabilities that enabled the incident.

- Includes:
 - Removing malware, unauthorized access tools, or rogue processes.
 - Identifying and patching exploited vulnerabilities.
 - Disabling compromised accounts or credentials.
 - Cleaning affected systems or rebuilding from trusted images.

Insight: Failure to eradicate the root cause can lead to **recurrence**, undermining organizational trust and increasing recovery costs.

2. Recovery – Restoration to Normalcy

Objective: Safely restore affected systems and services to full operational status.

- Includes:
 - Validating systems for integrity.
 - Monitoring for residual signs of compromise.
 - Phased reintroduction of systems to the network.
 - User verification, access restoration, and business validation.

Success Criteria:

- Systems are stable.
- No signs of residual threat.
- Business operations resume per RTO/RPO objectives.

3. Review

Objective: Institutional learning and continuous improvement.

- Conduct a **Post-Incident Review (PIR)**:
 - Analyze what happened and why.
 - Identify detection gaps or process failures.
 - Assess communication effectiveness.
 - Document actions taken, decisions made, and stakeholder impact.
- Update:
 - Incident response playbooks.
 - Policies and procedures.
 - Training and awareness programs.

Focus: The review phase strengthens the **feedback loop** between operations and governance. It's also critical for **board reporting** and **audit readiness**.

More Insights

- Eradication includes activities, tasks and steps taken to correct the root cause leading to the incident
- After the incident is eradicated, recovery steps move the affected system(s) back to regular operating procedures.
- Reviewing all the progress, good and bad, at the end provides valuable feedback to improve the program in the future.



Summary:

These three phases are where **technical and strategic elements converge**:

- Eradication ensures **the threat is gone**.
- Recovery ensures **the business is stable**.
- Review ensures **the organization is stronger next time**.

How to integrate them into **policy, training, and executive reporting** frameworks.

Eradication Activities

1. Root Cause Analysis

- **Purpose:** Identify the origin of the incident — e.g., phishing email, zero-day vulnerability, misconfigured system.
- **Strategic Value:** Helps prevent recurrence by addressing systemic or process failures.
- **Insight:** Ensure RCA findings are fed into risk assessments, incident reports, and control enhancements.

2. Clean Up of Artifacts

Clean up and removal of any artifacts left behind from the incident

- **Purpose:** Remove residual tools (e.g., backdoors, web shells, scripts) left by adversaries.
- **Strategic Value:** Prevents re-entry or reinfection.
- **Insight:** Validate cleanup actions against a documented list of Indicators of Compromise (IoCs).

3. Apply Missing Patches

Application of any outstanding patches

- **Purpose:** Remediate exploited vulnerabilities.
- **Strategic Value:** Reduces attack surface.
- **Insight:** Ensure patching policies are reviewed, automated where possible, and exceptions are tracked.

4. DNS Null Routing of Malicious IPs and FQDNs

DNS null routing (sinkhole) of malicious IP addresses and fully qualified domain names

- **Purpose:** Prevent systems from communicating with known malicious domains or IPs.
- **Strategic Value:** Disrupts command-and-control channels and data exfiltration paths.
- **Insight:** Integrate threat intelligence into DNS/firewall policies for real-time updates.

5. Firewall/IDS Changes

Additional changes to firewalls and IDS as needed

- **Purpose:** Modify rule sets to block malicious traffic or intrusion attempts.
- **Strategic Value:** Immediate containment, policy reinforcement.
- **Insight:** Ensure all changes are tracked through change management and logged for forensic review.

6. Scanning for Additional IoCs

- **Purpose:** Identify hidden or delayed threats that may still reside in the environment.
- **Strategic Value:** Increases confidence in eradication completeness.
- **Insight:** Use findings to refine detection capabilities and update SIEM signatures.

7. Removing Malicious Software

- **Purpose:** Completely eliminate malware from infected systems.
- **Strategic Value:** Final step to restore system integrity.
- **Insight:** Verify through endpoint scanning, sandboxing, and post-eradication monitoring.

Rebuilding impacted systems from authoritative media

Restoring from backups

Guidance:

Eradication is not just a technical task; it is a strategic control function.

A professional must ensure that:

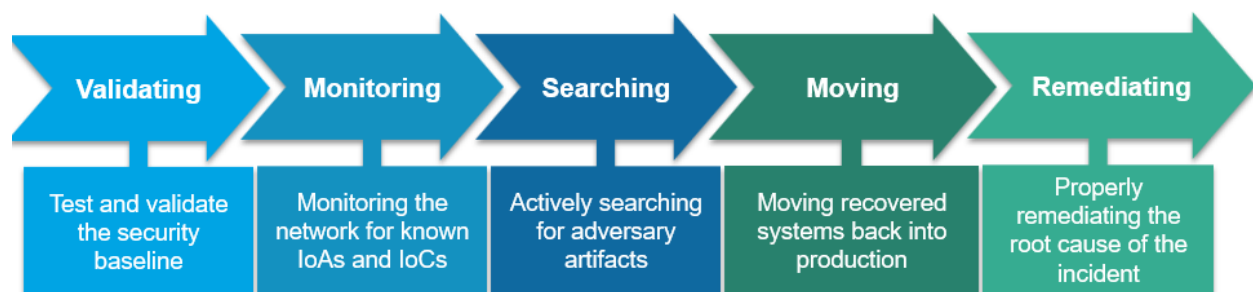
- These activities are part of documented procedures.
 - Roles and responsibilities are assigned and trained.
 - Lessons from eradication efforts feed back into preventive controls and risk registers.
 - Recovery is not approved until eradication is verified and signed off.
-

Recovery Activities

The **goal** of the recovery phase is not only to restore systems to operational status but also to ensure **resilience** against future incidents. Each stage shown in the slide plays a vital role in ensuring *secure reintegration* of systems into production.

Recovery Activities

Plan and implement recovery phase activities to prevent similar events from occurring through:



Note

- Recovery should be a deliberate, careful process not to be rushed.

1. Validating

- **Purpose:** Re-establish trust in system integrity.
- **Action:** Test and validate the **security baseline** (e.g., configurations, policies, and controls).
- **View:** Ensure validation is part of your change management and security assurance process.

2. Monitoring

- **Purpose:** Detect lingering or recurring threats.
- **Action:** Monitor systems for **Indicators of Compromise (IoCs)** and **Indicators of Attack (IoAs)**.
- **View:** This is an opportunity to test the effectiveness of your **SIEM, EDR,** and **alerting thresholds**.

3. Searching

- **Purpose:** Proactive threat hunting.
- **Action:** Actively search for remaining malware, backdoors, or artifacts.
- **View:** These searches should inform updates to threat detection rules and policies (e.g., IDS/IPS tuning).

4. Moving

- **Purpose:** Controlled reintegration.
- **Action:** Move remediated systems back into **production environments**.
- **View:** Move only after sign-off from IT, business owners, and security — following **defined return-to-service criteria**.

5. Remediating

- **Purpose:** Fix the root cause and weaknesses exploited.
- **Action:** Correct underlying vulnerabilities (e.g., poor patching, misconfigurations, inadequate access controls).
- **View:** Integrate lessons learned into control design and risk registers — not just fix the symptoms.

Recovery should be a deliberate, careful process; not to be rushed. Recovery is not a race — it's a risk-based, measured process.

More Insights

Plan and implement recovery phase activities to prevent similar events from occurring through:

- Testing and validating the security baseline
- Monitoring network for known indicators of attack (IoAs) and IoCs
- Actively searching for identified adversary artifacts across the enterprise
- Moving recovered systems back into production after verifying that they meet the security baseline
- Properly addressing and remediating the root cause of the incident to ensure business risk is managed properly.
- Recovery should be a deliberate, careful process and should not be rushed. Systems that have been previously compromised may have been rendered more vulnerable than they first appear. Threat actors often plant malware or otherwise stage their vectors for compromise in advance of actual incidents. In some cases, images or other quick-recovery mechanisms may only serve to reset a system to a state already vulnerable to the same attack. The safest course of action when recovering a compromised system may be to rebuild it from authoritative media, erasing all prior content in the process.

A premature return to production can reintroduce compromised systems. We must *govern* this transition with clearly defined **roles, responsibilities, criteria, and communication protocols**.

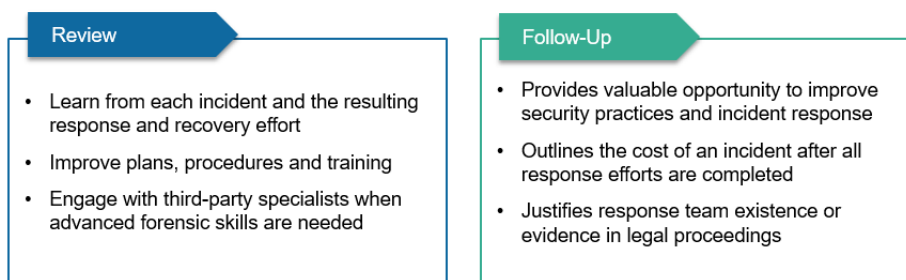
Governance Responsibilities During Recovery:

- Require documentation and evidence of remediation.
 - Validate that recovery aligns with **business impact analysis (BIA)** and **RTO/RPO**.
 - Communicate with stakeholders (technical + business) about service readiness.
 - Update incident reports and initiate post-incident review.
-

Post-Incident Review & Follow-Up

Post-Incident Review and Follow-Up

Post-incident reviews and follow-up procedures enable the information security manager to continuously improve the security program.



Review (Retrospective Analysis)

This is a *structured debriefing process* to understand:

- **What happened**
- **Why it happened**
- **How effectively it was managed**
- **What should be improved**

Key aligned review actions:

- **Learn from each incident:** Identify root causes, response gaps, and control failures. This supports continual risk management enhancement.
- **Improve plans/procedures/training:** Feed findings into updates to the **Incident Response Plan (IRP)** and **BC/DR strategies**.

- **Engage third-party experts when needed:** Forensic specialists bring independent verification and deeper technical root cause analysis, essential in regulatory or legal contexts.

Follow-Up (Formal Closure and Strategic Alignment)

Follow-up is how the professional ensures the *response has long-term impact* and aligns with organizational objectives.

Relevant follow-up actions:

- **Improve security program:** By identifying systemic weaknesses (people, process, tech) and using incident outcomes to justify budget, policy updates, or staffing needs.
- **Cost documentation:** Quantifying **business impact** (loss, downtime, reputational damage, recovery cost) supports **risk-based decision-making** and board-level engagement.
- **Legal and audit trail support:** Proper documentation provides critical evidence in compliance reviews, litigation, or regulatory investigations.

Why This Matters

Post-incident review and follow-up are not just procedural—they are **strategic levers** that:

- Justify **improvements in maturity and funding**
- Reinforce **accountability**
- Demonstrate **risk governance**
- Enable **metrics-based reporting** (e.g., MTTR, cost-per-incident, control effectiveness)

Post-incident reviews and follow-up procedures enables the information security manager to continuously improve the security program.

More Insights

The information security manager should:

- Manage post-incident reviews to learn from each incident and the resulting response and recovery effort.
- Use information gathered to improve the enterprise's response and recovery procedures.
- Perform reviews with the help of third-party specialists if detailed forensic skills are needed.

Follow-Up

- Provides the information security manager a valuable opportunity to improve security practices and incident response
- As a part of this process, the information security manager needs to outline the cost of the incident once all response efforts are done. Performed by adding the cost of any loss or damage plus the cost of labor and any special software or hardware needed to handle the incident.
- The cost provides a useful metric, especially in justifying the existence of the response team to senior management and may be used as evidence in legal proceedings.

Insight:

“A strong professional doesn't just resolve incidents—they institutionalize the lessons. That's where real resilience is built.”

Common Post-Incident Activities reflects an essential operational and governance practice directly aligned with **Domain 4: Incident Management**. This is the *final but most strategically impactful* stage of the incident response lifecycle — one that ensures **organizational learning, maturity, and resiliency**.

When concluding and closing out an incident, common post-incident activities need to be planned and carried out once the business has successfully recovered, activities may include, but are not limited to, the following:

Perspective: Breakdown of Each Activity

1. Documenting the Incident

- **Purpose:** Creates a permanent record for accountability and analysis.
- **Tie-In:** Supports auditability, evidence for compliance, and improvement tracking.
- *Tip:* Ensure accuracy, timestamps, actions, and decisions are clearly logged.

2. Gathering Stakeholder Review and Feedback

- **Purpose:** Captures insights from all impacted units.
- **Tie-In:** Promotes cross-functional learning, ensures that business units are heard, and enhances incident ownership.

3. Finalizing the Report for Senior Management

- **Purpose:** Summarizes what happened, business impact, and improvement recommendations.
- **Tie-In:** Enables governance accountability and informed strategic decisions; often includes executive-level metrics like **MTTR**, **costs incurred**, or **compliance gaps**.

4. Identifying Process Issues or Changes Required

- **Purpose:** Pinpoints policy, procedural, or control deficiencies.
- **Tie-In:** Direct link to risk treatment and control validation strategies.

5. Updating Procedures as Needed

- **Purpose:** Ensures SOPs reflect lessons learned.
- **Tie-In:** A core requirement for process maturity and alignment with ISO/IEC 27035 or NIST 800-61 standards.

6. Developing Remediation Plans to Mitigate Root Cause

- **Purpose:** Addresses technical, process, or human vulnerabilities.
- **Tie-In:** Proactively reduces recurrence probability. Supports **continuous improvement model (CIM)** in CISM lifecycle.

7. Seeking Resource and Funding Approval

- **Purpose:** Justifies investments needed to implement improvements.
- **Tie-In:** Enables cost-benefit communication to the board/CIO/CISO, aligning with risk appetite and business impact analysis (BIA).

Insight:

"Post-incident activities transform reactive defense into strategic resilience. Real value is demonstrated not in how fast they contain an incident, but how well they evolve the program afterward."

Practice Advice:

- Integrate findings into your **risk register** and **training plans**.
- Communicate outcomes to stakeholders to demonstrate transparency.
- Schedule a formal **lessons learned workshop** within 7–14 days of incident closure.
- Use this phase to **justify improvements** in IR automation, staffing, or vendor SLAs.

Identifying Causes and Corrective Actions provides a foundational framework for post-incident root cause analysis (RCA), which is central to effective incident response governance under **Domain 4: Incident Response**.

Interpretation

An experienced **Information Security Manager** is expected to:

- Move beyond surface-level symptoms

- Systematically analyze the full context of an incident
- Enable long-term mitigation strategies that improve security maturity

This visualizes a **structured, investigative approach**, guiding **root cause analysis (RCA)** through seven forensic-style questions:

The information security manager should appoint an incident review team to enable systematic review of security incidents. This team should:

- Review any evidence by identifying root causes of a specific incident
- Develop recommendations to enhance the information security program
- Implement necessary measures to prevent the same/similar events from recurring.
- The root cause of many system compromises, for example, is weak or nonexistent vulnerability assessment and patch management efforts.

The Seven RCA Questions Explained

Who was involved?

- Identify internal users, third-party actors, threat groups, or compromised accounts.
- Supports **attribution** and accountability.

What happened?

- Define the **type of event** (e.g., ransomware, data exfiltration, insider breach).
- Essential for **incident classification and prioritization**.

Where did it originate?

- Trace the attack vector (e.g., phishing email, compromised VPN, rogue application).
- Vital for improving **network segmentation, monitoring, or email filtering**.

When (in what time frame) did it happen?

- Establish timelines for attack initiation, detection, response, and recovery.
- Supports **mean time to detect (MTTD)** and **mean time to respond (MTTR)** metrics.

Why did it happen?

- Determine whether it was due to control failure, misconfiguration, social engineering, etc.
- Guides **risk treatment strategy** selection: mitigation, acceptance, or transfer.

How did the attack occur? or (How was the system vulnerable?)

- Map the **kill chain or attack path** using frameworks like MITRE ATT&CK.
- Informs **security control enhancements**.

What was the reason or motivation? (i.e., the perpetrator's motivation)

- Understand attacker **intent** (e.g., financial gain, espionage, sabotage).
- Supports threat intelligence and **incident profiling**.

Why This Is Crucial

- **Risk-Based Response:** Enables managers to tailor controls to attack root causes, not just symptoms.
- **Control Enhancement:** Links findings to GRC practices such as policy refinement, system hardening, or user awareness.
- **Incident Learning Loop:** Forms the evidence base for **continual improvement, training plans**, and **strategic investment** in security.

Insight:

"Treat every incident as a learning opportunity. A strong corrective action plan is your ticket to turning disruption into resilience."

Benefits of Documenting Events

Breakdown

Documenting events during and after a security incident is **not optional** — it's an integral element of governance, accountability, and evidence management.

During and after any actual or potential security incident, the information security manager should have processes in place and individuals assigned to develop a clear record of events.

Let's explore the three key benefits outlined:

1. Provides clarity of whether an incident is merely an accident, a mistake or a deliberate attack.

"Provides clarity of whether an incident is an accident, mistake, or deliberate attack."

- **Why It Matters:**

- Not all anomalies are malicious; misconfigurations, user errors, or testing activities can mimic attack behavior.
- Accurate classification is essential for prioritization and escalation.

- **Tie-In:**

- Supports **risk assessment, incident categorization**, and enables proper selection of containment and recovery strategies.

2. Preservation of evidence that can be investigated further by a forensics team or authorities

"Preserves evidence for later investigations by private forensics teams or authorities."

- **Why It Matters:**

- Audit trails, logs, and notes serve as primary evidence in breach investigations and compliance inquiries (e.g., GDPR, HIPAA, PCI-DSS).
- Forensic soundness depends on **timeliness** and **integrity** of recorded data.
- **Tie-In:**
 - Aligns with **chain of custody** principles, legal preparedness, and **incident handling procedures**.

3 Ensure nothing is missed if performed while events are unfolding.

“Ensures nothing is missed if performed while events are unfolding.”

- **Why It Matters:**
 - Real-time documentation reduces **human memory bias** and helps identify subtle indicators of compromise (IoCs) or attack vectors.
 - Enables better coordination and faster handoffs between incident response team members.
- **Tie-In:**
 - Critical to **incident communication plans**, coordination, and future **post-incident reviews**.

Key Tip:

If you're asked what the **first step** is once an incident is detected and confirmed — **documentation** is nearly always a correct early response, alongside containment actions.

Insight:

“In the fog of an incident, documentation becomes your compass. It's the thread that ties detection, response, and recovery into a coherent narrative — for operations, compliance, and courtrooms.”

Establishing Legal Procedures

Having solid, legally defensible procedures and framework in place prior to an incident declaration is key to successful recovery and response.

Analysis

Let's explore each of the four key elements on this slide:

1. Involve Legal Counsel Early

"Enterprises should involve legal counsel during preparation and execution."

- **Why This Matters:**
 - Legal teams guide the formulation of response protocols that align with contractual, privacy, and regulatory obligations.
 - Early engagement ensures documentation, investigation, and disclosure are handled lawfully.
- **Perspective:**
 - Legal collaboration is essential during **incident classification**, **notification**, and **evidence collection** processes.

2. Cyber Preparedness Faces Increased Scrutiny

"Cyber preparedness is under increased regulatory and legal scrutiny due to recent rapid increases in cybercrime."

- **Why This Matters:**
 - Legislators and regulators worldwide (e.g., GDPR, CCPA, DORA) are tightening the accountability of executive leadership during cyber incidents.
 - Failure to demonstrate readiness may lead to penalties, lawsuits, and reputational damage.
- **Implication:**

- Legal preparedness becomes part of your **risk treatment** and **business continuity** strategies.

3. Compliance Risk is Growing

"More laws and regulations may result in increased regulatory compliance risk for enterprises."

• *More laws and regulations may result in increased risk for enterprises especially in terms of regulatory compliance*

- **Why This Matters:**

- Incident response teams must operate in a regulatory minefield — cross-border data transfers, breach notification deadlines, industry-specific obligations (e.g., HIPAA, PCI-DSS).

- **Angle:**

- Maintaining a current legal register and embedding legal checkpoints in your incident response plan helps **mitigate compliance gaps**.

4. Legal Involvement Mitigates Risk

"Involvement may help maintain compliance risk within tolerable levels under evolving conditions."

• *Involving legal counsel in preparation and testing may help enterprises keep this risk within tolerable levels as conditions continue to evolve.*

- **Why This Matters:**

- Legal teams translate vague threats into **actionable legal exposure**, ensuring decisions during a crisis are **legally defensible**.
- It supports better **communication strategies** (press, regulators, stakeholders).

- **Implication:**

- This aligns with **Governance and Risk Management**, ensuring business leaders understand both operational and legal exposure

Insight:

“Your best defense isn’t just a firewall — it’s a general counsel who knows your IRP by heart and can guide you through a legal storm without sinking the ship.”

Regulations and the IRP

When a security incident occurs, the risk of mistakes or legal exposure for not complying with notification requirements can be significant .

Interpretation & Strategic Guidance

Key Message:

Non-compliance with regulatory notification requirements during incidents can result in severe legal and financial consequences.

- In a highly regulated environment, An IRP should position the enterprise to address legal and technical requirements encountered when responding to an incident. When a security incident occurs, there can be significant risk of mistakes or legal exposure for not complying with notification requirements

1. Engage Legal Counsel Early

“Consult legal counsel immediately to help ensure the investigation is covered by attorney-client privilege.”

- **Why It Matters:**

- Attorney-client privilege can **protect sensitive communications** and preliminary findings from disclosure.
- It **shields internal deliberations**, especially when litigation or regulatory investigations are anticipated.

- **Best Practice:**

- Involve legal counsel **at the first sign** of a breach, not just after confirmation.

2. Ensure Timely Regulatory Notifications

“Leverage legal counsel to analyze and fulfill any notifications required within the designated time frame.”

• *Leverage legal counsel to analyze and fulfill any notifications required within the designated number of hours following discovery.*

- **Why It Matters:**

- Regulations like **GDPR, CCPA, HIPAA**, and **NIS2** impose strict breach notification timelines (e.g., 72 hours under GDPR).
- Missing deadlines leads to **fines, reputational loss, and regulatory scrutiny**.

- **Insight:**

- Your **IRP should integrate legal workflows** to interpret notification triggers per regulation, jurisdiction, and sector.

3. Understand Jurisdictional Complexity

“Remember that localities may have different notice requirements to individuals, agencies or third parties.”

•Remember localities (states, provinces, regions) may have different notice requirements to individuals, agencies (regulatory or government) or third-parties

- **Why It Matters:**

- Breach notification laws vary by **state, country, and industry** — complexity grows in multinational or cloud environments.
- You may need to notify **data subjects, regulators, law enforcement**, and **business partners** — each with distinct rules.

- **Best Practice:**

- Maintain a **regulatory requirements matrix** in your IRP to avoid delays and oversight.

Tip:

“A well-rehearsed incident response plan isn’t complete unless your legal counsel can execute it blindfolded — in multiple jurisdictions.”

Consideration:

- If data breach or PII exposure is involved, assume **legal notification obligations apply**.
 - Always choose the option that involves **early legal consultation and timely notification**.
-

Data Preservation Procedures

Objective:

- Ensure evidence integrity to support investigations, legal proceedings, and future forensic analysis
- There are a few basic actions that the information systems staff must take when preserving evidence
 - Trained forensics personnel can inspect attacked computer systems
 - This includes doing nothing that could change, modify or contaminate potential or actual evidence.
 - but if the enterprise's personnel contaminate the information, the data may not be admissible in a court of law and/or the forensics staff may be unable to use the data in investigating an incident.
 - Computer forensics and gathering and handling information and physical objects relevant to a security incident in a systematic manner so they can be used as evidence in a court of law should usually be performed by specially trained staff, third-party specialists, security IRT or law enforcement officials.

The initial response by the system administrator should include:

- Determining privileged versus nonprivileged investigation by legal counsel
- Retrieving information needed to confirm an incident
- Identifying the scope and size of the affected environment (e.g., networks, systems, applications)
- Determining the degree of loss, modification or damage (if any)
- Identifying the possible path or means of attack

Foundational Principle

“To be prepared for potential legal action, IS staff must take certain actions to preserve evidence, including doing nothing to change, modify or contaminate potential or actual evidence.”

- **Key Concept: Forensic Readiness**

- The moment an incident is detected, **evidence must be treated as legally admissible** — no modification or tampering.
- This includes **logs, system images, memory captures, communications**, etc.
- IS staff must understand the concept of **chain of custody** and maintain it rigorously.
- **Best Practice:**
 - Build **procedural awareness** in advance — your response team shouldn't have to learn this during an actual breach.

Initial Admin Responses (Forensic-Driven Actions)

1. Determine Legal Boundaries

“Privileged vs. nonprivileged investigation by legal counsel”

- Critical for **attorney-client privilege** — legal counsel must lead any investigation that may result in litigation.
- Protects the confidentiality of internal findings until disclosure is legally required.

2. Retrieve Initial Indicators

“Retrieving information to confirm an incident”

- Initial triage to **validate whether an actual breach occurred**, versus a false positive.
- Includes reviewing alerts, logs, and abnormal behavior (but without contaminating logs or data).

3. Scope the Environment

“Identifying scope and size of affected environment”

- Helps determine:
 - **Extent of exposure**
 - **Which business processes** are impacted

- **Need for escalation**

4. Assess Damage

“Determining degree of loss, modification or damage”

- Impacts reporting thresholds under laws like GDPR, HIPAA, or SOX.
- Helps prioritize containment, notification, and recovery efforts.

5. Trace the Attack Path

“Identifying possible path or means of attack”

- Also known as **Attack Vector Analysis**.
- Critical for:
 - Containment
 - Patch and reconfiguration
 - Preventing recurrence

Tip:

“If it isn’t preserved properly, it won’t stand up in court — and the entire IR process may be challenged.”

Advice:

- Train system administrators on **what not to touch** before forensics are complete.
 - Document procedures in IRP and DRP for:
 - **Evidence handling**
 - **Preservation standards**
 - **When to escalate to legal/forensic teams**
-

Data and Evidence Preservation Considerations emphasizes a fundamental aspect of incident response from a **governance and legal integrity perspective**. Security managers have to treat **data preservation** as a **multi-stakeholder responsibility**, ensuring that legal, operational, and investigative standards are upheld.

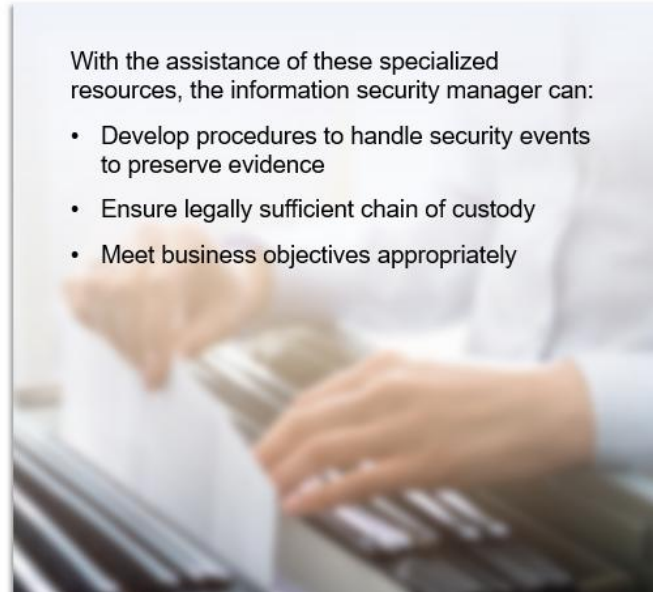
Data and Evidence Preservation Considerations

The information security manager should develop data preservation procedures with the advice and assistance of:



With the assistance of these specialized resources, the information security manager can:

- Develop procedures to handle security events to preserve evidence
- Ensure legally sufficient chain of custody
- Meet business objectives appropriately



Who Should Be Involved

The Information Security Manager must **not act in isolation** when developing evidence preservation procedures. Instead, collaboration with the following roles is essential:

Considering all that needs to happen to preserve evidence, the information security manager should develop data preservation procedures with the advice and assistance of:

1. Legal Counsel

- Ensures preservation procedures support **legal admissibility** and **attorney-client privilege**.
- Helps distinguish **privileged vs. non-privileged investigations**.

- Provides guidance on **local regulatory compliance** (e.g., GDPR, HIPAA, CCPA).

2. Enterprise Management

- Aligns data preservation with **strategic business objectives** and **risk appetite**.
- Authorizes resource allocation and **defines escalation paths**.
- Supports policy enforcement across business units.

3. Law Enforcement Officials

- Advises on procedures that **preserve evidentiary integrity** for possible criminal investigation.
- Informs chain-of-custody practices and may request **preserved digital artifacts**.
- May offer guidance for coordination with national or international agencies (e.g., FBI, CERT-IN, Europol).

What the IS Manager Achieves

With assistance from these stakeholders, the **Information Security Manager** should ensure the following outcomes

1. Develop Procedures to Handle Security Events

Develop procedures to handle security events in a manner that preserves evidence

- Clearly document how evidence is:
 - Identified
 - Collected
 - Preserved
 - Stored
- These procedures must be:

- Repeatable
- Tested
- Auditable

2. Ensure Legally Sufficient Chain of Custody

- Every person who touches the evidence must be **accounted for**.
- Documentation must include:
 - Date/time of collection
 - Method of collection
 - Who collected it
 - Where it's stored
- Any break in this chain can **invalidate evidence in court**.

3. Meet Business Objectives appropriately

- Ensure that legal or forensic obligations don't **disrupt core operations unnecessarily**.
- Develop procedures that balance:
 - **Speed of recovery**
 - **Forensic soundness**
 - **Regulatory and reputational protection**

Insight:

"Failing to preserve evidence correctly can lead to missed prosecution opportunities, regulatory penalties, or even lawsuits."

Pro Tip:

- Who should be consulted **first** when drafting evidence handling procedures?
- What is the role of **chain of custody** in incident response?

Answer: **Legal counsel** – to ensure all evidence is handled in accordance with admissibility standards and enterprise risk.

Legal Aspects of Forensic Evidence

Emphasizes that **handling evidence in a legally defensible manner** is not optional—it's essential for both internal accountability and external legal scrutiny.

Legal Aspects of Forensic Evidence

Objective:

To ensure **evidence is admissible in legal proceedings**, the **Information Security Manager** must:

- Define and document **standardized procedures** for evidence handling.
- Guarantee all evidence is **forensically sound**—untainted, authentic, and complete.
- Maintain an **unbroken, verifiable chain of custody**.

Key Responsibilities of the IS Manager:

1. **Establish Forensically Sound Procedures:**
 - Collection must avoid **modifying metadata or content**.
 - Use write blockers, validated tools, and proper imaging methods.
2. **Ensure Chain of Custody Is Intact:**
 - Every access or transfer of evidence must be logged, timestamped, and signed.
 - Prevents tampering accusations or legal disqualification.
3. **Documentation is Your Defense:**

- Without documentation, evidence is **legally useless**, even if technically valuable.

Required Documentation:

Document	Purpose
Chain of Custody Forms	Tracks who handled the evidence, when, why, and how.
Activity Logs/Checklists	Detailed logs ensure repeatability and accountability of acquisition steps.
Nondisclosure/Confidentiality Agreements	Protects sensitive information from leaking during investigations.
Case Log	Timeline of investigation activities. Helps in legal defense and internal reviews .
Investigation Report Templates	Ensure consistency and inclusion of legally relevant facts in reports.

- To ensure evidence is admissible in legal proceedings, the information security manager should establish and document procedures to handle evidence.
- It is important this evidence is acquired in a forensically sound manner while maintaining documented chain of custody.
- The required documentation to maintain legally admissible evidence must include:
 1. Chain of custody forms that include:
 - Name and contact information of custodians
 - When, why and by whom an evidence item was acquired or moved

- Detailed identification of the evidence (serial numbers, model information, etc.)
 - Where it is stored (physically or logically)
 - When/if it was returned
- 2. Checklists for acquiring technicians (including details of legally acceptable forensic practices)
- 3. Detailed activity log templates for acquiring technicians
- 4. Signed nondisclosure/confidentiality forms for all technicians involved in recovering evidence
- 5. An up-to-date case log that outlines:
 - Dates when requests were received
 - Dates investigations were assigned to investigators
 - Name and contact information of the investigator and requestor
 - Identifying case number
 - Basic notes about the case and its requirements and completed procedures
 - Date when completed
- 6. Investigation report templates that include:
 - Name and contact information of investigators
 - Date of investigation and an identifying case number
 - Details of any interviews or communications with management or staff regarding the investigation
 - Details of devices or data that were acquired (serial numbers, models, physical or logical locations)
 - Details of software or hardware tools used for acquisition or analysis (must be recognized forensically sound tools)
 - Details of findings including samples or copies of relevant data and/or references to their storage location
 - Final signatures of investigator in charge

Advice:

“Your technical tools won’t protect your organization in court—your documentation will.”

- Understand **what makes evidence admissible**.

- Know how to **maintain chain of custody**.
 - Be able to identify **key documentation required** for forensic integrity.
-

Evidence Requirements and Actions

Key Message:

The **Information Security Manager (ISM)** must ensure that **evidence remains intact and admissible** for potential legal or internal disciplinary actions.

Critical Risks to Evidence Integrity:

1. Overwrite

- Rewriting sectors on the disk can permanently erase critical logs or malicious payloads.
- Even automated tasks (like OS background services) can overwrite volatile data if the system is left running.

2. Delete

- Deletion without forensic tools **does not guarantee erasure** but can destroy metadata crucial for understanding sequence and timing of events.
- Some deletions also wipe registry entries, browser caches, or temp files essential to timeline reconstruction.

3. Contaminate

- Introducing new tools, logging into compromised accounts, or running scans **modifies timestamps and introduces noise** into evidence.
- This makes it difficult to distinguish attacker activity from investigator actions.

Legal and Forensic Best Practices for IS Managers:

Principle	Practical Guidance
-----------	--------------------

Preserve First	Disconnect the power only if instructed by law enforcement or if there's risk of volatile data loss.
Minimize Access	Avoid logging in or running diagnostics unless under guidance from forensic experts.
Document Every Action	Track time, personnel, and steps taken once the compromise is discovered.
Chain of Custody	Ensure documentation from the moment evidence is identified through every stage of handling and storage.

More Insight

The Information security manager should understand that:

- Any evidence contamination could prevent the ability to prosecute, limiting options.
- In addition, the modification of data can inhibit computer forensic activity necessary to identify the perpetrator and all the changes and effects resulting from an attack. It may also preclude the possibility of determining how the attack occurred and how the security program should be changed and enhanced to reduce the risk of a similar attack in the future.
- Law enforcement typically recommends disconnecting power to a computer that was compromised to maximize evidence preservation on the hard disk.

This approach is based on the risk of the evidence being compromised.

Compromise can occur as a result of the system swap files overwriting evidence or an intruder or malware erasing evidence of compromise. There is also the risk of contaminating evidence. Because the best approach is subject to controversy, the information security manager will need to establish the most appropriate approach for the enterprise and train personnel in the appropriate procedures.

Important Notes:

- **Any contamination = potential legal disqualification.**
 - **Powering off** the system is often better than letting it run (which may trigger attacker cleanup scripts).
 - IS managers should **train staff** to treat incidents as potential criminal matters.
-

Data and Evidence Preservation Actions

Best Practices in Evidence Preservation

Purpose:

- Ensure incident-related data is preserved **without contamination**, enabling defensible, auditable investigations that hold up in court or regulatory review.
- Whichever procedure is used to secure a compromised system, trained personnel must use forensic tools to create a bit-by-bit copy of any evidence that may exist on hard drives and other media to ensure legal admissibility.

To avoid the potential of alteration or destruction of incident-related data:

Step-by-Step Actions:

1. **Use a Write-Protect Cable**

- Prevents accidental alteration or write operations during imaging.
 - Ensures the **original evidence remains untouched** throughout the analysis lifecycle.
2. **Calculate and Compare Hash Values for the original and copy to ensure an exact match.**
- Generate hash (e.g., SHA-256) before and after imaging to **validate data integrity**.
 - A mismatch indicates alteration and invalidates the evidence.
3. **Perform Testing or Analysis on the Copy Only, never the original**
- Never conduct analysis on the original media.
 - Analysis includes: malware behavior, log review, data recovery, etc.
4. **Deliver the Original to a Designated Evidence Custodian to safety store**
- Storage must be secure, controlled, and access must be **logged and restricted**.
 - Often this role falls to the legal or compliance function.
5. **Maintain Chain-of-Custody Documentation for admissibility in court**
- Record every transfer, handler, timestamp, and condition.
 - This log is **critical in legal proceedings** to prove evidence authenticity.

Takeaways:

Governance Principle	Applied Action
Accountability	Assign roles for evidence handling (custodian, investigator).

Integrity	Use cryptographic hashes to confirm no tampering.
------------------	---

Business Impact and Continuity

Business impact is a major concern for incident management. Understanding what systems, processes and assets are critical as opposed to those that can wait depend on the enterprise requirements. This informs not just incident management but also business continuity efforts

Business Impact Analysis (BIA) Overview -

BIA:

Purpose of BIA:

Business impact is a major concern for incident management

Business Impact Analysis is a **proactive planning process** used to identify **critical business functions**, assess the **impact of disruptions**, and **prioritize recovery** to reduce business downtime and financial loss.

A business impact analysis is a business function designed to:

- Identify the resources that are most important to an enterprise,

- The impact resulting from disruption or availability loss,
- And understand the enterprise process flows needed to optimize recovery priorities based on system dependencies and interdependencies.
- When conducted properly, a BIA facilitates understanding the amount of potential loss (and various other unwanted effects) that could occur from certain types of events, including direct financial loss and less tangible types of loss, such as reputational damage or failure to achieve regulatory compliance

Key Elements:

1. **Identify Critical Enterprise Resources**
Focus is on assets, people, processes, and technologies essential to operations.
2. **Outline Impact of Disruptions**
Quantify the effects of lost availability: revenue loss, legal risk, safety concerns, or customer dissatisfaction.
3. **Understand Process Flows**
Identify **dependencies** and **interconnectivity** to avoid recovery gaps.
4. **Facilitate Understanding of Potential Loss**
Drives **executive awareness**, promotes buy-in for recovery investments, and informs decision-making.

A BIA should

- •Determine the loss of an enterprise resource resulting from a function being unavailable.
- •Establish the escalation of that loss over time.
- •Identify the minimum resources needed for recovery.
- •Prioritize the recovery of processes and supporting systems.

Sequential BIA Flow:

1. **Determine Loss**
Assess **quantitative (financial)** and **qualitative (reputational, compliance)** impacts from disruptions.
2. **Establish Loss Escalation**
Define **time-based thresholds** (e.g., RTO/RPO) for escalating recovery actions or

activating alternate sites.

3. **Identify Resources Needed**

Understand **staff, technology, suppliers**, and **data** dependencies for each function.

4. **Prioritize System and Process Recovery**

Rank recovery efforts based on **criticality, impact, and resource availability**.

Principle	Application in BIA
Risk Assessment	Evaluates impact of process failure
Business Alignment	Connects IT priorities to business drivers
Incident Response Preparedness	Enables structured recovery prioritization
Resource Allocation	Justifies investment in controls and recovery tools

BIA Goals

The **core Goals of Business Impact Analysis (BIA)** —

BIAs have three primary goals

Understanding BIA Goals

1. Criticality Prioritization

- Every critical business unit process must be identified and prioritized.
- The impact of an incident must be evaluated—the higher the impact, the higher the priority.

- **Purpose:** Determine which business processes are essential to survival and recovery.
- **Actions:**
 - Identify and rank **critical business unit processes**.
 - Evaluate the **impact of incidents** (financial loss, regulatory fines, customer churn, etc.).
- **Why it matters:** It ensures that the **most vital operations are recovered first**, in alignment with business priorities.

2. Downtime Estimation

- The assessment is also used to estimate the maximum tolerable downtime (MTD) or maximum tolerable outage (MTO) that the business can endure and still remain viable.
- This can also mean the maximum period of time that a system can be unavailable before compromising the achievement of the enterprise's business objectives (i.e., the acceptable interruption window [AIW]).
- **Purpose:** Understand how long a process can be unavailable before unacceptable consequences occur.
- **Key Metrics:**
 - **MTD** (Maximum Tolerable Downtime): Maximum time a business function can be disrupted before severe impact.
 - **MTO** (Maximum Tolerable Outage): Similar to MTD, used in IT context.
 - **AIW** (Acceptable Interruption Window): Duration for which a process can be unavailable without causing harm.
- **Why it matters:** Guides setting **RTOs (Recovery Time Objectives)** and supports planning for failover or backup procedures.

3. Resource requirements Identification

- Resource requirements for critical processes are also identified at this time.

- The most time-sensitive and highest-impact processes receive the highest priority for resource allocation.
 - **Purpose:** Ensure critical functions have the resources needed for continuity and recovery.
 - **Includes:**
 - Human resources
 - Infrastructure and systems
 - Data and applications
 - External dependencies (vendors, cloud services, etc.)
 - **Why it matters:** Enables targeted investment and prioritizes time-sensitive, high-impact processes.
-

Communicating Impact Details

- Determine range of severity regarding the enterprise to provide information needed and guide risk management activities
- Consider high probability events with low impact to the larger system
- Perform a small set of scenarios with key stakeholders to determine a potential range of outcomes
- Define quantitative distribution of impact magnitudes including values and confidence level
- Use defined values as inputs to perform quantitative and qualitative analysis to describe impacts and aid comparison

Communicating Impact Details – Key Practices and Relevance

1. Determine Range of Severity

- **Why:** Helps risk managers understand **how bad things can get** — from minor disruptions to enterprise-threatening events.
- **Impact:** Supports **risk prioritization** and informed decision-making.

2. Consider High-Probability, Low-Impact Events

- **Why:** These events may occur often and cause repeated operational friction.
- **Example:** System performance lags or minor outages — small impact individually, but significant **cumulative risk**.
- **Impact:** Encourages a **balanced view**, not just focusing on high-impact disasters.

3. Scenario-Based Assessment with Stakeholders

- **Why:** Enables realistic and **context-rich understanding** of potential business disruption.
- **What to do:** Collaborate with department heads to create “**what-if**” scenarios.
- **Impact:** Builds consensus on **impact tolerance** and required controls.

4. Define Quantitative Impact Distribution

- **What it means:** Assign **numerical values and confidence levels** to outcomes (e.g., revenue loss in \$\$, downtime in hours).
- **Why:** Converts subjective assessments into **data-driven insights**.
- **Impact:** Makes impact assessments **repeatable and defensible**.

5. Use Defined Values in Impact Analysis

- **Purpose:** Combine **quantitative and qualitative inputs** to compare risks across business units.
- **Method:** Use scoring models, heat maps, or matrices to aid **impact communication**.
- **Impact:** Facilitates **executive-level reporting** and helps justify budget or control decisions

In addition to a BIA, other methods may be used to determine potential impact and better communicate details to management.

- Because impact is the bottom line of risk, determine the range of severity in terms of the enterprise to provide the information needed and guide risk management activities, as discussed in module 2.
- Consider high probability events with little or no individual impact by understanding the role that event has within the larger system it supports.
- Perform a reasonably small set of scenario analyses with key stakeholders, where a range of potential outcomes is determined.
- This range of outcomes is then used to define a quantitative distribution of impact magnitudes, including minimum, maximum and most likely, including values and a confidence level.

These values can then be used as inputs to quantitative (e.g., Monte Carlo simulations to determine probability distribution) and qualitative analysis methods that more accurately describe for management the real impact potential. This closely resembles the type of impact data that management receives from other business risk domains (e.g., investment, marketing, credit). This alignment improves management's ability to make a consistent comparison and well-informed risk decisions

Elements of BIA

(Business Impact Analysis) breaks down the essential steps an enterprise should follow to understand and prioritize recovery needs.

Understanding the Elements of BIA (Business Impact Analysis)

BIA is a foundational component of **risk management** and **incident response planning**, supporting **Domain 4: Incident Management**. Its goal is to assess the consequences of disruption and guide continuity priorities.

The way in which BIAs are conducted varies between enterprises. This effort needs to consider not only the system being reviewed, but also the restoration of all required dependencies the system relies upon.

Business Context Identification

These activities focus on **understanding the business landscape**:

1. **Describe business mission of each business/cost center**
 - Establishes why the function exists and how it supports organizational goals.
2. **Identify functions that characterize each business function**
 - Helps isolate what **must continue** vs. what **can wait**.
3. **Determine dependencies such as required inputs from other operations**
 - Maps interdependencies; helps avoid domino failures.
4. **Determine subsequent operations dependent on the function**
 - Supports understanding of **process chains** and impact propagation.
5. **Identify critical processing cycles (in time intervals) for each function**
 - Captures time sensitivity, such as payroll, invoicing, etc.
6. **Estimate impact of each type of incident on business operations**
 - Determines **financial, reputational, operational** impact per scenario.

Recovery Planning Inputs

These support **resilience design** and recovery strategy:

1. **Determine required recovery time (RTO)**
 - RTO defines **how quickly a process must resume** after disruption.
2. **Identify resources and activities required to restore operating levels**
 - Specifies what is needed: staff, systems, facilities, etc.
3. **Determine amount of data that can be lost and must be re-created**
 - Relates to **Recovery Point Objective (RPO)**.
4. **Determine work-around possibilities**
 - Encourages flexibility in continuity planning (e.g., manual processes).
5. **Estimate amount of time that recovering could take relative to RTO**
 - Tests feasibility: can recovery occur **within the RTO**?

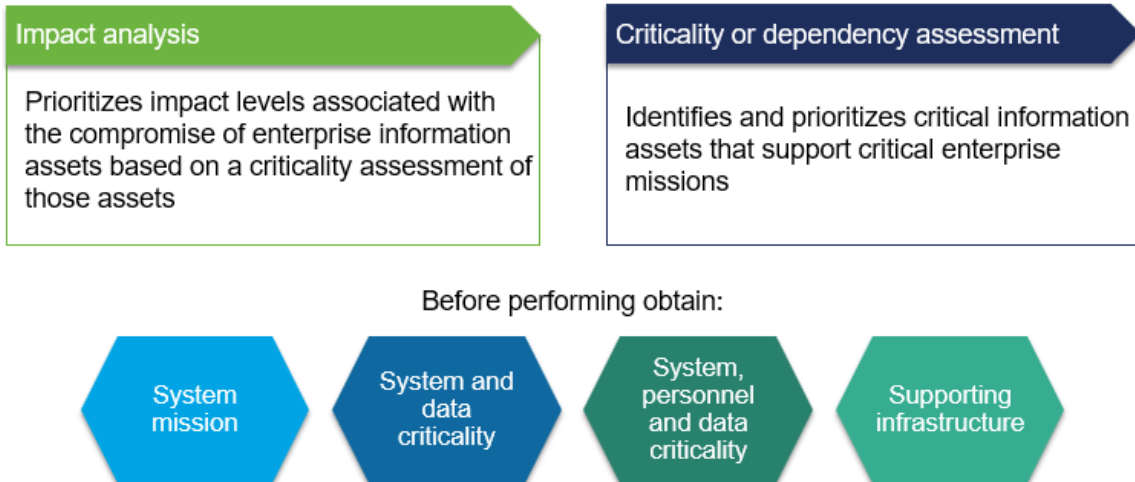
More Insights

In general, BIAs :

- Describe the business mission of each particular business/cost center
 - Identify the functions that characterize each business function
 - Determine dependencies such as required inputs from other operations
 - •Determine subsequent operations dependent on the function
 - Identify critical processing cycles (in terms of time intervals) for each function
 - Estimate the impact of each type of incident on business operations
 - Determine required recovery time (i.e., RTO)
 - Identify the resources and activities required to restore an acceptable level of operation
 - Determine the amount of data that can be lost and must be re-created to determine RPOs
 - Determine work-around possibilities, such as manual or PC-based operation or workload shifting
 - Estimate the amount of time that recovering from each type of incident is likely to take in relation to the RTO. If the estimated time is greater than the RTO, additional resources may be needed to ensure recovery objectives are met or revisited to validate business need.
-

Performing Asset Analysis

Performing Asset Analysis



1. Impact Analysis

- **Purpose:** To assess and prioritize the **impact levels** associated with a compromise of information assets.
- **Key Point:** This is **impact-focused** and depends on a **criticality assessment** of the assets.
- **Why it matters:** Helps identify where loss or disruption would cause the most damage to the enterprise.

Example:

If a database holding customer financial records is compromised, the impact (legal, reputational, operational) could be high.

2. Criticality or Dependency Assessment

- **Purpose:** To **identify and prioritize** assets based on their role in supporting **critical enterprise functions**.
- **Key Point:** This step answers, *"What processes depend on this asset?"*

- **Why it matters:** Without knowing dependencies, risk mitigation and continuity planning may overlook hidden single points of failure.

Example:

An authentication server may not seem critical—but if all systems rely on it for login, its criticality is immense.

Before Performing Asset Analysis, Collect These Inputs:

1. **System mission:**
Understand what the system is designed to support.
Helps align analysis with business value.
2. **System and data criticality:**
Assess the sensitivity, confidentiality, and availability needs.
Key to determining **security classification** and **protection level**.
3. **System, personnel, and data criticality:**
Go beyond technical assets—evaluate the human and data elements.
Example: Specialized personnel with tribal knowledge.
4. **Supporting infrastructure:**
Include physical, cloud, and network layers that enable the system.
Helps identify **hidden dependencies** in power, cooling, hosting, or bandwidth.

More Insights

- A mission impact assessment and analysis or BIA:
 - Prioritizes the impact levels associated with the compromise of an enterprise's information assets based on a qualitative or quantitative assessment of the criticality of those assets.
- An asset criticality or resource dependency assessment
 - Identifies and prioritizes the critical information assets (e.g., hardware, software, systems, services and related technology assets) that support the enterprise's critical missions.
- Before beginning the impact analysis of a specific set of assets, it is necessary to obtain information such as:
 - System mission (e.g., objectives of the processes performed by the IT system or personnel)

- System (manual or technical) and data criticality (e.g., the system's value or importance to an enterprise)
- System, personnel and data criticality (the impacts associated with unintended disclosure)
- Supporting infrastructure (what the system relies upon to operate as planned)
- If this documentation does not exist or such assessments for the enterprise's information assets have not been performed, the system and data sensitivity can be determined based on the level of protection required to maintain the availability, integrity and confidentiality of the system and data.

Perspective:

Asset analysis is foundational to risk analysis and controls selection. :

- Link **information assets** to **business objectives**
 - Justify **risk treatments**
 - Inform **BIA** and **incident response planning**
-

Analyzing Enterprise Information

Objective:

This emphasizes how analyzing enterprise information is a critical step in supporting **incident response planning (IRP)**, **disaster recovery planning (DRP)**, and **business continuity planning (BCP)**—all key domains in ISACA's **Domain 4: Incident Management** and **Domain 2: Risk Management**.

Analysis Provides:

1. **Detailed workflows, dependencies, and interdependencies:**

- These are used to **prioritize restoration efforts** during or after an incident.
- Helps determine **which systems must be restored first** based on business process impact.
- Ensures alignment of IT restoration with **business priorities**.

2. **Information about restoration and emergency operation options:**

- Includes **contingency procedures, manual workarounds, or redundant systems**.
- Ensures the enterprise can continue **critical functions** even during failures.

3. **Essential information to develop IRP, DRP, BCP:**

- Acts as the **foundation** for response and recovery plans.
- Provides the context needed to design **effective, actionable** plans tailored to enterprise needs.

Collecting and analyzing information for all significant functions across an enterprise can:

- Provide a detailed picture of workflows, dependencies and interdependencies
- Determine options for the required order of restoration efforts (i.e., resources dependent on other functions require the restoration of those functions before they can be operational).
- Provide information on restoration and emergency operation options (critical timing, options for workarounds or other operational choices) in the event of function failure and
- Provide essential information needed to develop effective IRPs, DRPs and BCPs.

Key Data to Obtain:

To perform effective enterprise information analysis, the IS manager should gather the following:

Element	Purpose
---------	---------

Function description	Understand what each business function does
Dependencies	Identify what systems, people, or processes each function relies on
Impact profile	Determine consequences of disruptions (financial, reputational, legal)
Operational impacts	Analyze how downtime affects day-to-day operations
Financial impacts	Calculate cost of service disruptions or delays
Work backlog	Measure accumulated work during outages
Recovery resources	Assess tools, systems, and people required to restore services
Technology resources	Inventory IT assets and recovery systems
Business records	Track obligations, contracts, and operational data
Regulatory reporting	Identify compliance obligations post-incident (e.g., breach reporting under GDPR, HIPAA)

A typical BIA includes obtaining the information from the enterprise's functional units such as:

- Function description: What is the function of the business unit?
- Dependencies: What is dependent upon this function? What must happen or needs to be available before the function can be performed?

- Impact profile: Is there a specific time, day, week or month that the function would be more vulnerable to risk/exposure or the impact to the business would be greater if the function is not performed?
- Operational impacts: When would operational impact to the business be realized if the function was not performed?
- Financial impacts: When would financial impact to the business be realized if the function was not performed?
- Work backlog: At what point will the backlog of work start to impact the business?
- Recovery resources: What kind of resources are needed to support the function, how many are needed and how soon are they needed after a disruption (e.g., phones, desks, PCs)?
- Technology resources: What software and/or applications (both internally and externally provided) are needed to support the function?
- Business records: Are there business records needed to perform the function and, if so, are they backed up? How? With what frequency?
- Regulatory reporting: Are regulatory documents created as a result of the function?

Insight:

Without thorough analysis of enterprise information, response and recovery plans will be incomplete or misaligned with actual business needs. Effective analysis bridges the **gap between IT capabilities and business expectations**.

This is a **risk-informed process** that supports **business impact analysis (BIA)**, and must be **continually updated** to reflect changes in processes, systems, and regulations.

Describing Adverse Impacts

Core Message:

This highlights the **types of harm** that can result from an incident involving **loss or degradation of confidentiality, integrity, availability, or safety**—core tenets of the **CIA triad** plus operational safety.

This aligns directly with **Domain 2: Risk Management** and **Domain 4: Incident Management**, particularly in the assessment of risk impact and the prioritization of security objectives.

Confidentiality

- **Impact:**
 - **Jeopardizing national security:** Especially relevant in government, defense, and critical infrastructure.
 - **Disclosure of private data:** PII, PHI, PCI, and intellectual property (IP) breaches are common.
- **Results:**
 - **Loss of public trust or customer base:** Once trust is eroded, customer churn and reputational damage follow.
 - **Legal action:** Regulatory violations (e.g., GDPR, HIPAA, CCPA) lead to fines and lawsuits.

Insight: Protecting confidentiality is often a **compliance-driven** requirement. The risk manager must map data classifications to legal/regulatory obligations.

Integrity

- **Impact:**
 - **Unauthorized or erroneous changes** to systems or data: These could be due to internal mistakes or malicious tampering.
- **Results:**
 - **Broader errors or cascading corruption** across dependent systems or business processes over time.

Insight: Integrity issues are often **less visible initially** but can be **catastrophic**. For example, corrupted financial records may go undetected until audits or regulatory checks reveal them.

Availability

- **Impact:**
 - **Loss of productive time** due to system or process unavailability.

- **Results:**
 - **Impeded mission performance:** Downtime disrupts operations, harms service levels, and could delay revenue or impact critical services.

Insight: Availability is often prioritized in **operational risk scenarios** like DDoS attacks, natural disasters, or system failures—particularly in time-sensitive industries like healthcare, finance, and manufacturing.

More Insights

The adverse impact of a security event can be described in terms of loss or degradation including combination of loss of confidentiality, integrity, availability and safety.

- **Loss of confidentiality:** refers to the protection of information from unauthorized disclosure.
 - Impact examples
 - Jeopardizing of national security
 - Disclosure of private consumer data.

Which result in

- Loss of public confidence or customer base
- Legal action against the enterprise
- **Loss of integrity**—System and data integrity refers to the requirement that information be protected from improper modification.
 - Integrity is lost if unauthorized or erroneous changes are made to the data or IT system by either intentional or accidental acts.
 - If the loss of system or data integrity is not corrected, continued use of the contaminated system or corrupted data could result in broader corruption, fraud or misinformed decisions.
 - Also, violation of integrity may be the first step in a successful attack against system availability or confidentiality.
- **Loss of availability**—If a mission-critical IT system or process is unavailable to its end users, the enterprise's mission may be affected.
- Loss of system functionality and operational effectiveness, for example, may result in loss of productive time, thus impeding the end users' performance of their functions in supporting the enterprise's mission.

A loss or degradation, or a combination of loss of confidentiality, integrity, availability and safety

Confidentiality

Impact:

- Jeopardizing national security
- Disclosure of private data

Results:

- Loss of public confidence or customer base
- Legal action

Integrity

Impact:

- Unauthorized or erroneous changes made to data or systems

Results:

- Broader errors or corruption over time

Availability

Impact:

- Loss of productive time

Results:

- Impedance of function performance in support of enterprise mission

Guidance:

To effectively **quantify and communicate risk**, you must **connect these impacts to business objectives**. It's not just a loss of data or uptime—it's a **loss of trust, revenue, legal standing, or operational viability**.

Qualitative vs Quantitative Assessments.

Here's a detailed interpretation.

Qualitative vs Quantitative Risk Assessments

This effectively differentiates between two fundamental **risk assessment methodologies** that an information security manager must master when building or evaluating an information security risk management program (aligned with **Domain 2: Risk Management**).

Qualitative Assessment

Definition:

Subjective, experience-based evaluation of risk **without numeric precision**.

Key Points:

- **Subjective** inputs from SMEs, managers, and stakeholders.
- Uses **ordinal scales** (e.g., high, medium, low).
- Best for identifying **areas requiring urgent attention**.
- Highly influenced by **assessor's context**, such as role or visibility within the enterprise.

Insight:

Qualitative assessments are widely used during initial risk triage, especially when time, data, or resources for detailed analysis are limited. They enable rapid decision-making but **lack rigor** for budget justification or insurance alignment.

Quantitative Assessment

Definition:

Objective analysis based on **measurable data** such as probability, financial loss, or downtime.

Key Points:

- Relies on **statistics, historical data, and models** (e.g., $SLE \times ARO = ALE$).
- Useful in **cost-benefit analyses** and comparing **risk treatments**.
- Can be **time-consuming** and requires **robust data**.
- Less subjective; results can be communicated to **executives and CFOs** effectively.

More Insights

In conducting an impact analysis, consideration should be given to the advantages and disadvantages of quantitative versus qualitative assessments.

Qualitative: Subjective valuations based on expert opinion and provided as ordered values (high, medium or low)

- The main advantage of the qualitative impact analysis is that it prioritizes the risk and identifies areas for immediate improvement in addressing the vulnerabilities.
- One disadvantage of qualitative analysis is that it does not provide specific quantifiable measurements of the magnitude of the impacts, therefore making a cost-benefit analysis of any recommended controls difficult.
- Qualitative results are also context-dependent, so that what someone at one level rates "high" (such as total loss of a business process) may be "low" when

viewed from a more senior position in the organization (where that process may play a small role in overall production).

- Interpretation depends on the context of the assessor (e.g., level within the organization)

Quantitative: Objective valuations based on statistics, replacement cost, and other mathematically valid measurements

- The major advantage of a quantitative impact analysis is that it provides a measurement of the impacts' magnitude, which can be used in the cost-benefit analysis of recommended controls.
- Additional factors must also be considered to determine the magnitude of impact, such as the range of possible errors in estimation or computations.
- The disadvantage of quantitative assessment is that it can be hard to calculate probabilities and dollar values, especially if historical data is not readily available



Insight:

Quantitative assessments offer **defensible, audit-friendly** results. They are ideal when prioritizing risk treatments by ROI, choosing insurance coverage, or justifying capital investments in controls.

Recommendation:

Security managers should use a **hybrid approach**:

- Use **qualitative assessments** to identify risk hotspots or conduct initial assessments.
 - Use **quantitative methods** to justify control investments and drive board-level risk discussions.
-

Conducting Business Impact Analysis (BIA)

The BIA is foundational to any **business continuity or incident response program**. Its purpose is to identify critical processes, evaluate the potential impact of disruptions, and inform continuity strategies.

This breaks BIA into three structured phases:

1. Gather Assessment Material

“Begin with understanding what’s critical to keep the business alive.”

Key Activities:

- Identify **critical business units** (e.g., finance, operations, IT).
- Drill down to **essential tasks and processes** needed for **minimum viable operations**.
- Determine **resources** (people, systems, vendors) that enable these operations.

Insight:

A successful BIA **must be stakeholder-driven**. Information security managers should work closely with business unit leaders to gain insight into **process criticality** and **dependencies**.

2. Analyze Compiled Information

“The core analytical phase of the BIA—turning data into actionable risk intelligence.”

Key Activities:

- Map **function interdependencies** and **cross-functional workflows**.
- Identify **disruptions** (natural, cyber, supply chain, human error)
- Document **threats** and vulnerabilities.
- Use both **qualitative** (e.g., SME opinions) and **quantitative** (e.g., estimated financial losses) inputs.
- Explore **alternative restoration methods**.
- Justify decisions with a **brief rationale statement**.

Insight:

This phase must tie back to **organizational risk appetite and tolerances**—such as RTO (Recovery Time Objective) and MTD (Maximum Tolerable Downtime). Link threats to business drivers for executive clarity.

3. Document Results and Present Recommendations

“The output must drive action and funding.”

Key Activities:

- Translate findings into a **clear report** for stakeholders.
- Outline **prioritized recommendations** to enhance resilience.
- Enable decision-makers (C-suite, risk committee) to allocate **resources**.

Insight:

Effective documentation ensures the BIA **informs not only recovery planning**, but also **incident response strategies, risk mitigation budgeting, and security control justification**.

More Insights

An assessment includes the following activities:

Gathering assessment material—

- Identify which business units are critical to an enterprise.
- Drill down to the critical tasks that must be performed and the resources needed to ensure business survival.

Analyzing compiled information — During this phase, several activities take place, such as documenting required processes and resources, identifying interdependencies and determining the acceptable period of interruption. Tasks in this phase include:

- Identify interdependencies among the functions and departments classified as critical or high impact.
- Discover all possible disruptions that could affect the mechanism necessary to allow these departments to function together.
- Identify and document potential threats that could disrupt interdepartmental communication.
- Gather quantitative and qualitative information pertaining to those threats.
- Provide alternative methods of restoring functionality and communication.
- Provide a brief statement of rationale for each threat and corresponding information.
- Documenting the result and presenting recommendations—
- Documenting assessment results from the previous activities
- Creating a report for business units and senior management.

Final Advice:

- **Link BIA outputs** directly to your incident response and continuity planning.
 - Use the results to **quantify risk** and secure **management buy-in**.
 - Reassess regularly, especially after mergers, regulatory changes, or incidents.
-

Benefits of Conducting a BIA (Business Impact Analysis)

A **Business Impact Analysis (BIA)** is a foundational activity that enables an enterprise to understand **what is most critical**, **how much impact a disruption could cause**, and **what must be prioritized for recovery**.

This highlights four key benefits:

1. Increased Understanding of Potential Loss Amounts and Undesirable Effects resulting from the loss of a particular function

"What could we lose, and how bad could it be?"

Explanation:

- Quantifies potential **financial, reputational, legal, or operational** loss.
- Helps in **scenario modeling** for varied impact durations and severities.
- Forms the basis for setting **risk appetite** and **tolerance thresholds** (e.g., MTD – Maximum Tolerable Downtime).

Tip:

Understanding loss values is crucial for **risk-based decision making** and justifying investments in continuity and recovery controls.

2. Prioritized List of Restoration Activities and Understanding Recovery Options

"What do we recover first—and how?"

Explanation:

- Guides **incident response and disaster recovery planning**.
- Identifies **mission-critical processes**, systems, and dependencies.
- Helps set **RTOs** (Recovery Time Objectives) and **RPOs** (Recovery Point Objectives).

Tip:

BIA outputs help create recovery tiers and ensure the enterprise can **restore services in a logical, risk-aligned order**.

3. Understanding Dependencies of Various Functions and Their Interdependencies

"No process operates in isolation."

Explanation:

- Maps **interconnected workflows** across departments.
- Identifies **cascading failures** (e.g., if payroll fails, HR and finance are also impacted).

- Informs design of **redundant processes** and **resilient architectures**.

Tip:

This is essential for planning **comprehensive containment strategies** and **avoiding recovery bottlenecks** during incidents.

4. Higher Awareness for Response Management Within an Enterprise

- Raising the level of awareness for response management within an enterprise

"Preparedness begins with awareness."

Explanation:

- Educates business units about **their role in resilience**.
- Enhances stakeholder engagement in **incident response** planning.
- Reinforces the **organizational culture of risk ownership**.

Tip:

A well-conducted BIA fosters **enterprise-wide accountability**, ensuring faster, more coordinated response during real-world disruptions.

Summary:

"A BIA is not just a compliance task—it's a strategic enabler. It converts operational complexity into actionable intelligence that empowers informed risk management and targeted response."

BCP and Contingency Planning

BCP and Contingency Planning

Enterprises setting up a BCP should address the processes needed to:

- Define roles and responsibilities to identify an incident during disaster declaration
- Define processes to restore primary site operations
- Upgrade a cold site to a primary operating facility

Ensure information security is incorporated into response and recovery plans

Review plans to ensure execution does not compromise information security standards and requirements

Information security manager must:

Explore other mitigation options when compromise is unavoidable

Conduct a focused risk assessment to inform management of security risk impacts introduced by plan execution

Purpose of Business Continuity Planning (BCP)

Business Continuity Planning (BCP) is a strategic process ensuring critical business functions can continue or quickly resume during and after a disruption. For an **information security manager**, BCP must **integrate s**

Security requirements into continuity and recovery strategies.

Core BCP Considerations

1. Define Roles and Responsibilities

- Crucial for recognizing **when** to declare a disaster.
- Aligns with **incident detection, escalation protocols**, and authority to initiate the response.

2. Define Processes to Restore Primary Site Operations

- This ensures minimal disruption and efficient **failback** to the original site.
- Involves **recovery sequences, RTO (Recovery Time Objective)** validation, and site restoration planning.

3. Upgrade Cold Sites

- Cold sites need to be periodically **evaluated and upgraded** to ensure they can function as **reliable operational backups**.
- This reflects on **availability controls** under security governance.

Responsibilities of the Information Security Manager

Ensure information security is part of response/recovery plans

- Avoid **security gaps** during continuity efforts (e.g., unpatched recovery systems or exposed backups).
- Embed **access controls, data integrity, encryption** into backup and restore workflows.

Review BCP execution against security standards

- Validate that execution does **not breach policies** or **regulatory compliance** (e.g., GDPR, HIPAA).
- Important for **auditability and legal defensibility**.

Explore mitigation options during unavoidable compromise

- When full prevention fails, develop **alternate controls** (e.g., segmentation, isolation, compensating controls).
- Prepares the organization for **resilient operations under attack**.

Conduct focused risk assessments

- Risk-based approach is vital for **prioritizing limited recovery resources**.
- Helps determine **cost-benefit trade-offs** (e.g., investing in hot site vs. extended downtime).

More Insights

To ensure effective and comprehensive contingency planning, enterprises setting up a BCP should address the processes needed to:

- Define roles and responsibilities to identify an incident when declaring a disaster and managing operations in a disaster mode,
- Define processes to restore operations at the primary site and announce the return to normalcy,
- Upgrade a cold-site to a primary operating facility if the incident renders the primary facility useless.

Information resources must still be protected during business interruption or disaster. The information security manager must:

- Ensure that information security is incorporated into all response and recovery plans.
Review plans to ensure execution does not compromise information security standards and requirements.
- Explore other mitigation options when compromise is unavoidable
- Conduct a focused risk assessment to inform management of extent and potential impacts of the security risk introduced by plan execution.

Insight:

“Effective contingency planning doesn’t stop at restoring systems — it ensures continuity without weakening security. A mature information security manager validates that security controls remain enforced, even in crisis mode.”

Planning Process Phases

The **planning process phases** in business continuity and disaster recovery (BC/DR) must follow a **structured and risk-informed sequence**. This highlights that a **Business Impact Analysis (BIA)** and **Risk Assessment** are foundational.

Why BIA First?

Performing a **BIA before BCP creation** is essential because it:

- **Quantifies daily losses** due to system unavailability.
- **Identifies critical systems**, dependencies, and acceptable downtime.
- Guides decision-making on **RTO (Recovery Time Objective)** and **recovery strategy** cost-effectiveness.

Prior to creating a detailed BCP, it is important to perform BIAs to determine the incremental daily cost of losing different systems.

- This provides the basis for deciding on appropriate RTOs and associated costs.
- This, in turn, affects the location and cost of offsite recovery facilities and the composition and mission of individual response and recovery teams, which are key to disaster recovery.

Each of these planning processes typically includes several main phases, including:

Main Planning Phases Explained:

Phase	Commentary
1. Conduct Risk Assessment and BIA	Identify threats, vulnerabilities, and business impact. Ensures the BCP is risk-based and value-driven .
2. Define Response and Recovery Strategy	Choose recovery site types (hot, cold), cloud failover options, manual workaround strategies, etc., based on RTO/RPO and risk tolerance.
3. Document Response and Recovery Plans	Ensure formal, structured, and version-controlled documentation covering all business units. Align with legal/regulatory mandates (e.g., HIPAA, ISO 22301).
4. Train Response and Recovery Teams	Training is not optional. It ensures assigned personnel are aware of their roles during disruption. Must include cross-functional teams.
5. Update Response and Recovery Plans	Reflect organizational changes (e.g., new systems, vendors, facilities). Continuous improvement aligns with Plan-Do-Check-Act (PDCA) cycle.
6. Test Response and Recovery Plans	Simulate real-world incidents (tabletops, functional tests). Validates practicality, timing, and team preparedness.
7. Audit Response and Recovery Plans	Independent review confirms effectiveness, identifies gaps, and ensures compliance. Should be both internal and external as needed.

Insight:

“A recovery plan that hasn't been tested or audited is a liability. CISM professionals must view the planning process as a lifecycle — not a checklist. BIA and risk assessments should be periodically updated to reflect changes in business, threats, and compliance obligations.”

Business Continuity Plan (BCP) Overview

Objective of a BCP:

The primary goal of a BCP is to ensure the enterprise can continue critical operations during and after a disruptive event. It's about resilience, sustainability, and recovery.

Key Elements Explained:

Component	CISM Mentor Insight
Establish capability to continue services/products	A mature BCP enables the organization to meet RTO (Recovery Time Objective) for key services even during system or facility outages.
Reduce and limit overall impact	A proactive BCP reduces financial loss, reputational damage, and regulatory noncompliance . Risk and BIA findings drive this effort.
Develop operational continuity plan	Plans should be clear, role-specific, and actionable. Must include interim procedures, manual workarounds, communication protocols , and escalation criteria.
Consider resources, services, threats	A comprehensive BCP accounts for staffing, supply chain, facility readiness, technology resilience , and risk scenarios like natural disasters, cyberattacks, or pandemics.

Breakdown:

BCP Element	Mentor Commentary
Considers all possible affected enterprise areas	A complete BCP is enterprise-wide. Every critical business unit, IT system, facility, and dependency must be evaluated.
Includes key processes, personnel, assets, and third parties	Don't overlook outsourced services and vendors . Clearly define roles, contact points, and escalation paths for external stakeholders.
Informs DR (Disaster Recovery) development procedures	DRP is a subset of BCP. While DR focuses on IT/system recovery , the BCP addresses broader operational continuity .
Enables enterprise to recover and resume normal operations	This is the ultimate goal of the BCP: to ensure continuity with minimal disruption and graceful return to normalcy .

The ability to work through business disruptions requires the enterprise to:

- Establish the capability to continue delivering their services or products even in a diminished capacity,
- Reduce and limit the overall impact.
- Develop a plan outlining how the enterprise will continue to operate during an unplanned disruption.
- Consider available resources, expected services, and the types, kinds and severity of threats faced by the enterprise.
- The BCP should include a comprehensive set of plans that:
 - Consider every aspect of the enterprise that could be affected during a crisis
 - Includes key processes, personnel, (information and technology) assets along with required third parties.
 - Inform the development of DR procedures, as the enterprise defines and prioritizes critical processes and systems that are absolutely vital to function, even in a diminished capacity,
 - Enable the enterprise to recover and resume normal operations.

Tip:

"A BCP is not a document—it's a **living framework**. professionals must regularly test, update, and train stakeholders on it. Real resilience comes not just from planning, but from **preparedness and execution under pressure**."

Effective Incident Response Integration

Integrating incident response (IR) with business continuity (BC) and disaster recovery (DR) is **critical for minimizing disruption and ensuring a smooth operational transition** during adverse events. This slide outlines the **key integration points** required for an effective and resilient response strategy.

Breakdown of Key Integration Elements:

Element	CISM Insight
Consistency with and support of the overall enterprise IT plan	The IR process must align with the enterprise architecture, IT strategy, and security governance model . Disjointed plans lead to operational gaps and miscommunication.
Integration with BC and DR	Incident response should seamlessly transition into BCP/DRP when predefined escalation thresholds (e.g., impact or duration) are met. This ensures minimal disruption and continuity of operations.
Consideration of RTO, RPO, SDO, and MTO	Integration must reflect clearly defined recovery metrics: - RTO (Recovery Time Objective) - RPO (Recovery Point Objective) - SDO (Service Delivery Objective) - MTO (Maximum Tolerable Outage) These inform prioritization and resource allocation during a crisis.
Transition time from incident response to DR operations	Clear triggers and criteria must exist to shift from IR mode to full disaster declaration and activate the disaster recovery plan . Speed and coordination are crucial here.

Effectively integrating of the incident management and recovery plan with BC and DR functions includes:

- Consistency with and support of the overall IT plan of the enterprise.
- Integrated with BC and DR to provide an effective transition to disaster declaration.
- Careful consideration of the relationships among RTO, RPO, SDO and MTO.
- Transition time from incident response to disaster recovery operations for any solutions (aside from mirrored or duplicate processing sites).

This is important to consider as RTOs, MTOs and AIWs are directly influenced by recovery capabilities. Failure to consider these relationships can result in the inability to achieve target objectives.

Important Advisory Box Explanation:

"RTOs, MTOs and AIWs are directly influenced by recovery capabilities. Failure to consider these relationships can result in failure to achieve objectives."

- **AIW (Alternate Information Workflows)** must be feasible and tested.
- **Resource gaps** (e.g., lack of failover infrastructure) can invalidate RTO/MTO targets.
- Integrating these concepts ensures **plans are achievable, realistic, and aligned with business risk appetite.**

Recommendation:

"Incident Response is not a standalone process. It must be **synchronized with business and IT recovery mechanisms.** Without this integration, even the best IR efforts can fall apart during large-scale disruptions."

Providing Continuity of Network Services

In the realm of **business continuity and disaster recovery**, ensuring **uninterrupted network service** is foundational. As networks underpin nearly all IT and business functions, the organization must adopt multiple strategies to maintain availability during incidents or disasters.

1. Redundancy

Definition: Having backup components and paths that can take over in case of failure.

Strategy	Description
Extra capacity	Overprovisioning network resources to handle failover and peak loads.
Multiple paths between routers	Ensures alternate data routes in case one path becomes unavailable.
Dynamic routing protocols	Enables automatic rerouting of traffic through available paths (e.g., OSPF, BGP).
Failover devices	Backup routers/switches take over automatically during failure.
Saved configuration files	Enables quick restoration of device configurations in a recovery scenario.

Redundancy reduces *mean time to recover (MTTR)* and supports *RTO* targets.

2. Alternative Routing

Definition: Using completely different network infrastructures to route traffic.

Method	Description
--------	-------------

Different circuits or endpoints	Ensure physical path diversity and logical separation.
Carrier fiber-optic options	Utilize high-availability links offered by telecom providers.
Dial-up, cellular, microwave	Emergency alternatives when primary channels are down.

Supports continuity when primary circuits fail — particularly valuable in remote or disaster-affected areas.

3. Diverse Routing

Definition: Using geographically or logically distinct routes or infrastructure.

Practice	Purpose
Split/duplicate cable sheaths	Prevents single point-of-failure in physical infrastructure.
Duplicate facilities	Supports high-availability and fast recovery in case of local failure.
Alternate routing from carrier	Ensure the telecom provider routes via different paths (e.g., two ISPs).

Essential for meeting high-availability SLAs, especially in regulated industries (e.g., finance, healthcare).

This contains extra contextual information. Consider reviewing necessary content in course and referring participants to the CISM manual for more details.

Facilitator Notes:

Methods for providing continuity of network services include:

Redundancy—Achieving redundancy involves a variety of solutions, including:

- Providing extra capacity with a plan to use the surplus capacity should the normal primary transmission capability not be available. In the case of a local area network, a second cable could be installed through an alternate route for use if the primary cable is damaged.
- Providing multiple paths between routers
- Using special dynamic routing protocols such as the Open Shortest Path First (OSPF) and External Gateway Routing Protocol (EGRP)
- Providing for failover devices to avoid single points of failure in routers, switches, firewalls, etc.
- This should include saved configuration files for recovery of network devices, such as routers and switches, if they fail

Alternative routing—Alternative routing means routing information via an alternate medium such as copper cable or fiber optics.

- This involves use of different networks, circuits or end points, if the normal network is unavailable.
- Most local carriers are deploying counter-rotating fiber-optic rings. These rings have fiber-optic cables that transmit information in two different directions and in separate cable sheaths for increased protection. Currently, these rings connect through one central switching office. However, future expansion of the rings may incorporate a second central office in the circuit. Some carriers are offering alternate routes to different points of presence or alternate central offices.
- Other examples include dial-up circuits as an alternative to dedicated circuits, a cellular phone and microwave communications as alternatives to land circuits and couriers as an alternative to electronic transmissions.

Diverse routing—This is the method of routing traffic through split cable facilities or duplicate cable facilities.

- This can be accomplished with different and/or duplicate cable sheaths. If different cable sheaths are used, the cable may be in the same conduit and, therefore, subject to the same interruptions as the cable it is backing up.
- The communication service subscriber can duplicate the facilities by having alternate routes, although the entrance to and from the customer's premises may be in the same conduit.

- The subscriber can obtain diverse routing and alternate routing from the local carrier, including dual entrance facilities; however, acquiring this type of access is time-consuming and costly. Most carriers provide facilities for alternate and diverse routing, although most services are transmitted over terrestrial media. These cable facilities are usually located in the ground or the basement of buildings that house computer equipment. Ground-based facilities are at risk due to the aging infrastructures of cities. In addition, cable-based facilities usually share space with mechanical and electrical systems that can impose risk due to human error and disastrous events.

Summary:

As a best practice, the **Information Security Manager (ISM)** should:

- **Ensure network continuity strategies align with the Business Impact Analysis (BIA).**
 - Work closely with **network engineers, telecom providers, and DR planners.**
 - Include these controls in the **risk treatment plan and response procedures.**
 - **Test alternate and redundant routing paths** during DR/BCP exercises.
-

Providing Continuity of Network Services (Continued)

To support **resilient business operations**, especially during a disaster or carrier failure, the **Information Security Manager** must ensure continuity at **all layers of network infrastructure** — from long-distance backbone circuits to last-mile and telephony systems.

1. Long-haul Network Diversity

Element	Description
High-speed data circuits	Ensure that core enterprise sites (HQ, DR sites, cloud zones) stay connected over wide geographic areas.

Redundant lines / automatic rerouting	Prevents interruption due to backbone carrier outage by rerouting through alternate long-haul routes.
Recovery facility capability	DR/BCP sites must be provisioned with the same redundancy levels — it's a frequent audit failure if they aren't.

Supports enterprise-wide failover strategies, essential for maintaining RTO/RPO during widespread disruption.

2. Last-mile Circuit Protection

Element	Description
Redundant local access	Mix of cable, fiber, or DSL from different providers to ensure local site access continuity.
Critical for facility access	If local loops fail, users can't reach the network even if the core is fine.
Alternate routing by local carriers	Must be tested regularly — sometimes providers offer “redundant” lines that physically converge, nullifying the benefit.

Often overlooked in risk assessments; last-mile failure is a leading cause of prolonged local outages.

3. Voice and Telephony Recovery

Practice	Description
Redundant cabling	Separate physical cables for voice and data, ideally entering from different points.
Alternative routing	VoIP or cloud PBX failover can support continuity if on-prem systems fail.

Avoid consolidation risks	Combining all voice and data over a single infrastructure introduces a <i>single point of failure</i> . Risk must be assessed and mitigated.
----------------------------------	--

Voice systems are often critical for incident response and coordination — ensure they are part of the IR/BCP planning.

More Insights

Methods for providing continuity of network services include:

Long-haul network diversity—Many vendors of recovery facilities provide diverse long-distance network availability.

- High-speed data circuits are used among the major long-distance carriers.
- This ensures long-distance access if any single carrier experiences a network failure.
- Several of the major carriers have now installed automatic rerouting software and redundant lines that provide instantaneous recovery if a break in their lines occurs.
- The information security manager should confirm that the recovery facility has these vital telecommunications capabilities.

Last-mile circuit protection

- Many recovery facilities provide a redundant combination of local carrier high-speed data circuits, microwave and/or coaxial cable access to the local communications loop.
- This enables the facility to have access during a local carrier communication disaster.
- Alternate local carrier routing is also used.

Voice and Telephony recovery— With the increased use of network based voice-over Internet Protocol (VoIP) based telephony, careful attention and consideration needs to be given to those business functions which require high availability and accessibility to telephony services.

- Many service, financial and retail industries dependent on voice communication. Therefore, their recovery plans should provide for redundant cabling and alternative routing for voice and data communication lines. This is especially true when the enterprise is in a time sensitive or provides critical service industry, such as healthcare or emergency services.
- While it may appear cost effective to reduce and consolidate the number of providers to provide both network and telephony over the provider's data circuits, this carries the risk of creating a single point of failure.
- Information security managers should advise to ensure proper diversification of carriers and use of plain old telephone service (POTS) lines to reduce the impact and chances associated with a total communication failure should the data services be interrupted.

Takeaway:

The Information Security Manager (ISM) must:

- Include **network service continuity** in the **BCP/DRP design and review cycles**.
- Engage with **telecom, infrastructure, and risk teams** to ensure network SLAs and redundancy configurations meet business impact expectations.
- Evaluate **third-party telecom risk** during BIA and vendor assessments.
- Conduct **regular failover testing** for long-haul and last-mile scenarios.

High-Availability Considerations

Why High Availability Matters:

High-availability (HA) strategies are essential to **minimize disruption** to critical business processes and services. The **Information Security Manager (ISM)** must ensure that business continuity and disaster recovery plans include HA considerations, particularly for systems managing **sensitive data** or **mission-critical workloads**.

Planning Requirements

Plan Component	Purpose	
Operational failover methods	Ensures automatic or semi-automated switching to backup systems, minimizing downtime. Examples: active-passive clustering, load balancers, DNS failover.	
Server recovery	Procedures to restore physical or virtual servers quickly using backups, snapshots, or replication mechanisms.	
Data storage options	Redundancy and scalability are key. Choose storage types based on availability needs and recovery objectives.	

HA planning must support both RTO (Recovery Time Objective) and RPO (Recovery Point Objective) to avoid data and service loss.

Data Storage Types

Type	Description	Availability Characteristics
DAS (Direct Attached Storage)	Storage attached directly to a server or workstation (e.g., local HDD or SSD). In order for multiple users to access the DAS, each needs to have direct access to the server that is housing the storage device If the need for more storage arises, the server or client needs to be taken offline so additional drives can be installed, which affects availability.	High-speed, cost-effective, but limited scalability and failover.
NAS (Network Attached Storage)	File-level access over a network, typically used for centralized backups, file sharing. File storage and user accessibility are provided through an existing Ethernet network. Adding storage to the NAS has minimal downtime, because the connection is to the network rather than the server; therefore, availability is not necessarily impacted as storage needs increase. Connectivity and access to files is typically facilitated through a variety of protocols such as Network File Share or Server Message Block.	Redundant configurations possible, but network latency and performance can be bottlenecks.

	the ability to access files via a web browser, dedicated application or command line tools may also be available in NAS appliances.	
SAN (Storage Area Network)	High-performance block-level access over dedicated storage networks. A storage area network (SAN) is a high-speed, special-purpose network that provides mass storage using remote interconnected devices—such as disk arrays, tape libraries or optical jukeboxes—with associated data servers that function as if they were attached locally. SANs are typically part of the overall network of computing resources for larger enterprises but may also serve as remote resources for backup and archival storage. SANs typically support disk mirroring, backup and restore functions, data migration between storage devices, and the sharing of data among different servers in one or more networks. Compatible with DAS, NAS and SAN storage solutions, a redundant array of inexpensive (or independent) disks (RAID) provides performance improvements and fault-tolerant capabilities via hardware or software solutions, breaking up data and writing them to a series	Enterprise-grade availability and performance with built-in redundancy; ideal for mission-critical workloads.

	of multiple disks to improve performance and/or save large files simultaneously. These systems provide the potential for cost-effective continuous data availability onsite or offsite.	
--	---	--

SAN and clustered NAS systems are typically used in environments with strict uptime SLAs (e.g., financial services, healthcare).

The loss or disruption of servers managing sensitive and critical business processes could have catastrophic effects on an enterprise.

Plans should include:

- Operational failover methods to prevent servers from going offline for an extended period.
- Server recovery (universal power supplies [UPSs] and failover systems to prevent power failures of varying levels)

•Data storage options

- Data storage options:
- Direct attached storage (DAS) is a data storage and availability solution directly attached to a server or client, such as a disk drive.
- In order for multiple users to access the DAS, each needs to have direct access to the server that is housing the storage device.

•If the need for more storage arises, the server or client needs to be taken offline so additional drives can be installed, which affects availability.

Network attached storage (NAS) is a dedicated appliance with its own operating system (e.g., TrueNAS, etc.).

- File storage and user accessibility are provided through an existing Ethernet network.
- Adding storage to the NAS has minimal downtime, because the connection is to the network rather than the server; therefore, availability is not necessarily impacted as storage needs increase.

- Connectivity and access to files is typically facilitated through a variety of protocols such as Network File Share or Server Message Block.
- the ability to access files via a web browser, dedicated application or command line tools may also be available in NAS appliances.

A storage area network (SAN) is a high-speed, special-purpose network that provides mass storage using remote interconnected devices—such as disk arrays, tape libraries or optical jukeboxes—with associated data servers that function as if they were attached locally.

- SANs are typically part of the overall network of computing resources for larger enterprises but may also serve as remote resources for backup and archival storage.
- SANs typically support disk mirroring, backup and restore functions, data migration between storage devices, and the sharing of data among different servers in one or more networks.

•Compatible with DAS, NAS and SAN storage solutions, a redundant array of inexpensive (or independent) disks (RAID) provides performance improvements and fault-tolerant capabilities via hardware or software solutions, breaking up data and writing them to a series of multiple disks to improve performance and/or save large files simultaneously.

•These systems provide the potential for cost-effective continuous data availability onsite or offsite.

Considerations

The **Information Security Manager** should:

- **Evaluate business needs and classify systems** by criticality to determine appropriate HA solutions.
 - **Ensure redundancy exists across layers** — compute, storage, and network — not just one tier.
 - **Validate recovery procedures** through regular testing and simulation exercises (aligned with the IRP/BCP).
 - **Collaborate with IT and infrastructure teams** to assess single points of failure (SPOFs) and mitigate them.
 - **Incorporate HA strategies into third-party/vendor assessments** to ensure alignment with business availability expectations.
-

Fault-Tolerant Storage Solutions

Objective:

To **ensure uninterrupted data availability and swift recovery** in the event of an incident, aligning with business-defined **Recovery Time Objectives (RTOs)** and **Recovery Point Objectives (RPOs)**. Strategies to ensure data availability and re-creation in the event of an incident are dependent on RPOs and RTOs

Key Concepts:

Concept	Explanation
RTO (Recovery Time Objective)	The maximum allowable time to restore business processes after an incident.
RPO (Recovery Point Objective)	The maximum tolerable amount of data loss measured in time (i.e., how far back in time you can go to recover data).

These metrics are **defined by the business** and determine the **level of fault-tolerant infrastructure needed**.

Fault-Tolerant Storage Characteristics:

When **no downtime is tolerable**, a fault-tolerant solution becomes essential. It includes:

1. Fail-safe Redundancy

- Uses **mirrored primary servers** or real-time replication.
- Ensures continuous data availability.

2. Distributed Processing & Load Balancing

- Increases performance and eliminates bottlenecks.
- Supports **high transaction environments** (e.g., banking, healthcare).

Fault-tolerant storage differs from high-availability (HA) in that it assumes zero tolerance for failure — all failure points must be eliminated or duplicated in real time.

Storage & Recovery Methods Timeline:

This illustrates where common storage/recovery strategies fall along the RTO/RPO spectrum:

Technology	RPO Suitability	RTO Suitability	Notes
Tape backup	Weeks to Days	Days	Low-cost but high recovery latency.
Remote data journaling	Hours to Minutes	Hours	Good for offsite near real-time replication.
Database shadowing	Minutes to Seconds	Minutes	Replicates data changes to a secondary system.
Clustering	Seconds	Seconds	Enables immediate failover.
Replication	Seconds	Seconds	Real-time copying to other systems or locations.
Online restore	Seconds to Minutes	Seconds	Fast local recovery with snapshot or disk-based tools.

More Insights

Strategies to ensure data availability and re-creation in the event of an incident are dependent on the RPOs and RTOs. An illustration of techniques implemented in relation to RTOs and RPOs is presented for you on-screen.

- After an incident involving data loss, the acceptable time before a system must be restored/re-created (i.e., RTO) and degree of completeness, or the acceptable limit of data loss for the re-created system (i.e., RPO), are business requirements that are enabled through the use of high-availability or fault-tolerant solutions.
- Their use depends on the needs of the business and varies among industries.

Establish a fault-tolerant storage solution if no downtime is tolerated (RTO is instantaneous and the RPO is equally stringent and the goal is for users to experience no downtime).

- Fault-tolerant servers provide for fail-safe redundancy through mirrored images of the primary server.
- Using this approach also entails distributed processing of a server load—a concept referred to as “load balancing” or “clustering”—where all servers take part in processing. In this arrangement, an intelligent cluster unit provides for load balancing for improved performance. This type of server architecture is transparent to users. The only thing that may be noticeable to a user is performance degradation if a server fails.
- The information security manager consider the costs associated with fault-tolerant solutions and difficulties in achieving this state of data availability. For example, in a virtual environment, multiple instances (copies) of a virtual machine (VM) running in parallel must exist. Any change in the state of the primary VM (such as modification of a file) must be applied on all of the secondary VMs in real time.

Role in Implementation:

As an Information Security Manager, you should:

- Collaborate with **IT and business units** to define RTO and RPO for each asset/process.
- Evaluate fault-tolerant solutions in light of **cost-benefit analysis** and **risk appetite**.
- Ensure **storage solutions align with regulatory and operational needs** (e.g., HIPAA, GDPR).
- Test and audit the fault-tolerant systems as part of your **BCP/DRP testing program**.

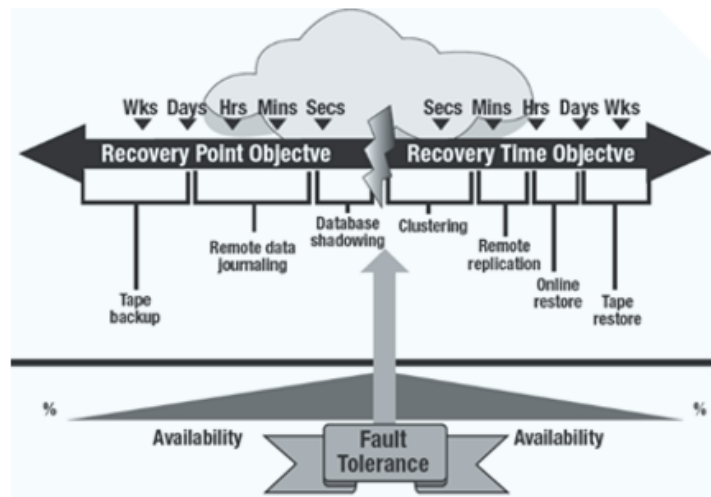
High Availability (HA) Storage

Purpose:

To ensure **minimized service disruption** with **acceptable levels of downtime** using **automated failover mechanisms**. This solution supports **business continuity** without requiring full fault tolerance.

More-flexible downtime requirements enable servers with a failover relationship to provide high availability.

- Primary server fails while running application and restarted in failover server
- Current work in progress may be lost but application can be available again quickly
- Less costly to implement than solutions designed for 100% fault tolerance



Key Characteristics of High Availability Storage:

Feature	Description	
Failover capability	Automatically or manually switches to a standby server if the primary fails.	
Quick recovery	Ensures services are resumed rapidly, minimizing business impact.	
Risk of minimal data loss	Some in-memory or unsaved transactions may be lost (RPO not zero).	

Cost-effective	Less expensive than full fault-tolerant architectures. Appropriate where short delays are tolerable .	
-----------------------	--	--

Example: If a customer order system fails mid-transaction, it might lose that one transaction, but resume processing the next one within seconds or minutes.

Comparison to Fault-Tolerant Solutions:

Aspect	High Availability (HA)	Fault Tolerance (FT)
Downtime tolerance	Some short duration allowed	Zero tolerance
Data loss (RPO)	Minimal or near real-time	None (zero RPO)
Cost	Moderate	High
Use Case	CRM systems, email, file shares	Life-critical systems, trading platforms

Alignment with RTO and RPO:

- **RTO (Recovery Time Objective):**
HA storage solutions aim for **minutes to hours**, depending on architecture.
- **RPO (Recovery Point Objective):**
Supports **minutes**, though not typically in real time like fault-tolerant systems.

Focus on selecting HA solutions based on defined business impact assessments (BIA), risk tolerance, and cost-efficiency.

More Insights

If the RTO and RPO are more flexible (i.e., the business will tolerate a limited amount of downtime), when a high-availability storage solution is established.

- An example of high availability is a set of servers that have a failover relationship
- When an application is running and the primary server fails, the application is restarted in the failover server.
- In this arrangement, the most current work in progress may be lost but the application could be available again quickly.
- High availability solutions are less costly to implement than solutions designed for 100 percent fault tolerance.

Governance Takeaways:

- Ensure RTO/RPO **align with business risk tolerance**.
 - HA is **ideal for systems where short interruptions are acceptable** but availability must be quickly restored.
 - Integrate into **IT continuity planning** and regularly test failover mechanisms.
 - Verify configurations match **vendor SLAs** and **disaster recovery (DR)** plans.
-

Insurance

In the context of enterprise risk and continuity planning, **insurance** serves as a **risk transfer mechanism**. While it cannot prevent incidents, it can **reduce financial exposure** associated with certain types of losses.

Key Guidance for Information Security Managers:

1. Consider elements of protection within the plan

- Insurance should be **one part of a broader risk treatment strategy**, not the sole control.
- Use it to **offset financial loss**, especially for low-probability but high-impact events (e.g., cyber extortion, system outage).

2. Understand limitations of coverage

- Policies **often exclude**:
 - **Legal/regulatory violations**
 - **Intentional misconduct**
 - **Compliance failures**
- IS managers must **not rely solely on insurance** to fulfill control objectives.

3. Review exclusions and deductibles carefully

- It's crucial to understand **what is *not* covered**, such as:
 - Nation-state attacks
 - Acts of war
 - Insider threats
- Deductibles and limits determine **the actual payout**—risk impact may exceed the insured amount.

4. Construct modular policies

- Modular insurance allows:
 - **Alignment with changing IT assets and services**
 - Coverage for **cloud computing, outsourcing, or remote work infrastructure**
- Enables **scalable protection** as the enterprise evolves.

Practical Risk Governance Tips:

Area	CISM Consideration
Risk Treatment	Insurance is a valid treatment under “transfer” category
Continuity Planning	Ensure cyber insurance aligns with DR/BCP/RTO targets
Due Diligence	Coordinate with legal, procurement, and risk teams to assess policies
Policy Lifecycle	Reassess policies annually or after significant changes in IT or regulatory posture

More Insights

The IRP should include information regarding the enterprise's insurance plans including general coverage, cyberinsurance or IT-related insurance.

- Some elements of the enterprise's coverage, such as a business interruption policy, may provide some level of protection and should be considered as part of the plan. This includes reviewing policies which require multiple policy designed to provide various types of IT coverage.
- These policies should be constructed modularly so they can be adapted to the enterprise's particular IT environment.
- Be aware an enterprise can typically not insure against failure to comply with legal and regulatory requirements or any other breach of the law.
- Review policies for exclusions and deductibles to gain a clear understanding of the actual protection provided.

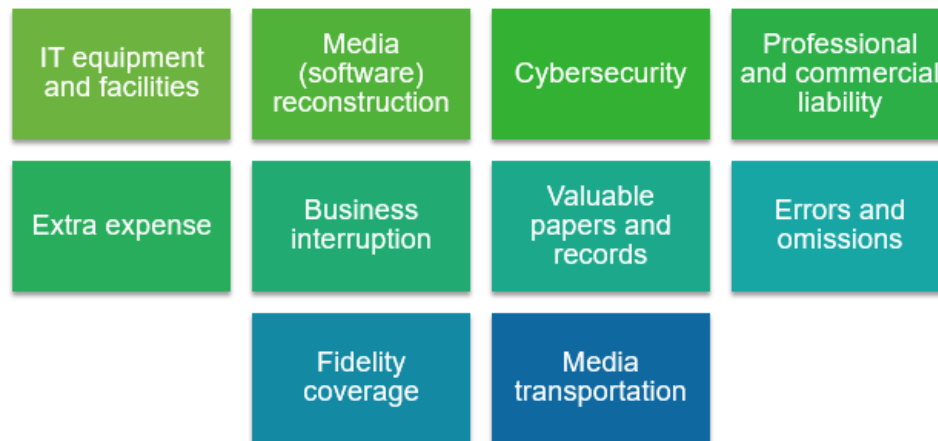
Insight:

Ensure that **insurance complements—not replaces—controls** and that senior management is aware of the **true limitations** of coverage.

Types of Insurance and Coverage

Insurance options should be evaluated as part of the **risk treatment strategy** to **transfer residual risk**. The following are common **insurance categories** relevant to information security and business continuity:

Types of Insurance and Coverage



Operational & Technical Asset Protection

Type	Description
IT equipment and facilities	- Covers physical IT infrastructure from damage, theft, or destruction. - Provides coverage of physical damage to the information processing facility (IPF) and owned equipment. An enterprise should also insure leased equipment if it is obtained when the lessee is responsible for hazard coverage. - The information security manager should review these policies carefully; many policies are worded such that insurers are obligated to replace damaged or destroyed equipment with "like kind and quality," not necessarily the identical brand and model.
Media (software) reconstruction	Covers cost to restore or reconstruct lost software or digital media. Covers damage to computer- related media that are the property of the insured and for which the insured may be liable. Insurance is available for on-

	premises, off-premises or in-transit disasters and covers the actual reproduction cost of the property. Considerations in determining the amount of coverage needed are programming costs to reproduce the media damaged; backup expenses; and physical replacement of media devices such as tapes, cartridges and disks.
Media transportation	Protects digital media in transit (e.g., backup tapes or drives). Provides coverage for potential loss or damage to media in transit to off-premises IPFs. Transit coverage wording in the policy usually specifies that all documents must be filmed or otherwise copied. When the policy does not specifically require that data be filmed prior to being transported and the work is not filmed, management should obtain from the insurance carrier a letter that specifically describes the carrier's position and coverage in the event data is destroyed.
Valuable papers and records	Coverage for irreplaceable hard-copy documents. Covers the actual cash value of papers and records (not defined as media) on the insured's premises against unauthorized disclosure, direct physical loss or damage.

Cyber and Liability Coverage

Type	Description
Cybersecurity	Covers data breaches, malware, ransomware, and other cyber events. Insurance that provides cover for cyberattacks of various kinds, including ransomware, DoS/distributed DoS (DDoS), and losses associated with breaches
Professional and commercial liability	• Protection against legal claims due to performance failures or negligence. • Protection from third-party claims for losses and damages caused by the insured • Extra expense—Designed to cover the extra costs of continuing operations following damage or destruction at the IPF. The amount of

	insurance needed is based on the availability and cost of backup facilities and operations. Extra expense can also cover the loss of net profits caused by computer media damage. This provides reimbursement for monetary losses resulting from suspension of operations due to the physical loss of equipment or media as in the case when IPFs are on the sixth floor and the first five floors are burned out. In this case, operations would be interrupted even though the IPF remained unaffected.
Errors and omissions (E&O)	Covers claims from failure to deliver promised services or products. Provides legal liability protection in the event that the professional practitioner commits an act, error or omission that results in financial loss to a client. This insurance originally was designed for service bureaus, but it is now available from several insurance companies for protecting against actions of systems analysts, software designers, programmers, consultants and other information systems personnel
Fidelity coverage	Protection from losses caused by internal actors (e.g., employee fraud or theft). Usually takes the form of banker's blanket bonds, excess fidelity insurance and commercial blanket bonds, and covers loss from dishonest or fraudulent acts by employees. This type of coverage is prevalent in financial institutions operating their own IPF.

Business Resilience & Continuity

Type	Description
Business interruption	Covers lost income due to operational disruption. Covers the loss of profit due to the disruption of the activity of the company caused by any covered IT malfunction or

	security-related event in which an attacker or malicious code causes loss of availability of computing resources
Extra expense	Reimburses additional costs to maintain operations (e.g., renting servers after a fire). Designed to cover the extra costs of continuing operations following damage or destruction at the IPF. The amount of insurance needed is based on the availability and cost of backup facilities and operations. Extra expense can also cover the loss of net profits caused by computer media damage. This provides reimbursement for monetary losses resulting from suspension of operations due to the physical loss of equipment or media as in the case when IPFs are on the sixth floor and the first five floors are burned out. In this case, operations would be interrupted even though the IPF remained unaffected

Governance Takeaways

1. **Risk Transfer Integration**
 - Insurance must align with risk appetite, residual risk posture, and business impact analysis (BIA) results.
2. **Policy Evaluation**
 - Regularly review policies for coverage limits, exclusions, and alignment with IT and legal obligations.
3. **Compliance Consideration**
 - Understand that **regulatory fines or compliance violations** are **typically not insurable**.
4. **Crisis Preparedness**
 - Cyber insurance should complement IRP/BCP/DRP—not replace them.

Tip:

“When recommending insurance coverage, the IS manager must validate that the policy supports risk treatment decisions and ensures **legal, operational, and continuity alignment**—not just financial recovery.”

BCP and DRP Relationship

BCP vs DRP – Strategic Understanding

Understanding the **difference and synergy** between a Business Continuity Plan (BCP) and a Disaster Recovery Plan (DRP) is **critical** to aligning business goals with IT recovery capabilities.

BCP (Business Continuity Plan)

- **Objective:** Prevent and mitigate disruption to **critical business operations**.
- **Nature:** **Proactive** and continuous.
- **Scope:** Covers **people, processes, facilities**, and third-party dependencies.
- **Ownership:** **Business-driven**—owned by executive/operational units.
- **Execution Trigger:** Initiated **before or during an incident** to ensure continued service delivery.

Example Activities:

- Alternate worksite planning
- Manual workarounds for essential services
- Communication protocols for stakeholders

DRP (Disaster Recovery Plan)

- **Objective:** Restore **IT systems and data** after an incident.
- **Nature:** **Reactive** and conditional—executed **after** BCP triggers.
- **Scope:** Primarily technical—focuses on systems, applications, networks, and data.
- **Ownership:** Typically **IT department** (CIO, infrastructure & ops teams).
- **Execution Trigger:** Initiated **after incident declaration**, often by BCP.

Example Activities:

- Restore backups from offsite/cloud
- Failover to disaster recovery site
- Rebuild compromised systems

Alignment:

- **BCP ensures continuity; DRP ensures restoration.**
- DRP is a **subset** of BCP and must **align with business recovery objectives** (like RTOs and RPOs).
- Both should be **tested together** to ensure end-to-end resiliency.

More Insights

The DRP is a subset of the BCP.

BCP

- BCP goals include incident prevention and mitigation
- A BCP may be seen as a continuous process that is actively implemented in normal, business-as-usual scenarios
- Typically owned by the business

DRP

- Focused on what must be done to restore operations after an incident has already taken place.
- Reactive in nature and is implemented under a specific set of conditions (i.e., the business has incurred an incident).
- Typically owned by the IT function

Insight:

"Which of the following best differentiates a BCP from a DRP?"

Correct answer: *BCP focuses on sustaining business operations, while DRP focuses on recovering IT services.*

Disaster Recovery Planning

The information security manager must understand the basic processes required to recover operations from information system incidents resulting in security breaches and system failures, natural disasters, and other probable events that would cause potential disruption of business operations

Disaster Recovery Overview

Disaster recovery (DR) is a **critical component of enterprise resilience**. While it is often conflated with business continuity, it has a **distinct and technical focus** within the broader continuity strategy.

Disaster Recovery

- **Definition:** Focused on the **restoration of IT systems** following disruptive events such as hardware failure, cyberattacks, or natural disasters.
- **Scope:** Covers **data centers, infrastructure, applications**, and connectivity.
- **Trigger:** Activated **post-disaster declaration**.

DR answers the question: **How do we recover our systems and data?**

Business Recovery

- **Definition:** Ensures **continuity of critical business functions** such as customer service, payroll, and logistics.
- **Scope:** Includes **people, facilities, supply chain, communications, and manual workarounds**.

- **Dependency:** Business recovery may rely on IT but often involves **non-technical processes**.

Business recovery answers: **How do we keep the business running?**

Planning Includes

1. **Documenting disaster declaration criteria:**
 - Clearly define thresholds for declaring a disaster.
 - Must involve executive authority and legal/compliance input.
2. **Preparing for site relocation:**
 - Alternate processing site setup (hot, warm, cold).
 - Logistics for people, equipment, and secure access.

More Insights

- Disaster recovery has traditionally been defined as the recovery of IT systems after disruptive events that cause major system failures, such as hurricanes and floods resulting in inaccessibility or prolonged power or communication outages.
- Business recovery is defined as the recovery of all the critical business processes necessary to continue or resume operations. Business recovery includes DR and all other required operational aspects.
- Planning for disaster and business recovery includes:
 - Documenting the requirements for declaring a disaster (i.e., determining when an incident cannot be resolved by the available recovery processes).
 - Preparations to move operations to an alternate processing site.

Insights

From an information security governance perspective:

- Disaster recovery is **tactical** and IT-centric.
- Business recovery is **strategic** and cross-functional.
- The **Information Security Manager** must ensure:

- Alignment of RTOs/RPOs with business priorities.
- Coordination between IT recovery and business recovery plans.
- **Regular testing** and documentation updates.

Tip:

Disaster recovery focuses on *“how to restore IT systems,”* while **business recovery** focuses on *“how to resume critical operations.”*

Disaster Escalation and Declaration

In the realm of information security management, it's essential to **differentiate between an event, incident, problem, and disaster**, and to have clearly defined criteria for **escalating and declaring a disaster**.

Progression Path:

1. **Event** – A deviation from normal operations (e.g., system alert).
2. **Incident** – A confirmed breach or disruption affecting confidentiality, integrity, or availability.
3. **Problem** – A more serious issue, often underlying or recurring, with no immediate resolution.
4. **Disaster** – A disruption so severe that it **requires activation of the disaster recovery or business continuity plan**.

Role of the IS Manager

To ensure appropriate escalation and timely disaster declaration, the **Information Security Manager** must:

Collaborate with BC/DR Planning Functions

- Ensure **alignment between business continuity (BC), disaster recovery (DR), and security response plans**.
- Create an integrated response roadmap.

Define Roles and Responsibilities

- Assign **decision authority** for declaration.
- Clarify **chain of command** and communication paths.

Establish Declaration Criteria

- Define **severity levels**, business impact thresholds, and escalation triggers.
- Use metrics like **RTO**, **RPO**, or **MTD** to support decisions.

Train Personnel

- Educate teams on **incident classification**, escalation paths, and reporting procedures.
- Conduct **scenario-based training** to reinforce decision-making protocols under pressure.

Insights

- **Disaster declaration** should not be ad hoc. It is a **predefined governance process** based on objective criteria.
- IS Managers ensure **escalation processes are rehearsed and regularly tested**.
- Effective declaration protects organizational assets and reputation by enabling timely recovery.

More Insights

- When an incident occurs, the ability to address an incident can mean the difference between an inconvenience and a disaster. An important consideration is recognizing the point at which an incident becomes a problem requiring a disaster declaration.
- Progression of a disaster flows from the:
 - Event to the
 - Incident stemming from the event
 - Which develops into a problem
 - Leading to disaster.

The extent of information security involvement and authority varies widely by enterprises as many have a separate department responsible for BC planning and DR. The information security manager needs to:

- Collaborate with BC/DR planning departments to integrate plans regardless of department structure
- Define individual roles and responsibilities clearly
- Establish clear severity and declaration criteria.
- Train personnel to recognize, classify, report and escalate potential incidents.

Not all events, incidents or critical disruptions should be classified as security incidents. For example, disruption in service can be caused by system malfunctions or accident. Regardless of the cause of operational disruption, satisfactory resolution requires prompt action to maintain or recover operational status. Actions may, among other things, necessitate restoration of hardware, software and/or data files.

Takeaway:

"The IS Manager must ensure there is a clear, repeatable, and tested framework for identifying when an incident exceeds internal response capability and requires invoking the disaster plan."

Severity, Escalation, and Incident Declaration Criteria

Effective incident response relies on **clearly defined and communicated criteria** for determining the **severity** of an event, when to **escalate**, and how to **declare** an incident or disaster.

Objectives of Establishing Criteria

1. Provide Clear Lines of Authority

- Define **who has the authority** to escalate incidents and declare disasters.
- Avoid delays caused by ambiguity in decision-making.

2. Activate the Teams

- Specify **trigger points** to mobilize IRT/BCP/DRP teams.
- Supports rapid, role-based engagement.

3. Declare an Incident or Disaster

- Define what **constitutes a disaster** vs. a high-severity incident.
- Prevent overreaction or underreaction by using agreed thresholds.

4. Mobilize Containment and Recovery Teams

- Ensure **containment, eradication, and recovery** teams respond in a coordinated manner.
- Aligned response across business units and technical teams.

Characteristics of Effective Criteria

Criteria should be:

- **Consistent** – Uniformly applied across business units and event types.
- **Concise** – Clear and brief to allow swift interpretation during a crisis.
- **Understandable** – Easily interpreted by both technical and non-technical stakeholders.
- **Published and Communicated** – Made available to relevant staff and integrated into training and awareness.

More Insights

The information security manager must be aware that, regardless of how well incidents are planned for and handled, there is always the possibility that events will escalate to a disaster.

Escalation and incident declaration criteria are established and communicated to:

- Provide clear lines of authority to determine the response level
- Activate the teams
- Declare an incident or disaster
- And mobilize the appropriate teams to initiate containment and recovery processes.

Severity criteria should be:

- Consistent,

- Concisely described
- Easy to understand so severity levels of similar events are uniformly determined.
- Published and communicated to all relevant parties.

Governance Perspective

From a **governance** standpoint:

- The IS Manager is responsible for ensuring **escalation criteria are integrated into policies and response plans**.
 - Regular reviews and **post-incident feedback** should validate whether criteria were sufficient and followed.
-

Evaluating Recovery Strategies

Expert Commentary

In the context of information security governance, **selecting an appropriate recovery strategy** is one of the **most critical steps** in ensuring business continuity and incident response effectiveness. A well-evaluated strategy safeguards the enterprise against unacceptable downtime and data loss.

Key Considerations When Choosing a Strategy

1. **Enterprise Size, Complexity, and Maturity**
 - Recovery plans should scale appropriately with the organization's operational scope and technological landscape.
 - A small enterprise may need simplified solutions, while complex organizations require layered, integrated strategies.
2. **Alternative Strategies**
 - Consider options like **hot sites, cold sites, hybrid cloud, managed DRaaS**, etc.
 - Flexibility improves adaptability in dynamic risk environments.
3. **Trade-offs: Scope, Capabilities, Risk, and Cost**
 - Balance **cost-effectiveness** with **response time and recovery completeness**.

- Example: Faster recovery times (RTO) typically cost more.
- 4. **Outsourcing Capabilities**
 - Evaluate vendor capabilities (e.g., DRaaS providers) and their **SLA performance and cost structures**.
 - Must align with organizational objectives and legal/regulatory requirements.
- 5. **Business Interruption Insurance**
 - Use as a **financial safeguard** to offset disruption-related losses.
 - Should complement but **not replace** technical and procedural recovery measures.

Characteristics of a Well-Selected Strategy

The chosen strategy must:

- **Meet Management Objectives**
 - Align with defined **risk appetite** and **tolerance thresholds**.
- **Enable Detailed Plan Development**
 - Serve as a **foundation** for IRP, DRP, and BCP documentation and testing.
- **Address Probable Events Effectively**
 - Focus on high-likelihood and high-impact events with **reasonable recovery expectations**.
- **Balance Cost and Preparedness**
 - Avoid overinvestment in unlikely scenarios; ensure **justifiable ROI**.

Even with the support of senior management, the information security manager should understand that the development of an incident management and response plan is likely to be a difficult and expensive process that may take considerable time.

Various strategies exist for recovering critical information resources. When choosing a strategy consider:

- Size and complexity of the enterprise and the state of recovery planning,
- Alternative strategies, encompassing different capabilities and costs, to be presented to management for a final decision.
- Trade-offs among scope, capabilities, risk and cost of alternate strategies
- Outsourcing some or all the needed capabilities and associated costs for the purpose of comparisons.
- Business interruption insurance as a strategy option to mitigate disruption impacts

The strategy choice should:

- Not only meet management's objectives
 - But also provide a basis to develop detailed incident management and response plans.
 - And demonstrably address probable events with acceptable recovery times at a reasonable cost
 - Consider costs of preparing for possible disruptions (e.g., purchasing, maintaining and regularly testing redundant computers; maintaining alternative network routing; and training and personnel costs) and activating capabilities in the event of an incident.
-

Addressing Threats Proactively

Proactive Threat Management

Effective information risk management is rooted in **proactivity**—not reactivity. This slide reflects key strategies aligned with **risk treatment** options per the CISM Risk Response Plan framework:

1. Eliminate or Neutralize

- **Definition:** Directly remove or disarm threats where feasible.
- **Examples:** Decommissioning vulnerable legacy systems, removing malware, disabling unnecessary services.
- **ISACA Relevance:** Aligns with the **risk avoidance** treatment option.

2. Minimize Likelihood of Occurrence

- **Definition:** Implement controls to **reduce the probability** that a threat materializes.
- **Examples:** Firewalls, employee awareness training, patch management, secure coding.
- **ISACA Relevance:** Aligns with **risk mitigation**, which is the most common and cost-effective strategy.

3. Minimize Effects

- **Definition:** Focus on **reducing the impact** of a threat should it occur.
- **Examples:** Incident response planning, business continuity procedures, disaster recovery (DR) capabilities.
- **ISACA Relevance:** Still under **risk mitigation**, but emphasizes **impact** instead of likelihood.

4. Use Redundant or Mirrored Systems

- **Definition:** Build **high-availability environments** to support resilience.
- **Examples:** RAID, load-balanced servers, failover clusters.
- **Viewpoint:** This supports **business continuity and disaster recovery** by **maintaining availability**.

5. Ensure High Resilience or Robustness

- **Definition:** Design systems that can **withstand and adapt** to disruptions.
- **Examples:** Cloud elasticity, fault-tolerant architecture, chaos engineering in DevSecOps.
- **ISACA Relevance:** Supports **long-term risk sustainability** through **architecture resilience** and **robustness principles**.

More Insights

Each critical information processing system requires an approach to restoring operations in the event of disruption. Some proactive strategies that may be considered in incident management when responding to threats include:

- Eliminate or neutralize a threat—Although removing or neutralizing a threat might seem like the best alternative, it can be unrealistic with external threats. If the threat is internal and specific, it may be possible to eliminate it. For example, the threat of a particular activity creating a security incident might be addressed by ceasing the activity.

- Minimize the likelihood of a threat's occurrence—The best alternative is often to minimize the likelihood of a threat's occurrence by reducing or eliminating vulnerabilities or exposure. This goal can be achieved by implementing the appropriate set of physical, environmental and/or security controls. For example, deploying firewalls, IDSs and strong authentication methods might substantially reduce the risk of a successful attack. Reducing exposure may be achieved by compartmentalization, such as network segmentation.
- Minimize the effects of a threat if an incident occurs—There are ways to minimize impact if an incident occurs, such as effective incident management and response, insurance, redundant systems with automatic failover, or other compensating or corrective controls.
- Other strategies include redundant and mirrored systems to ensuring a high degree of system or process resilience and robustness

Summary

Proactive threat management is a **cornerstone of effective security governance**. The CISM exam will often test your ability to align threat handling with business risk appetite, resource constraints, and operational priorities.

Recovery sites

Recovery sites are predefined alternate facilities or service agreements that support business continuity during major disruptions. Their selection is directly tied to the organization's **Recovery Time Objective (RTO)** and **Recovery Point Objective (RPO)** as determined during Business Impact Analysis (BIA).

1. Hot Sites

- **Fully operational** facilities with real-time replication of systems, applications, and data.
- Immediate failover capability.
- **RTO**: Minutes to hours
- **Cost**: High
- **Ideal For**: Mission-critical operations requiring zero or near-zero downtime.

2. Warm Sites

- Equipped with hardware and connectivity but may need system/data restoration.
- **RTO**: Several hours to < 1 day
- **Cost**: Medium
- **Ideal For**: Essential business functions not requiring real-time availability.

3. Cold Sites

- Basic infrastructure (space, power, cooling, connectivity) but **no hardware or data**.
- Requires setup before use.
- **RTO**: Days or more
- **Cost**: Low
- **Ideal For**: Non-critical functions or organizations with tight budgets.

4. Mobile Sites

- Portable data centers delivered to a specified location.
- Can support short-term operational needs.
- Often **used as a supplement** to traditional DR plans.

5. Duplicate Sites

- A **fully functional replica** of the primary site maintained and managed by the organization.
- Includes applications, systems, and personnel.
- Typically used for **load balancing and geographic redundancy**.

6. Mirror Sites

- Real-time **synchronized systems and data**, often geographically distant.
- Offers **high availability and zero RPO**.
- More advanced than hot sites in some cases.

7. Disaster Recovery as a Service (DRaaS)

- Cloud-based failover solution managed by a third party.

- Flexible, cost-effective, and scalable.
- **RTO/RPO vary by contract.**
- Popular for SMBs and hybrid cloud environments.

8. Reciprocal Agreements

- Mutual pacts between organizations to host each other's operations in a disaster.
- **High risk** due to lack of control and uncertainty of availability during mutual crisis.
- Typically **not recommended without formal testing and SLAs.**

More Insights

Some critical operational aspects may require mirroring to meet service level requirements, while others can be adequately supported by hot, warm or cold site capabilities at the same or other facilities.

The types of offsite backup facilities that can be considered include:

- **Hot sites:** fully configured and ready to operate within hours
- **Warm sites:** complete infrastructures, partially configured
- **Cold sites** (vendor/third party or off-the-shelf): only viable when enterprises can afford long downtime. Sites are ready to receive equipment but only have a basic environment. Activation may take several weeks.
- **Mobile sites:** Specially designed trailers that can be quickly transported to a business location or an alternative site to provide a ready-conditioned IPF. These mobile sites can be attached to form larger work areas and can be preconfigured with servers, desktop computers, communications equipment, and microwave and satellite data links. They are a useful alternative when there are no recovery facilities in the immediate geographic area. They are also useful in case of a widespread disaster and may be a cost-effective alternative for duplicate IPFs for a multisite enterprise.
- **Duplicate sites:** Dedicated recovery sites that are functionally similar or identical to the primary site that can quickly take over for the primary site. They range from a standby hot site to facilities available through a reciprocal agreement with another company.
- **Mirror sites:** Best option if continuous uptime and availability are required. A mirror site is very similar or identical to the primary site. The mirror site is operational in concert with the primary site on a load-sharing basis.
- **Disaster recovery as a Service:** a category of cloud computing used for protecting a system or data from disruptions at an IPF by enabling a full recovery within a cloud environment. This differs from a cloud-based backup/storage service by providing the necessary IT capabilities on demand (pay as you go) and ensuring systems are recovered

and operate as needed, reducing overhead investment costs associated with mirror, hot and warm sites.

•**Reciprocal agreements:** Reciprocal agreements are not as common as they once were. Under the typical agreement, participants promise to provide computing time and network operations to each other when an emergency arises. If the recovery strategy is to use reciprocal agreements with one or more internal or external entities, it is essential that similar equipment and applications are available.

Practices:

- Choose recovery site type **based on BIA findings** and aligned with the organization's **risk appetite**.
 - Regularly **test** and **review** all recovery arrangements.
 - Ensure **SLAs** (Service Level Agreements) are in place—especially for DRaaS and reciprocal setups.
-

Determining the Type of Recovery Site

Choosing an appropriate **recovery site** is a **risk-based decision** and must be made **strategically**. The selection hinges on a combination of **business impact analysis (BIA)** outcomes, **risk appetite**, and **cost-effectiveness**.

Determining Type of Recovery Site

Lengthier and more costly outages or disasters that impair the primary physical facility are likely to require offsite backup alternatives.



Key Decision Factors Explained

1. Probability of Major Outages Occurring

- Evaluate historical incidents, threat modeling, and regional risks (e.g., natural disasters).
- High-risk zones may demand **hot or mirror sites** for resilience.
- Rarely impacted environments might afford a **cold site** or **reciprocal agreement**.

2. Nature and Extent of Impact on Enterprise Ability to Continue Operations

- What are the operational dependencies?
- Will the outage cause **regulatory breaches, revenue loss, or brand damage**?
- High-impact functions may require faster recovery capabilities (e.g., warm/hot sites).

3. BIA Operational Requirements

- BIA helps determine **RTO (Recovery Time Objective)** and **RPO (Recovery Point Objective)**.
- For example:
 - **RTO < 1 hour**: Likely requires hot/mirror site.
 - **RTO of 72 hours**: Cold or DRaaS site may suffice.

4. Management Risk Appetite

- Executives must be consulted: Are they willing to risk a few hours/days of downtime to save costs?
- **Risk-tolerant organizations** may delay investments in faster DR sites, opting for reactive measures.
- **Risk-averse entities** may opt for proactive, continuous availability (e.g., active-active configurations).

5. **Costs and Benefits**

- Balancing cost vs. criticality:
 - **Hot sites** provide immediate continuity at high cost.
 - **Cold sites** are cheaper but carry high recovery delays.
- Must conduct **cost-benefit and ROI analysis** to justify expenditures.

Tip

Site selection should be aligned with both **IT and business recovery objectives**. It is not an IT-only decision. Instead, it is driven by:

- **BIA**
 - **Risk assessment**
 - **Management decisions**
-

Selecting a Recovery Site

Strategic Guide to Selecting a Recovery Site

Selecting a recovery site requires balancing multiple **technical, operational, and risk-based considerations**. Each factor shown on this slide reflects a **key metric** that contributes to evaluating recovery site readiness and appropriateness.

Key Factors

Parameter	Meaning & Strategic Importance
AIW (Acceptable Interruption Window)	The total time that the enterprise can wait from the point of failure to the restoration of critical services/applications. After this time, the cumulative losses caused by the interruption may threaten the existence of the enterprise.
RTO (Recovery Time Objective)	The length of time from the interruption to the time that the process must be functioning at a service level sufficient to limit financial and operational impacts to an acceptable level. Some organizations express it as partial moments (i.e., from point of failure to technical recovery or point of disaster declaration to full operations).
RPO (Recovery Point Objective)	The age of the data the enterprise needs to be able to restore in the event of a disaster (i.e., the amount of data that can be lost and need to be recreated). Sometimes this is expressed as the point of last known good data. This will be the starting point for operations at the recovery site. If full backups are infrequent, it may take too much time to re-create the amount of data lost and the result would be RTOs not being met.
SDO (Service Delivery Objective)	Level of services to be supported during the alternate process mode until the normal situation is restored. This must be directly related to business needs.
MTO (Maximum Tolerable Outage)	The maximum time the enterprise can support processing in the alternate mode. Various factors will determine the MTO, including increasing backlogs of deferred processing. This, in turn, is affected by the SDO if it is less than that required during normal operations.
Proximity Factors	The distance from potential hazards, which can include flooding risk from nearby waterways, hazardous material manufacturing or storage, or other situations that may pose a risk to the operation of a recovery site
	Sufficient distance needed to minimize the likelihood of both the primary and recovery

Location	facilities being subject to the same occurrence of an environmental event. When planning, consideration should be given to the typical impact area of the types of events that have a higher likelihood of occurrence for a given location. For example, in the case of hurricanes vs. tornados, the impact area of a hurricane is typically much larger than the impact area of a tornado, requiring greater distance between sites for a location where hurricanes frequently occur
Nature of Probable Disruptions	This must be considered in terms of the MTO. For example, a major earthquake is likely to render a primary site inoperable for a number of months. Clearly, the MTO in an area subject to this disruption must be greater than the probable duration of such an event.

Real-World Application

When selecting a recovery site, an enterprise should **prioritize alignment** with:

- **Business Impact Analysis (BIA)** outcomes
- **Risk assessment findings**
- **Enterprise risk appetite**
- **Cost-effectiveness vs performance trade-offs**

For example:

- If the **RTO is < 4 hours**, a **hot or mirror site** is needed.
- If the **RPO is 24 hours**, **daily backups** and warm site provisioning may suffice.
- If the site is located within the same region, **shared regional disruptions** (like power grid outages) must be factored into the site's **resilience architecture**.

Guidance

A mature organization does **not treat recovery site selection as an IT issue alone**. Instead, it is:

- A **business-driven** decision
- Justified through **quantitative metrics** from the BIA
- Guided by **risk tolerance, cost justification, and regulatory requirements**

Telecommunications Recovery

Telecommunication systems are critical infrastructure. Their failure can **cripple continuity** and **disrupt incident response execution**. Therefore, organizations must design **resilient communication architectures** that support operational continuity under adverse conditions.

Part of IT facility recovery involves telecommunications. The strategies usually considered include elements of network disaster prevention:

Key Elements of Telecommunications Recovery

Element	CISM-Relevant Explanation
Alternative and diverse routing	Implementing physically separate paths for network traffic reduces the likelihood of a single point of failure .
Long-haul network diversity	Ensures redundancy over geographically dispersed distances to survive regional outages (e.g., natural disasters).
Protection of local resources	Hardens on-site telecom infrastructure (e.g., routers, switches, cabling) against threats like vandalism or fire.
Voice recovery	Strategies (VoIP backup, satellite phones) to maintain voice communications during outages.
Circuit and bandwidth availability	Prearranged contracts and sufficient capacity to ensure on-demand network throughput during high-impact events.
Out-of-band communication	Enables management traffic on a separate channel. Used when primary systems are compromised.

Alternate telecom carriers	Mitigates risk of total service loss if the primary carrier fails. Often part of SLA and vendor risk planning .
-----------------------------------	--

Implementation Guidance for Information Security Managers

1. **Conduct a risk-based assessment** of telecom dependency.
2. Ensure **redundancy in both infrastructure and service providers**.
3. Build out **failover protocols** and ensure **regular testing**.
4. Integrate telecom recovery strategies into:
 - Business Continuity Plan (BCP)
 - Disaster Recovery Plan (DRP)
 - Incident Response Plan (IRP)

Recovery and Restoration Strategy

Once a disaster recovery (DR) strategy is developed, it's not enough to simply wait for full restoration. A **graded continuity approach** must be implemented to maintain operations at some capacity. This is the essence of a **phased recovery and restoration model**.

After a strategy for the recovery of sufficient IT facilities to support critical business processes has been developed, it is critical that the strategies work for the entire period of recovery until all facilities are restored.

The strategies may include:

- Doing nothing until recovery facilities are ready
- Using manual procedures
- Focusing on the most important needs (customers, suppliers, products, systems, etc.) with the resources that are still available
- Using user-level application software to capture data for later processing or performing simple local processing

Phased Strategies

Step	Strategy	CISM-Based Meaning and Relevance
1	Doing nothing until recovery facilities are ready	Passive approach. Often used when downtime impact is acceptable. May align with low-priority systems.
2	Using manual procedures	Enables continuity of critical processes in a degraded mode. Essential for recovery of operational functions when systems are down.
3	Focusing on the most important needs with available resources	Reflects risk-based prioritization . Ensures limited resources are allocated to mission-critical operations .
4	Employing user-level application software to capture data for later processing	Supports data continuity. Temporary workarounds allow for post-recovery processing, avoiding data loss and backlog.

Role of the Information Security Manager

The IS manager must ensure:

- Recovery procedures are **prioritized by business impact and risk tolerance**
- Temporary procedures (manual or automated) **do not compromise security**
- There's a **communication plan** in place to update stakeholders as recovery progresses
- Data captured offline is securely stored and properly integrated post-recovery

Integrate with BCP & IRP

Recovery strategies should:

- Be **tested** during DR/BCP exercises
- Be **aligned** with RTOs, RPOs, and business impact analysis (BIA)
- Address **data integrity** and **auditability** for later reconciliation

Recovery Plan Development

The development of disaster recovery (DR) procedures that ensure an organization’s resilience and continuity.

Interpretation of Recovery Plan Development

A **Recovery Plan** is a tactical component of a broader **Business Continuity Plan (BCP)** and **Disaster Recovery Plan (DRP)**. Its success hinges on preparation, coordination, clarity, and accessibility.

Core Elements of the Recovery Plan

Component	Explanation
Clear documentation	Standardizes recovery procedures. Ensures consistent execution and auditability.
Teams responsible for specific tasks	Clarifies roles & responsibilities based on skill sets. Aligns with RACI (Responsible, Accountable, Consulted, Informed) framework.
Procedures (system, user, application, and network recovery)	Addresses technical steps for system restoration—ensuring recovery aligns with RTO/RPO objectives.
Plan copies retained offsite	Supports redundancy. Enables access during localized outages (e.g., site unavailability). Best practice includes digital and hard-copy redundancy.

Considerations for Recovery Plan Development

Governance and planning standards:

Category	Best Practices
----------	----------------

Pre-incident readiness	Plans must be built before disasters occur, emphasizing preventive and detective controls.
Logistics & Evacuation	Physical security planning intersects with continuity. Important for both safety and operational continuation.
Disaster declaration steps	Defines thresholds and triggers for declaring a disaster (often aligned with BIA outputs).
Transition to DR	Plan must address what to do if incident containment fails (moving from IRP to DRP).
Business process & IT resource alignment	DR must support mission-critical functions. Prioritization should follow BIA and risk appetite findings.
Contacts and communication	Essential for command-and-control. Must include updated vendor, regulator, and stakeholder details.
Step-by-step instructions	Simplifies execution during high-stress scenarios. Avoids improvisation.
Resource requirements	Includes hardware, software, facilities, personnel, and budget required to execute the recovery.

Based on the response and recovery strategy selected by management, a detailed response and recovery plan should be developed and address all issues involved in recovering from a disaster including:

- Clear documentation written in simple and easy to read language.
- Teams of personnel responsible for specific tasks during incidents or disasters.

- Procedures that accommodate system, user, application and network recovery strategies.
- Copies of the plan retained offsite to ensure availability when needed including the recovery facility, the media storage facility and the homes of key decision-making personnel.

Various factors should be considered while developing the plan, including:

- Pre-incident readiness
- Logistics (personnel relocation and temporary housing are considered)
- Evacuation procedures
- Disaster declaration steps
- Transition steps to DR if incident response fails
- Business processes and IT resources that should be recovered
- Individuals and contact information: This includes those with decision authority and responsibilities along with people and alternates responsible for each function in the plan
- Step-by-step explanation of the recovery options
- Resources required for recovery and continued operations

Role of the Information Security Manager

The IS Manager must:

- Ensure recovery planning is **aligned with enterprise risk management**
- Conduct **tabletop exercises** to validate recovery plans
- Ensure plans reflect **compliance with legal, regulatory, and contractual obligations**
- Establish **plan ownership** and **version control**
- Guarantee **confidentiality, integrity, and availability (CIA)** during recovery operations

Recovery Operations

Recovery Workflow at DR Site

When an enterprise is forced to operate from a DR site due to a disruption at the primary site, the **Business Continuity (BC) team** plays a pivotal role in monitoring and transitioning operations back. The sequence includes:

1. **Monitor Restoration Progress at Primary Site**
Continuous monitoring is essential to determine when the original site becomes viable for reoccupation.
2. **Assess When It Is Safe to Return**
Safety and operational assessments ensure conditions do not expose personnel or assets to undue risk.
3. **Perform Tests to Evaluate Accessibility, Operations, and Functionality at Primary Site**
Before resumption, verify IT infrastructure, physical accessibility, and application functionality.
4. **Repeat Relocation Team Processes to Restore Primary Location**
Use predefined relocation protocols to reverse the initial shift to the DR site.
5. **Notify and Update BC Leader After Complete Restoration**
Final documentation and executive communication are required for audit trails, lessons learned, and continuity validation.

Strategic Recovery Decisions

In situations where the primary site is deemed unviable for an extended duration or permanently, senior leadership and crisis management teams may need to:

- **Transform Alternate Recovery Site into the Primary Site**
This requires evaluating long-term sustainability, cost, security controls, and regulatory implications.
- **Identify, Acquire, and Set Up Another Site to Act as the Primary**
Establishing a completely new site includes facilities provisioning, connectivity, staffing, and aligning with the enterprise's business continuity objectives.

When the enterprise operates in recovery mode from a DR site, the BC teams should:

- Monitor the restoration progress at the primary site.
- The team will assess when it is safe to return
- Perform tests to evaluate whether the primary data center and facilities are accessible, operational and capable of functioning at normal capacities and processing load.
- Repeat processes used by relocation team to restore the primary location.

- Notify and update the BC leader on complete restoration of the primary facility and data processing capabilities who will then declare normalcy in consultation with the crisis management team
- and migrate operations back to the primary site.

The enterprise may make a strategic decision if the primary site is severely damaged or completely destroyed:

- Transform the alternate recovery site to the primary operations site or
- Identify, acquire and set up another site where operations will eventually be restored and will function as the primary site. This is especially true in cases where the enterprise subscribes to a third-party disaster recovery site because the costs of operating from such a site for an extended period may prove to be prohibitively high.

Key principles reinforced:

- **Risk-based decision-making** in DR site transition
 - Importance of **testing, validation**, and **stakeholder communication**
 - Emphasis on **strategic adaptability**
-

Training, Testing and Evaluation

Because an incident may occur at any time, training, testing and evaluating the incident management program are all essential to ensuring the success of the program. Effectiveness in this area requires understanding not only of the roles and responsibilities of the team but also how the program can adapt and improve through testing and evaluation.

Incident Management Training

Context and Strategy

The header emphasizes a key **strategic decision**:

“Incidents may be managed internally, by a third party, or through a hybrid approach.”

This sets the foundation that **training must align with the enterprise's sourcing model**, contractual obligations, and regulatory expectations.

Training Objectives

1. Understanding Duties, Capabilities, and Skills

- **Why It Matters:** Incident response requires clarity in roles—ambiguity can lead to escalation failure or non-compliance.
- **Focus:** Ensures personnel know their scope of authority and technical expectations.
- **Alignment:** Supports control assurance and mitigates risk of improper or delayed response.

2. Flexible Training Methods

- Ranges from:
 - **Instructor-led classroom training**
 - **Tabletop simulations**
 - **Live incident exercises**
 - **On-the-job experiential learning**
- **Insight:** A mature IR program customizes training for audience relevance (executives vs. technical teams) and ensures **annual refreshers and scenario updates**.

3. Skills Must Match Operational Reality

- Skills must stay **aligned with current systems, technologies, and threats** (e.g., cloud, zero trust, ransomware).
- **Emphasis:** Training is not static—it's a lifecycle-driven requirement based on changing risk profiles and **lessons learned from actual incidents**.
- Includes documentation of:
 - Skill gaps
 - Remediation paths

- Metrics for training effectiveness
- The IS manager should train all incident management roles on how the enterprise handles incidents as they may be managed internally, by a third party or a combination.
- Training ensures proper understanding of the duties, foundational capabilities and skills needed to respond throughout the life cycle of an incident.
- Training can take many forms ranging from formal instructor-led classes to on-the-job training.
- The skills needed for each role need to be clearly defined and kept relevant with the current operating environment of the enterprise.

Incidents may be managed internally by a third party or a combination of both.



Ensures proper understanding of the duties, capabilities and skills needed



Can range from formal instructor-led classes to on-the-job training



Define skills and keep relevant to current enterprise operating environment

Implementation Recommendations:

- **Document Training Requirements** in the incident response plan (IRP)
- **Tie training outcomes** to measurable improvements in Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR)
- **Coordinate training with third-party vendors** if incident response is outsourced or hybrid
- Maintain **training logs and certifications** for audit and compliance traceability

Incident Management Roles

Poorly managed incidents have the capacity to become disasters. The incident management capability in an enterprise acts as the first responder for a variety of incidents, including information processing and processes.

Responding to and managing incidents to contain and minimize damage

- Limiting disruptions to business processes
- And restoring operations as quickly as possible.
- Understanding the hierarchy and structure to clearly define and communicate roles, preventing miscommunicating during an active incident.

The roles associated with incident management will vary enterprise to enterprise.

Common roles normally involved in incident management activities include, but are not limited to (select items shown on screen):

- **•Analysts (security, technology, threat intelligence)**
- **•Affected business unit representation**
- **•Corporate communications**
- **•Executive sponsor**
- **•General counsel**
- **•Human Resources**
- **•Incident communications lead**
- **•Incident coordinator (documentation and timeline)**
- **•Incident response team lead**
- **•Information security manager**
- **•Internal audit**
- **•Lead investigator**
- **•Public relations**
- **•Risk management**
- **•Security analysts**
- **•Technical subject matter experts (e.g., applications, infrastructure, engineering)**

Purpose of Enterprise Incident Management

This outlines **four core objectives**, reinforcing the **strategic role of incident response** within an enterprise:

1. **Respond and Manage:**
 - Act quickly to **contain and mitigate** potential damage (aligned with CIA triad).
2. **Limit Disruption:**
 - Prioritize **business continuity**, preventing downstream impact across operations.
3. **Restore Operations Quickly:**
 - Supports **RTO (Recovery Time Objective)** achievement and SLA commitments.
4. **Clarify Structure and Communication:**
 - Roles must be predefined to avoid **confusion during crisis**—key for legal, operational, and audit readiness.

Common Roles in Incident Management

Each of the 12 roles contributes to **interdisciplinary coordination**. Here's a brief function breakdown:

Role	Responsibility & Alignment
Analysts	Triage, analyze, and validate incidents using logs, threat intel, and monitoring tools.
Affected business unit reps	Convey business impact, help prioritize recovery actions based on operational risk.
Executive sponsor	Approves funding and provides high-level decision-making support.
General counsel	Manages legal exposure, helps with privilege, law enforcement coordination, and disclosure laws (e.g., GDPR, HIPAA).
Human resources	Supports insider threat handling, policy enforcement, and employee communications.
Incident communications lead	Manages internal/external messaging to control rumors and ensure consistent narratives.

Incident team leadership	Oversees the incident lifecycle and ensures escalation procedures are followed.
Information security manager	Owns the IRP (incident response plan), risk governance, and policy enforcement.
Internal audit	Reviews control effectiveness post-incident, ensures compliance with procedures.
Lead investigator	Manages forensic process, identifies root cause, and documents evidence.
Risk management	Evaluates residual and aggregate risk, aligns response with enterprise risk appetite.
Technical SMEs	Provide deep technical insight into affected systems, suggest containment and remediation actions.

Best Practices

- **Define roles in advance:** Document in IRP and DRP; map to incident categories and escalation paths.
- **Train for cross-function coordination:** Especially among Legal, HR, Comms, and IT.
- **Conduct tabletop exercises:** To validate real-time readiness of all participants.
- **Maintain chain-of-command:** Executive sponsors and team leads must have decision-making authority.
- **Ensure redundancy in roles:** Avoid over-reliance on one individual; document backups.

Note:

"An effective incident response hinges not only on speed, but on **role clarity and coordination**. This grid shows how the enterprise must bring together legal, operational, technical, and communication functions under one umbrella—because cybersecurity is no longer just an IT issue, it's a business risk issue."

Responsibilities of IS Manager

aligns closely with **Domain 4: Incident Management**, where the **Information Security (IS) Manager** plays a strategic and operational role in planning, coordination, validation, and budgeting of security incident response efforts.

Responsibilities of the Information Security (IS) Manager

Each represents a **core responsibility** that is tightly interwoven with enterprise-wide incident response planning and execution.

1. Develop information security incident management and response plans

- **Strategic alignment:** Create comprehensive plans that align with business objectives, regulatory requirements, and risk tolerance.
- **Key tasks include:**
 - Defining incident types and classification levels.
 - Mapping incident lifecycle processes (identify → contain → recover).
 - Ensuring plans are **reviewed, tested, and updated** regularly.
- **Tip:** This links to control design, risk assessment, and lifecycle maintenance in incident response programs.

2. Handle and coordinate information security incident response activities effectively and efficiently

- **Execution of plans in real-time:** Oversee coordination between stakeholders such as IT, legal, HR, and executive leadership.
- **Efficient response includes:**
 - Timely containment and escalation.
 - Maintaining the **chain of custody** for digital evidence.
 - Activating appropriate team roles and communication protocols.

- **Note:** Demonstrates operational accountability and command during incidents.

3. Validate and report safeguard or countermeasure solutions, either logical, physical, or administrative

- **Control testing and validation:** Confirm effectiveness of incident containment, recovery, and prevention mechanisms.
- Examples of safeguards:
 - **Logical:** IPS/IDS tuning, patch deployment.
 - **Physical:** Badge revocation, isolated access.
 - **Administrative:** Revised policies, additional training.
- **Relevance:** Supports post-incident analysis and continuous improvement.

4. Plan, budget, and develop program for all matters related to information security incident management and response

- **Program governance:** Oversee the design of a long-term, sustainable incident response program.
- Key activities include:
 - Resource allocation (tools, training, third-party vendors).
 - Defining KPIs and metrics.
 - Ensuring integration with **BCP/DRP and enterprise risk management**.
- **Best Practice:** Emphasize ROI justification and alignment with senior management priorities.

Integration Insight

The puzzle design highlights that **no responsibility stands alone**—strategic planning, operational execution, validation of controls, and budgetary oversight

must be synchronized to create a **resilient and adaptive incident response capability**.

Takeaway:

A successful IS manager:

- **Designs the playbook, calls the plays, validates the field, and funds the game.**
 - Must think long-term (strategically) **and** act quickly (tactically).
-

Incident Response Approach of IS Manager

outlines the guiding principles and operational mindset that an Information Security (IS) Manager must adopt to lead effective incident response (IR) efforts.

Breakdown of the IS Manager's Incident Response Approach

This illustrates key *tactical and strategic goals* the IS Manager must uphold, regardless of the nature or severity of the incident.

The approach to incident response varies depending on the situation and types of events that may occur, but the goals are constant.

1. Maintain incident response readiness

- **Proactive preparation** is crucial.
- Activities include:
 - IR policy and plan development
 - Training and awareness programs
 - IR testing (e.g., tabletop exercises)
- **Relevance:** Supports capability maturity and aligns with governance.

2. Contain and minimize the effects of the incident to prevent escalation of damage and losses

• Contain and minimize the effects of the incident so damage and losses do not escalate out of control

- Immediate action to:
 - Isolate affected systems
 - Prevent lateral spread
 - Protect data confidentiality and integrity
- **Best Practice:** Follow pre-approved containment playbooks.

3. Notify the appropriate people for the purpose of recovery or to provide needed information

- Ensures *timely communication* to:
 - Internal stakeholders (IT, legal, PR)
 - External entities (regulators, customers, vendors)
- **Reminder:** Define notification escalation paths in advance.

4. Recover quickly and efficiently from security incidents

- Restoration efforts must:
 - Align with RTOs and RPOs
 - Maintain system integrity
 - Avoid data re-exposure
- **Note:** Recovery should be aligned with BCP/DRP strategy.

5. Respond systematically and decrease the likelihood of recurrence

- **Root cause analysis (RCA)** and:
 - Patch vulnerabilities
 - Improve control design
 - Revisit incident classification schemes
- Promotes *resilience* through lessons learned.

6. Balance operational and security processes

- Ensure that:
 - Business continuity is not compromised
 - Security improvements are practical and do not disrupt core operations
- **Principle:** Security must support, not block, enterprise objectives.

7. Handle legal and law-enforcement-related issues

- Responsibilities include:
 - Preserving chain of custody
 - Coordinating with legal counsel
 - Managing regulatory disclosure obligations (e.g., GDPR, HIPAA)
- **Critical Competency:** Maintain compliance while managing reputational risk.

Key Takeaway

The IS Manager must act as both:

- **Tactical Commander:** Leading the response during chaos.
- **Strategic Architect:** Ensuring long-term readiness, compliance, and recovery.

The goals are **constant**, but execution is **adaptive** based on incident type, scope, and impact.

Emergency Management Activities

Incident Management, focusing on the **coordination between information security management and government emergency management services**. It highlights the role of the Information Security (IS) Manager in leveraging external capabilities to manage crises efficiently and effectively.

Key Elements of Emergency Management Activities

Role of the IS Manager:

The IS Manager is expected to:

- Understand and integrate external emergency resources into the organization's incident response and business continuity strategy.
- Leverage expert knowledge and historical data to improve preparedness.

The information security manager should determine the capabilities available from government emergency management officials (e.g., federal, regional, local).

- Advice and assist constituents in dealing with a wide range of natural and human-initiated threats.
- Provide information concerning the nature of the risk to which the location or area is susceptible.
- This will provide insight into historical events that will inform the enterprise on the sorts of events it must plan to manage.

Emergency management activities typically focus on the activities immediately after an incident:

- Measures to assure personnel safety, such as evacuation plans and creation of a command center from which emergency procedures can be executed.
- These events may require prompt action to recover operational status.
- Actions may necessitate restoration of hardware, software and/or data files.
- Communicate incident information to control exposure of potentially sensitive information.

Government Emergency Management Capabilities:

1. Advice and Assistance:

- Help enterprises manage both **natural disasters (e.g., floods, earthquakes)** and **human-initiated threats (e.g., cyberattacks, terrorism)**.
- Supports strategic planning and risk mitigation.

2. Risk Intelligence:

- Government agencies can supply detailed **risk assessments** for geographic areas or critical infrastructure.
- Enables **threat modeling** and informed **BCP/DRP development**.

3. Historical Event Insights:

- Past incidents help enterprises:
 - Predict risk exposure
 - Develop **scenario-based response plans**
 - Improve **resilience metrics**

Core Emergency Management Activities:

Activity	Description
Measures to assure personnel safety	Prioritizing life and safety through evacuation plans, sheltering, or first-aid protocols.
Prompt action to recover operational status	Immediate recovery steps like switching to alternate sites or restoring critical applications.
Restoration of hardware/software/data	Replacing or recovering assets that are essential for resuming business operations.
Communicating to control exposure	Ensure secure, timely, and coordinated communication to limit data leaks and maintain reputation and compliance.

Integration:

These actions align with key goals:

- Protecting people, information, and assets
- Coordinating with public-sector partners
- Maintaining readiness and rapid response

Summary:

An **effective IS Manager** must:

- Maintain **strong relationships with government entities**.
 - Know what support can be obtained **before, during, and after** an emergency.
 - Align emergency activities with the organization's **incident response, BCP, and DRP** frameworks.
-

Incident Management Testing and Evaluation

Key Concepts:

Testing (Validation-focused):

- **Purpose:** Ensure the plan works in a real or simulated environment.
- **Key Benefits:**
 - Validates the **plan's operational effectiveness**.
 - Verifies **individual roles and responsibilities** are understood.
 - Identifies **gaps or improvements** in the incident response strategy.

Testing Questions to Ask:

- Do responders know what to do?
- Is escalation handled properly?
- Are communications working?

Evaluation (Performance-focused):

- **Purpose:** Measure the plan's **efficiency, relevancy, and alignment** with organizational goals.
- **Key Triggers:**
 - Conduct **annually** or after **significant changes** in:
 - Technology
 - Business processes
 - Threat landscape
- **Evaluation Scope Includes:**
 - Staff skill and response readiness
 - Supporting tools, systems, and communication infrastructure
 - Organizational ability to meet **incident recovery targets (RTO/RPO)**

Integration:

Activity	Principle Aligned
----------	-------------------

Testing	Operational readiness; awareness and training effectiveness
Evaluation	Performance measurement; continuous improvement loop
Both	Governance, maturity assessments, control effectiveness verification

More Insights

The information security manager should provide regular testing and evaluation of the program.

Testing:

- Ensures and validates the effectiveness in managing incidents within the operating environment.
- Ensures that individuals know and understand their responsibilities
- Determines the effectiveness of the plan itself.

Program Evaluation is an independent and objective evaluation of processes, practices and activities against the enterprise's defined standard of practice for incident management

- should be conducted at least annually or when there are significant changes to the environment.
- Performed to determine efficiency and conformance with the plan
- Consider the processes, the individual capabilities and skill levels, plan relevancy, supporting infrastructure and overall ability to achieve defined targets as planned.

Summary:

- Ensure **regular testing** to validate that plans work.
- Perform **evaluation** to confirm plans are current, relevant, and effective.
- Use results to **adjust the incident management program** to meet evolving enterprise risk.

Incident Management Metrics and Indicators

Criteria used to measure the effectiveness and efficiency of the incident management function.

- Present metrics based on KPIs and program goals (KGIs) to senior management to justify continuous support and funding
- Enables senior management understanding of incident management capabilities and areas of risk to address



Key Terms and Concepts:

KPI (Key Performance Indicator):

- **Definition:** A specific, measurable value that tracks performance over time.
- **Example from Slide:**
Incidents resolved within two minutes
 - Reflects **real-time performance** or operational efficiency.

KGI (Key Goal Indicator):

- **Definition:** A broader measure of achieving a **strategic goal** or program objective.
- **Example from Slide:**
1,000 incidents resolved within two minutes
 - Reflects **overall achievement** aligned with business expectations.

Purpose of Incident Management Metrics:

1. **Justify continued investment** in incident management by showing results.
2. **Identify gaps** in incident response (e.g., low KPI % = performance issues).
3. **Enable management decision-making** for improving capability and reducing risk.

IS Manager Best Practices:

- **Align KPIs/KGIs** with business objectives and incident risk appetite
- **Track trends** over time for improvement.
- Use metrics to prioritize:
 - Staffing need
 - Training gaps
 - Technology upgrades

Integration Table:

Metric Type	Focus	Use Case
KPI	Operational performance	"How quickly are we resolving incidents?"
KGI	Strategic goal achievement	"Are we meeting organizational targets?"

More Insights

Incident management metrics, measures and indicators are the criteria used to measure the effectiveness and efficiency of the incident management function.

- Present metrics based on KPIs and program goals (KGIs) to senior management to justify continuous support and funding.
 - This enables senior management understanding of incident management capabilities and areas of risk to address.
 - For example, let's consider a business goal for the year to resolve 1,000 incidents within two minutes of occurrence.
 - KPI- KPIs are a quantifiable activity measure (e.g., the number of incidents per year resolved within two minutes of occurrence).
 - KGI: are either quantitative or qualitative measure, depending on the situation, intended to show progress toward or relating to a predefined goal
- At the point of measurement, the KPI of incidents currently resolved in the target time frame is 100; therefore, the KGI at the point of measurement is 25 percent (250 incidents resolved out of 1,000 target incidents).

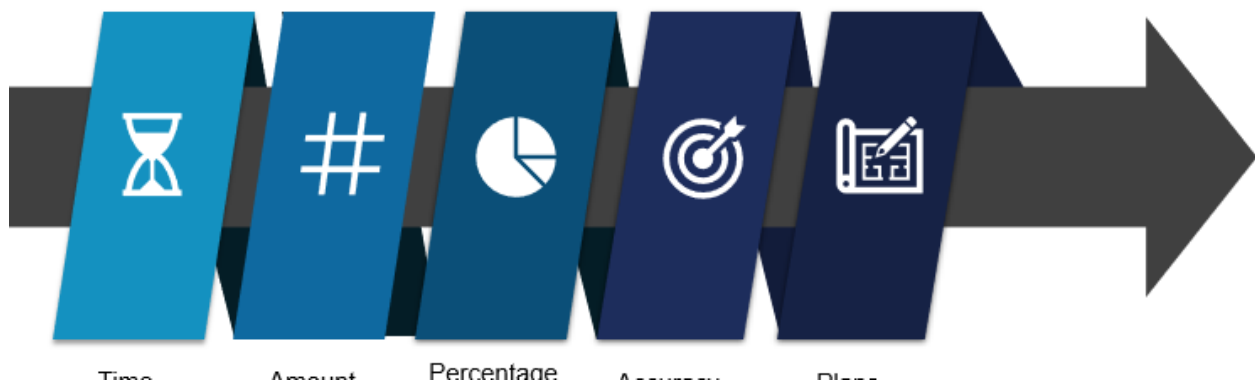
Summary:

- **KPIs** show **how well** a function performs.
- **KGIs** show **whether goals** are met.
- Effective use of both ensures **continuous improvement** in the incident management program.

Types of Metrics

outlines the **common categories of performance and risk indicators** relevant to **Domain 4: Incident Management**. It's designed to help information security managers define, track, and report the right measures to evaluate the effectiveness of their incident response programs.

Specific measures may vary based on enterprise, but general types include:



Overview of Metric Types:

Metric Type	Purpose
-------------	---------

Time	Measures how quickly actions are taken (e.g., time to detect/respond/recover)
Amount	Quantifies items such as number of incidents, patches applied, tickets resolved
Percentage/Number	Tracks ratios (e.g., % of successful recoveries, % compliance with SLA)
Accuracy	Measures correctness of actions (e.g., false positive rate, detection accuracy)
Plans	Assesses the existence, quality, and execution of documented plans (e.g., DRP, IRP)

Application in Context:

Metric Examples in Incident Management:

Metric Type	Sample Metric
Time	Mean Time to Detect (MTTD) or Mean Time to Recover (MTTR)
Amount	Number of incidents escalated
Percentage/Number	% of incidents resolved within SLA
Accuracy	% of false positives in alerts
Plans	% of incident response plans tested annually

More Insights

Although specific measurements vary depending on the test and the enterprise, the following general types of metrics usually apply:

- **Time**—Elapsed time for completion of prescribed tasks, delivery of equipment, assembly of personnel and arrival at a predetermined site. This is essential to refine the response time estimated for every task in the escalation process.
- **Amount**—Amount of work performed at the backup site by clerical personnel and the amount of information systems processing operations
- **Percentage and/or number**—The number of vital records successfully carried to the backup site versus the required number, and the number of supplies and equipment requested vs. actually received. The number of critical systems successfully recovered can be measured with the number of transactions processed.
- **Accuracy**—Accuracy of the data entry at the recovery site versus normal accuracy (as a percentage). The accuracy of actual processing cycles can be determined by comparing output results with those for the same period processed under normal conditions.
- **Plans**—The number of plans tested that cover each critical business process. This is required to ensure that business critical functions are properly accounted for, as criticality of business functions may change over time.

Why This Matters:

- Ensures **alignment with business objectives**
 - Enables **data-driven decision-making**
 - Supports **continuous improvement** in security operations
 - Forms the basis for **KPI/KGI reporting to senior management**
-

Other Key Metrics and Managing Risk

Presents essential disaster recovery and business continuity metrics used by information security managers to reduce operational risk and ensure recovery objectives are met. These metrics are foundational in **Domain 4: Incident Management** and support effective **Business Continuity Planning (BCP)** and **Disaster Recovery Planning (DRP)**.

Other Key Metrics and Managing Risk

RPO

- Determines and quantifies acceptable data loss during disruption
- Reduce time between backups to reduce volume of data to restore
- Large data restoration times can make achieving RTO difficult

MTO

- Maximum time an enterprise can operate in recovery mode
- Affected by factors related to the recovery site
- Variables affect RTO and RPO
- Consider relationship between MTO, RTO and RPO to minimize risk of inadequate recovery

SDO

- Minimal level of service restored to meet business requirements
- Affected by RTOs and RPOs
- Higher service levels require greater resources and more current RPOs

AIW

- Amount of time normal operations can be down before enterprise existence is threatened
- MTO should align to AIW to minimize enterprise risk during a disaster

Key Metrics Explained:

Metric	Description	Key Risk Relevance
RPO (Recovery Point Objective)	Maximum acceptable data loss measured in time	Drives backup frequency; long RPO means more potential data loss
MTO (Maximum Tolerable Outage)	Longest time a business can function in degraded mode before severe impact	Directly tied to disaster recovery planning
SDO (Service Delivery Objective)	Minimum acceptable level of service after disruption	Determines what services must be prioritized and how fast

AIW (Acceptable Interruption Window)	Maximum time normal operations can be halted before organizational viability is at risk	Sets outer boundary for recovery timelines (must not be exceeded)
---	---	---

More Insights

Recovery Point Objectives (RPO):

- Determines and quantifies acceptable data loss during operation disruption.
- Depending on the volume of data, it may be advisable to reduce the time between backups to prevent a situation where recovery becomes impossible because of the volume of data to be restored.
- It may also be the case that the time required to restore a large volume of data makes it impossible to achieve the RTO. While this is typically the scope of BC and DR planning, it is an important consideration when developing a risk management strategy.

Service Delivery Objectives (SDO)

- Minimal level of service that must be restored after an event to meet business requirements until normal operations are restored.
- SDOs will be affected by both RTOs and RPOs
- Higher levels of service will generally require greater resources as well as more current RPOs.

Maximum Tolerable Outage (MTO):

- Refers to the maximum time an enterprise can operate in alternate (or recovery) mode.
- Affected by various factors related to the recovery site, such as availability of fuel to operate emergency generators, accessibility of a recovery site that might be located remotely and limited operational capacity of the recovery site.
- This variable will affect the RTO, which, in turn, affects the RPO.
- Consider the occurrence relationship among the MTO, RTO and RPO to minimize risk of inadequate recovery to the organization.

Allowable Interruption Window (AIW)

- AIW is the amount of time the normal operations can be down before the enterprise faces major financial difficulties that threaten its existence.
- The MTO should in any event be as long as the AIW to minimize the risk to the organization in the event of a disaster.

Implications:

- **Align metrics** (RPO, RTO, MTO, SDO, AIW) to minimize **inadequate recovery risks**
 - Use these measures to **inform strategy**, evaluate **recovery site capabilities**, and justify **budget/resources**
 - Ensures **risk-informed decisions** and **just-in-time recovery** aligned with enterprise tolerances
-

Recovery Time Objectives (RTOs)

Key Takeaways:

Role of RTO:

- **RTO** defines the *maximum tolerable time* to restore systems and services after a disruption.
- It is business-driven — set based on **enterprise needs**, not technology alone.
- RTO works in tandem with:
 - **SDO (Service Delivery Objective)** – defines the minimum level of service during recovery.
 - **Cost-benefit analysis** – to justify what's worth restoring quickly.

Factors Affecting RTO:

- **Asset criticality** and **interdependencies** between systems
- **Timing of the business cycle:**
 - For example, **financial systems** may have stricter RTOs at the *end of the month* due to reporting deadlines.
 - At the *beginning of the month*, those systems may tolerate longer recovery times.

More Insights

The information security manager must understand how RTOs apply to the enterprise information resources as part of the overall risk evaluation.

- The enterprise business needs will dictate the RTO, which is usually defined as the amount of time to recover an acceptable level of normal operations.
- The acceptable level is defined by the SDO.
- Variables that determine the RTO are the information asset functional criticality, recovery priorities and interdependencies offset by costs.

The information security manager should consider that the RTO may vary with the timing of the month or year.

- •Consider the timing of business cycles and dependence on information need.
- •Financial information may not be as critical at the beginning of the month when the new fiscal month is being opened.
- •This same information is likely to be highly critical at the end of the month when the monthly financial reports are being prepared and the accounting period is being closed.

Application:

- Align RTOs with **risk tolerance**, **impact analysis (BIA)**, and **cost constraints**
- Use **RTOs to drive prioritization** of recovery tasks in the incident response and DR plans
- Periodically reassess RTOs as **business priorities shift**

Determining Recovery Time Objectives (RTOs)

Breakdown of RTO Determinants:

Factor	Description
--------	-------------

Cyclical Need	Time-of-day, weekly, monthly, or seasonal demand (e.g., payroll processing, month-end financial close) that affects system criticality.
Interdependencies & Cost	Interplay between business units and IT systems, plus the financial viability of recovery strategies.
Enterprise Requirements	Includes SLAs, regulatory mandates, and customer expectations that may demand tighter RTOs.
System Interconnections	Revealed via Business Impact Analysis (BIA) and used to define coordinated recovery priorities in the Business Continuity Plan (BCP) .

More Insights

Determining RTOs can depend upon multiple factors including the:

- Cyclical need (e.g., time of day, week, month or year) of the information and enterprise,
- Interdependencies among the information and the enterprise's requirements and the cost of available options.
- The enterprise requirements, such as customer needs, contractual obligations or service level agreements (SLAs), and, possibly, regulatory requirements.
- Interconnection of systems and their dependencies as determined by performing a BIA in coordination with developing a BCP.

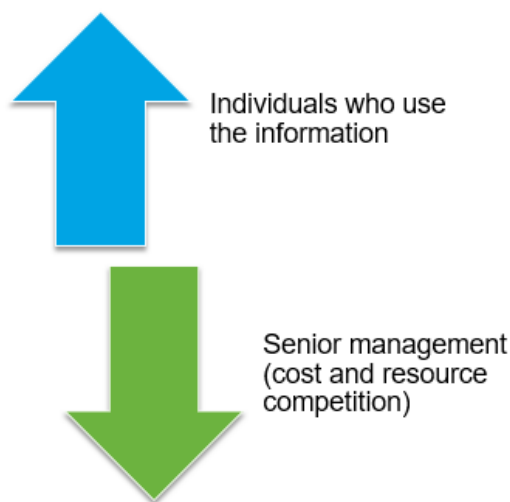
Key Considerations:

- RTOs are **not static**; they must evolve based on operational changes and enterprise context.
- **Interdependencies** require the IS manager to assess upstream/downstream impacts of downtime.
- RTO determination must be **realistic and cost-justified**, factoring in technical, financial, and operational constraints.
- Integration of RTOs with **BCP/DRP planning** ensures **resilience** and **risk alignment**.

RTO Perspectives

emphasizes the importance of balancing **operational need** with **business practicality** when defining Recovery Time Objectives —

RTO Perspectives



The information security manager should work toward an RTO considering both perspectives.

- Results factor into BCP, scope of restored services and system recovery priority
- Final decisions made by senior management based on business need

Perspective	Focus	Implications
Users of Information	Need quick recovery to resume operations and minimize impact	May push for shorter RTOs to maintain productivity
Senior Management	Weighs cost of recovery, resource allocation , and business justification	May extend RTOs based on strategic and budget constraints

More Insights

The BIA is generally conducted by interviewing information owners to obtain their perspective on the cost associated with an interruption in service for a business system or process. Often there are two perspectives for RTOs.

1. Individuals whose job it is to use the information,
2. Senior management who must consider costs and may need to arbitrate among business units competing for resources. For example, an information asset that a divisional supervisor may believe is critical may not be critical in the eyes of the vice president of operations, who is able to include the overall organizational risk in the evaluation of the RTO.

The information security manager should work toward an RTO considering both perspectives.

- The result factors into the BCP, the scope of the services to be restored and priority order for the recovery of systems.
- In the end, the final decision is that of senior management based on business need. Senior management is in the best position to arbitrate the needs and requirements of the different components of the business—such as the regulatory requirements to which the organization is subject—and determine which processes are the most critical to the continued survival of the business as well as determine acceptable costs.

IS Manager Responsibilities:

- Act as a **bridge** between users and management to define a **realistic and cost-effective RTO**.
 - Ensure RTO decisions are **documented** and integrated into the **BCP and system recovery prioritization**.
 - Acknowledge that while **users push for immediacy**, **senior management has final authority** based on **enterprise value and risk appetite**.
-

RTO Relationship with Continuity and Contingency Planning

provides essential insight into how **Recovery Time Objectives (RTOs)** guide the **development, prioritization, and costing** of contingency strategies

Must know RTO for systems and associated data to:

Identify and develop contingency strategies to meet RTOs

Drive order and priority of service restoration

Inform selection of specific recovery technologies

Cost is a critical factor when developing contingency processes:

- Recovery cost is often less if RTO is longer
- Balance cost trade-off of short RTOs
- Breakeven point depends on type of disruption and assets involved
- Consider costs quantitatively and qualitatively

RTO's Role in Continuity & Contingency Planning:

1. Identify and Develop Strategies

RTO defines the time window within which systems must be recovered, driving:

- Selection of hot, warm, or cold sites
- Use of backup methods, redundancy, or cloud-based failover

2. Drive Service Restoration Order

Shorter RTO = Higher priority → More immediate and costly resources allocated

3. Inform Technology Choices

RTO defines:

- Whether tape backups are sufficient
- Or whether real-time replication is necessary

Cost Considerations:

Factor	Insight
Recovery Cost vs. Time	Longer RTOs often reduce recovery costs
Short RTO Trade-Offs	Require faster solutions (e.g., hot sites), increasing costs
Breakeven Analysis	Helps weigh investment against potential impact
Quantitative & Qualitative	Must factor in reputation, regulatory, and legal risks too

More Insights

To implement an effective BC program, the enterprise must know the RTO for systems and associated data. Once the RTOs are known

- The enterprise can identify and develop contingency strategies that will meet the RTOs of the information resources.
- Which drive the order of priority for restoration of services
- and, in certain cases, inform selection of specific recovery technologies in situations where the RTO is short.

Cost is a critical factor when developing contingency processes. System owners invariably prefer shorter RTOs, but the tradeoffs in cost may not be warranted. Near-instantaneous recovery can be achieved, where needed, using technologies such as mirroring of information systems, so that, in the event of a disruption, the information systems are always available quickly.

- In general, the cost of recovery is less if the RTO for a given resource is longer. Most enterprises can reduce their RTOs, but there is an associated cost. There is a breakeven point of the time to determine the RTO, where the impact of the disruption begins to be greater than the cost of recovery. The length of this time depends on the nature of the business disruption and the assets involved.
 - Consider impacts qualitatively and quantitatively because loss of customer confidence, even if it cannot be estimated, can have a long-term negative impact on the enterprise.
-

Incident Management Report Criteria

Incident management reports and measures are useful for the IMT for self-assessment and for program assessment to determine what has been done satisfactorily and where improvements need to be made. Common criteria that are used as part of incident management metrics may include:

- Total number of reported incidents
- Total number of detected incidents
- Number of days without incident
- Average time to respond to an incident relative to the RTO
- Average time to resolve an incident
- Total number of incidents successfully resolved
- Incidents not resolved successfully
- Proactive and preventive measures taken
- Total number of employees receiving security awareness training
- Total damage from reported and detected incidents if incident response was not effective or not performed
- Total savings from potential damages from incidents resolved
- Total resources involved in responding to incidents
- Detection and notification times

IM/IR Performance Measurement

Key Concepts:

1. KGI and KPI Alignment

- **KGI (Key Goal Indicator)** = Outcome-based measure of long-term success
Example: % of incidents handled without business impact
- **KPI (Key Performance Indicator)** = Operational measure of process efficiency
Example: Average time to resolve incidents (MTTR)

These must be collaboratively defined by stakeholders and approved by senior leadership.

2. KGI Focus Areas

- Reflect **successful handling of incidents** under both:
 - **Simulated (test) conditions**
 - **Real-world (actual incident) conditions**

Typical KGI example: "90% of critical incidents resolved within 4 hours"

3. KPI Relevance to RTO

- Measures how effectively IR processes support:

- **Business continuity**
- **System recovery within the defined Recovery Time Objectives (RTOs)**

KPI example: "95% of incidents contained within 1 hour of detection"

More Insights

The performance measurements for incident management and response focus on achieving the defined objectives and optimizing cost-effectiveness.

- KGI and KPIs for the activity should be defined and agreed on by stakeholders and ratified by senior management.
- The typical range of KGIs encompasses the successful handling of incidents whether by live testing or under actual conditions.
- Key performance measures can be identified by successfully handling incidents that threaten business operations within the RTOs.

Tip:

Always relate performance measures to:

- Enterprise risk tolerance
- Business impact thresholds (e.g., RTO, MTO, AIW)
- Cost-efficiency in mitigating disruptions

Updating Recovery Plans

Key Responsibilities of the IS Manager:

1. **Establish Update Process**
 - Integrate recovery plan updates into ongoing enterprise change cycles.
2. **Assess Requirements During Change Management**
 - Evaluate how system, application, or organizational changes affect response/recovery strategies.

3. Schedule-Based Review

- Conduct periodic reviews even in the absence of major changes.

Factors That May Require Recovery Plan Updates:

Trigger	Impact
Inadequate Strategy	May no longer meet evolving enterprise needs
New Applications	Require integration into backup and recovery workflows
Business Strategy Shifts	Can redefine what is “mission-critical”
Environmental/Operational Changes	Existing provisions may become obsolete
Changing Physical Conditions	New threats may emerge (e.g., relocation, climate risks)

The response and recovery plans also need to change as the enterprise evolves and changes. To maintain the recovery plan, the information security manager must

- Establish a process to update recovery plans as changes occur within an enterprise.
- Assess the response and recovery plan requirements during the change management process within an enterprise.
- Review and update plans and strategies for response and recovery according to a schedule reflecting continuing recognition of changing requirements.

The following factors, along with others not listed, may impact requirements and the need for the plan to be updated:

- Inadequate strategy out of alignment with enterprise needs
- New applications developed or acquired

- Changes in business strategy altering significance of critical applications or additional applications deemed critical.
 - Changes in the software or hardware environment that render current provisions obsolete or inappropriate.
 - Changing physical and environmental circumstances
-

Maintaining Recovery Plans outlines essential **plan maintenance activities** that an Information Security (IS) Manager must implement to ensure recovery plans remain effective and current.

Core Maintenance Activities:

Activity	Purpose
Develop a schedule for periodic reviews	Ensure regular evaluation and updates
Call for revisions upon significant changes	Keep the plan aligned with business/technical realities
Review and update based on feedback	Incorporate lessons learned and recommendations
Schedule & coordinate tests (scheduled/unscheduled)	Validate effectiveness through simulations
Participate in annual plan tests	Confirm functionality and compliance at least once per year

Develop emergency/recovery training schedule	Ensure staff preparedness and role clarity
Maintain documentation of all plan updates	Provide an audit trail and historical context
Update notification directory	Ensure all personnel contact details are accurate and current

More Insights

The responsibility for maintaining the BCP/DRP often falls to a BCP coordinator and the information security manager may be responsible for maintaining the IRP. However these responsibilities are allocated, specific plan maintenance activities include:

- Develop a schedule for periodic review and maintenance of the plan and advise all personnel of their roles and the deadline for receiving revisions and comments
- Call for revisions when significant changes have occurred
- Review revisions and comments and update the plan within a reasonable period (e.g., 30 days) after the review date
- Arrange and coordinate scheduled and unscheduled tests of the plan to evaluate its adequacy
- Participate in scheduled plan tests, which should be performed at least once each year. For scheduled and unscheduled tests, the coordinator should write evaluations and integrate changes to resolve unsuccessful test results into the response plan within a reasonable period (e.g., 30 days).
- Develop a schedule for training personnel in emergency and recovery procedures, as set forth in the plan. Training dates should be scheduled within a reasonable period (e.g., 30 days) after each plan revision and scheduled plan test.
- Maintain records of plan maintenance activities, such as testing, training and reviews
- Update, at least quarterly, the notification directory to include all personnel changes, such as changes to phone numbers and responsibilities or status within the enterprise

Testing Plans highlights the key considerations for **testing business continuity (BC) and disaster recovery (DR) plans**, and the role of the **Information Security (IS) Manager** in ensuring the success of such testing.

Testing Plans

Testing:

- Promotes collaboration and coordination among teams
- Provides a useful training tool but costs valuable time and resources

Success:

- Define the relationship between teams clearly
- Understand and integrate with scope and capabilities of existing teams
- Gain an understanding of enterprise-specific BC process

To ensure that plans are tested, IS manager should:

Plan and control tests carefully to avoid placing the business at increased risk

Develop methodical test objectives to help ensure achievement of measurable benefits

Maintain a testing schedule for all critical functions

Consider testing after completion of plans, major drafts or following changes

Purpose of Testing:

- **Promotes collaboration and coordination** across teams.
- Acts as a **valuable training tool**—though resource-intensive.

Testing Success Factors:

Key Factor	Explanation
Define team relationships	Clarify who does what during a disruption
Understand team capabilities	Align testing scenarios with team competencies
Grasp enterprise-specific BC process	Customize tests to reflect the organization's structure and critical functions

IS Manager Responsibilities for Testing:

- **Plan and control tests** to minimize business disruption.
- **Develop clear test objectives** to ensure meaningful results.
- **Maintain a test schedule** for all critical functions.
- **Re-test after plan completion or major changes** (e.g., organizational, infrastructure, or regulatory updates).

All aspects of the IRP should be tested regularly to ensure plan execution results in successful recovery of infrastructure and critical business processes.

Testing:

- Promotes collaboration and coordination among teams
- Provides a useful training tool but also costs time and resources.

For better results:

- Clearly define the relationship between BC, DR and incident response and recovery teams as these vary between enterprises
- Understand and integrate with scope and capabilities
- Gain an understanding of enterprise-specific BC process including incident management and disaster recovery.

To ensure that all plans are regularly tested, the information security manager should:

- Plan and control tests carefully to avoid placing the business at increased risk.
 - Develop methodical test objectives to help ensure achievement of measurable benefits.
 - Maintain a testing schedule of dates and tests to be conducted for all critical functions.
 - Consider testing after completion of plans, major drafts or following changes in personnel, technology or environment
-

Testing Focus

outlines the **scope areas** and **expected outcomes** of Business Continuity (BC) and Disaster Recovery (DR) testing efforts.

Whatever the structure, the full scope of incident management responsibilities must be tested including

- Escalation
- Involvement of disaster management and recovery operation
- Or hand-offs to other teams
- To full disaster declaration.

Testing should focus on:

- Identifying gaps
- Verifying assumptions
- Testing timelines
- Determining the effectiveness of strategies
- Evaluating the performance of personnel
- Determining the accuracy and relevancy of plan information

Test Scope Areas:

Scope Component	Explanation
Escalation	Test how incidents are escalated from detection to decision-making authorities
Disaster Management & Recovery Ops	Validate response and recovery actions once a disaster is declared
Hand-offs	Evaluate transitions of tasks/responsibilities between teams or locations
Full Disaster Declaration	Practice declaring a disaster and activating full response protocols

Testing Should Include:

Testing Element	Purpose
Identifying gaps	Find deficiencies in current plans or procedures
Verifying assumptions	Confirm expected conditions and behaviors are realistic
Testing timelines	Ensure responses occur within expected RTO/MTO/SDO timeframes
Determining strategy effectiveness	Measure whether the strategies truly achieve resilience
Evaluating personnel performance	Assess readiness and decision-making capability of involved staff
Determining plan accuracy/relevancy	Ensure documentation reflects current assets, roles, and configurations

Key Point:

Testing should not only validate operational steps but also **improve incident response maturity**, help **meet recovery objectives**, and support **continuous improvement**.

Testing Infrastructure and Applications

outlines key areas the **Information Security Manager** must address to ensure **continuity and recoverability** of systems during normal and disaster operations.

Testing recovery and response plans must include both infrastructure and critical applications. The IS manager must secure these systems during normal operations and during disaster events by identifying

- Critical applications required by the enterprise
- Infrastructure needed to support critical applications
- Recovery tests used to ensure appropriate recovery time

Key Focus Areas:

Area	Description
Critical Applications	Identify applications vital for enterprise operations (e.g., finance, ERP, CRM, SCADA). These are prioritized during incident response and recovery.
Supporting Infrastructure	Includes servers, databases, storage, networks, and cloud components required to run critical applications. Their availability is essential to service continuity.
Recovery Tests	Simulate incidents to ensure recovery objectives like RTO (Recovery Time Objective) and RPO (Recovery Point Objective) are met. These validate system readiness under pressure.

Concepts:

- **Asset Classification** (from Domain 2): Classify applications and infrastructure by business criticality.
 - **Recovery Metrics Validation**: Confirm that recovery strategies match business impact levels.
 - **Continuous Improvement**: Use results from recovery tests to refine disaster recovery planning (BCP/DRP).
-

Recovery Testing Categories

Categories of Recovery Testing:

Test Type	Purpose & Characteristics
Paper Tests (a.k.a. tabletop tests)	- On-paper walkthrough of the plan (entire or portion) involving the major players in the plan's execution The goal is to determine what might happen in a particular type of service disruption. - Usually precede preparedness tests as preparedness and operational tests pose increasing difficulty and introduce the risk of disrupting operations.
Preparedness Tests	- Localized version of a full test where actual resources are expended in the simulation of a system crash. - These tests are performed regularly on different aspects of the plan - Provide cost-effective way to determine plan effectiveness and incremental improvement points
Full Operational Tests	- These tests are one step away from an actual service disruption. - An enterprise should have tested the plan well on paper and locally before endeavoring to completely cutover operations.

Types of Tests

shows a progression of **disaster recovery and business continuity testing** methods, from low-impact planning to high-stress operational simulations.

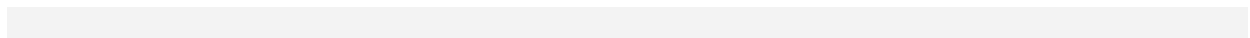
Progressively more challenging tests can include

- Tabletop walkthrough of the plans
- Tabletop walkthrough with mock disaster scenarios
- Testing the infrastructure and communication components of the recovery plan
- Testing the infrastructure and recovery of the critical applications
- Testing the infrastructure, critical applications and involvement of the end users
- Full restoration and recovery tests with some personnel unfamiliar with the systems
- Surprise tests

Progression of Recovery Test Types:

Test Type	Characteristics & Purpose
Tabletop Walkthrough of the Plans	- Discussion-based. - No live systems involved. - Validates documented procedures and responsibilities.
Tabletop with Mock Disaster Scenarios	- Adds simulated real-world disruption. - Tests decision-making under theoretical pressure.

Testing Infrastructure & Communication Components	- Verifies hardware/software readiness and team coordination. - Focus on technical failover and alert systems.
Testing Infrastructure & Critical Applications	- Assesses how core applications perform under failover. - Begins to simulate more realistic disruptions.
Testing with End-User Involvement	- Adds real workload and human factors. - Verifies usability and business process recovery.
Full Restoration & Recovery Tests (with Unfamiliar Personnel)	- Tests team resilience. - Ensures plan works even if key staff are unavailable.
Surprise Tests	- Unannounced drills to test true preparedness. - Measures real-time reaction, speed, and coordination.



Test Preparations

outlines key responsibilities of the **Information Security (IS) Manager** prior to executing any test related to disaster recovery or business continuity.

Responsibilities:

Requirement	Purpose / Rationale
Minimize disruption risk	The risk and impact of disruption from testing is minimized
Business risk acceptance	The business understands and accepts the risk inherent in testing.
Fallback arrangements in place	Fallback arrangements exist to restore operations at any point during the test.
Comprehensive documentation	All tests are fully documented with pretest, test and posttest reports.
Retain documentation for audits	Test documentation is retained for audit review and reference.
Test information security controls	Information security is also tested and not compromised during testing.

Test Evaluations and Documenting Findings

Once test objectives have been defined, the information security manager should ensure that an independent third party (internal/external audit or other assurance personnel) is present to monitor and evaluate the test.

Test Evaluations and Documenting Findings

After establishing test objectives, the IS manager should ensure an independent third party is present to monitor and evaluate the test.

Outcomes

- Result of findings and corresponding implementation recommendations to improve response and recovery plans
- Tracking process to ensure that recommendations are implemented
- List of personnel assigned to make necessary changes

Documentation:

- Specific steps and recorded information from each team
- Historical information that can facilitate recovery
- Detailed analysis of plan strengths and weaknesses

Post-Test Evaluation Responsibilities:

1. Involve an Independent Third Party

- Ensures **objectivity** in test monitoring and evaluation.
- Increases **credibility** of test findings and adherence to compliance/audit standards.

2. Evaluation Outcomes:

Element	Purpose
Findings and recommendations	Identify improvement areas and provide actionable recovery enhancements.
Tracking process	Verifies that recommendations are implemented.
Assigned personnel	Defines accountability for remediation tasks.

3. Documentation Requirements:

Element	Description
Recorded steps and team actions	Provides detailed audit trail.
Historical data	Supports learning from past events and streamlines future recovery.
Analysis of strengths/weaknesses	Helps identify areas needing updates or retraining.

More Insights

Once test objectives have been defined, the information security manager should ensure that an independent third party (internal/external audit or other assurance personnel) is present to monitor and evaluate the test. The outcomes include:

- The result of findings and corresponding implementation recommendations to improve response and recovery plans
- A tracking process to ensure recommendations are implemented
- A list of personnel assigned to make necessary changes.

Detailed documentation of observations, problems and resolutions should be maintained during every phase of the test providing:

- Specific steps and information recorded from each team.
 - Historical information that can facilitate actual recovery during a real disaster.
 - Detailed analysis of the plan's strengths and weaknesses.
-

Testing Considerations

Key Testing Considerations for the IS Manager:

Consideration	Description
Schedule tests to minimize operational impact	Ensure minimal disruption to production by selecting low-risk times.
Address all critical components	Testing should not overlook essential systems, processes, or dependencies.
Simulate real-world conditions	Run tests under prime-time processing conditions to assess realistic stress and failures.
Include all key recovery team members	Ensures coordinated response, validates role clarity, and improves training effectiveness.

More Insights

- Response and recovery tests commonly fall short of a full-scale test of all operational portions of the enterprise. This should not prevent full testing as the purpose should determine plan effectiveness and areas of improvement.
- The IS manager should consider the benefits and consequences before recommending test approaches. Surprise tests can provide a similar experience to real-life scenarios but also can be potentially disruptive on operations.
 - •Schedule tests to minimize impact on normal operations
 - •Address all critical components
 - Simulate actual prime-time processing conditions, even if the test is conducted during off hours (such as weekends)
 - It is important for all key recovery team members to be involved in the recovery test process

Performing Preparedness or Recovery Testing

highlights the structured phases and importance of measurement in evaluating business continuity (BCP) and disaster recovery (DR) plans. This supports **Domain 4: Incident Management** objectives regarding **testing, metrics, and continual improvement**.

Phases of Testing:

Phase	Purpose
Pretest	Set objectives, define scope, document assumptions, and prepare participants.
Test	Execute the plan to simulate a recovery or continuity scenario.
Posttest	Review results, identify gaps, and document lessons learned.

Use of Metrics in Testing:

Metric Activity	Purpose
Record and evaluate metrics quantitatively	Track measurable data like time to recovery, resource utilization, and system availability.
Measure plan effectiveness	Identify whether objectives were met (e.g., RTO, RPO).
Provide means to improve plan	Feed results into corrective actions and updates to BCP/DRP.

To perform preparedness or operational recovery testing complete each of the following test phases:

1. Pretest—

- The pretest consists of the set of actions necessary to set the stage for the actual test ranging from placing tables in the proper operations recovery area to transporting and installing backup telephone equipment. These activities are outside the realm of those that would take place in the case of a real emergency, in which there is generally no forewarning of the event and thus no time to take preparatory actions.

2. Test—

- This is the actual test of preparedness to respond to an emergency.
- Actual operational activities are executed to test the specific objectives of the plan such as data entry, telephone calls, information systems processing, handling orders, and movement of personnel, equipment and suppliers should take place.
- Evaluators should review staff members as they perform the designated tasks.

3. Posttest—

- The posttest is the cleanup of group activities. This phase comprises assignments such as returning all resources to their proper place, disconnecting equipment, returning personnel to their normal locations and deleting all company data from third-party systems.
- The posttest cleanup also includes formally evaluating the plan and implementing indicated improvements.

Metrics

- Metrics should be developed and used in measuring the success of the plan and testing against the stated objectives.
 - Results should be recorded and evaluated quantitatively, as opposed to an evaluation based only on verbal descriptions.
 - The resulting metrics should be used not only to measure the effectiveness of the plan, but more importantly, to improve it.
 - .
-

Test Results and Outcomes

A Recovery Test Should Strive to:

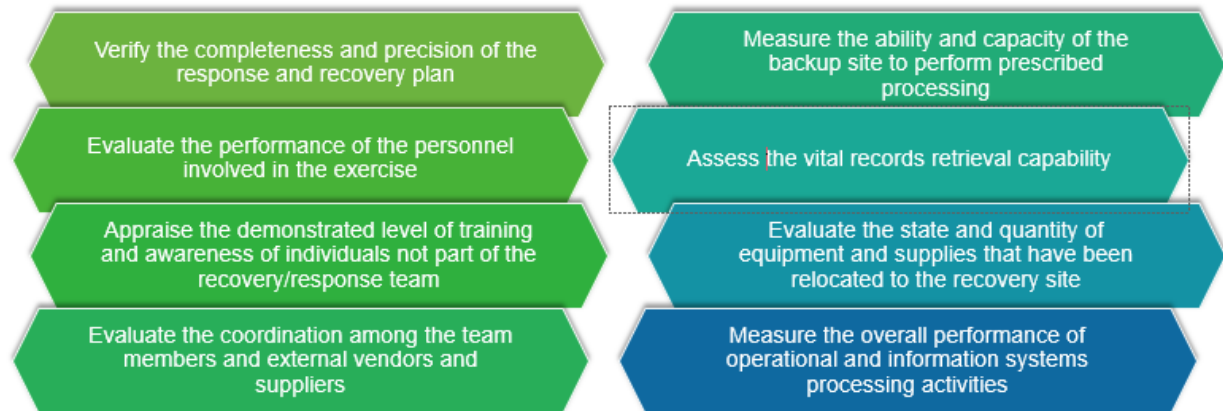
Plan Validation & Team Evaluation

Objective	Purpose
Verify completeness and precision of the response and recovery plan	Ensure plans are thorough and correctly structured for execution.
Evaluate performance of the personnel involved	Measure readiness, speed, and accuracy of staff actions.
Appraise awareness of non-participating staff	Gauge general enterprise-wide understanding and preparedness.
Evaluate team/vendor coordination	Confirm synchronization and collaboration across internal and external roles.

Technical & Operational Assessment

Objective	Purpose
Measure backup site capability	Validate infrastructure capacity for real workload processing.
Assess vital records retrieval	Ensure critical data is accessible and usable post-disruption.
Evaluate equipment/supplies relocation	Test readiness of logistics and resource staging.
Measure overall performance of operations/IT systems	Determine actual system throughput, availability, and response.

A recovery test should strive to:



Takeaway:

- **Comprehensive recovery testing** must go beyond checklists—it should validate **technical infrastructure, human readiness, and operational continuity**.
- **Measurement criteria** include **plan accuracy, site capabilities, resource availability, and cross-functional team coordination**.
- These outcomes feed into **continuous improvement** and form the basis for reporting to **senior management**.